

DESIGN AND EVALUATION OF INFRAGUARD AI: A
GOVERNANCE-BY-DESIGN REFERENCE FRAMEWORK FOR
BOUNDED LLM-ASSISTED INCIDENT TRIAGE

BY

ADEBODUN SAMUEL TOMOLA

MATRICULATION NUMBER: 2025/A/MIT/0616

DEPARTMENT OF INFORMATION TECHNOLOGY
SCHOOL OF COMPUTING
MIVA OPEN UNIVERSITY, ABUJA
NIGERIA

A PROFESSIONAL MASTER'S PROJECT SUBMITTED TO THE DEPARTMENT OF
INFORMATION TECHNOLOGY, SCHOOL OF COMPUTING, MIVA OPEN
UNIVERSITY, ABUJA, NIGERIA.

IN PARTIAL FULFILMENT OF THE REQUIREMENTS FOR THE AWARD OF THE
PROFESSIONAL MASTER OF INFORMATION TECHNOLOGY DEGREE

AUGUST 2026

CERTIFICATION

I certify that this project is my original work, except where the work of others is acknowledged through citations and references. The project has not been submitted to this University or another institution for the award of a degree.

Student: Adebodun Samuel Tomola

Matriculation Number: 2025/A/MIT/0616

Signature: _____

Date: _____

APPROVAL

This project has been approved for the Department of Information Technology, School of Computing, Miva Open University, Abuja, Nigeria.

Project Supervisor: Dr. Emmanuel Mkpojiogu

Signature: _____ Date: _____

Head of Department: Dr. Abdullahi Mohammed

Signature: _____ Date: _____

Dean, School of Computing: Dr. Emeka Ogbuju

Signature: _____ Date: _____

External Examiner: Prof. Kingsley Obani

Signature: _____ Date: _____

DEDICATION

This project is dedicated to my family and to the engineers who maintain critical digital services with limited operational resources.

ACKNOWLEDGEMENT

I thank Almighty God for the strength and opportunity to complete this programme and project.

I am grateful to my project supervisor and the staff of the Department of Information Technology for their guidance and criticism throughout the work. Their feedback helped narrow the project to a testable implementation.

I also thank colleagues and practitioners who discussed the operational problems that motivated the system, particularly alert fatigue, slow incident triage, and the cost of maintaining several monitoring tools.

I acknowledge the maintainers of the open-source software used in the implementation, including FastAPI, LangChain, LangGraph, ChromaDB, Prometheus, Grafana Loki, and CrowdSec.

Finally, I thank my family and friends for their patience, encouragement, and support during the programme.

ABSTRACT

Cloud-native systems generate operational evidence faster than small teams can interpret it. Using Design Science Research Methodology, this study developed InfraGuard AI, an operator-hosted governance-by-design reference framework for bounded LLM-assisted incident triage. It integrates telemetry, local runbook retrieval, structured verdicts, acknowledgement memory and operator-approved threat response.

The 2 September local working tree passed 180 source-scoped tests at 89% line coverage. In the separate frozen qwen2.5:3b benchmark, 24 purposive synthetic scenarios were each repeated three times, producing 72 scenario-run responses. All 72 were schema-valid, but exact agreement with researcher-defined severity labels was 40.3%. Six high-to-warning under-calls arose from two scenario families, each repeated three times. Only 10 of 24 scenarios (41.7%) produced identical signatures across their three runs.

A relevant runbook appeared in the top four for all twelve labelled questions, demonstrating top-four runbook retrievability within the frozen corpus, not answer correctness or a causal RAG benefit. The separate System Usability Scale survey yielded a descriptive mean of 79.25 from 10 complete responses among 11 consented submissions, indicating favourable perceived usability within the exploratory convenience sample.

The contribution is an inspectable reference implementation and an evidence-based design finding: schema compliance and top-four retrievability do not establish reliable diagnosis. The current acknowledgement implementation is a prototype mechanism rather than a validated durable-condition identity mechanism; a deterministic telemetry-derived identity is the next design iteration. Human authority remains necessary for action. Evidence remains limited to a local working-tree verification, one model, purposive synthetic scenarios and a small usability sample; production effectiveness and cross-model performance remain unmeasured.

Keywords: InfraGuard AI; AI governance; governance-by-design; incident triage; observability; retrieval-augmented generation; human oversight; design science; System Usability Scale.

TABLE OF CONTENTS

CHAPTER ONE: INTRODUCTION.....	1
1.1 Background to the Project.....	1
1.2 Statement of the Problem.....	1
1.2.1 Research Gap.....	2
1.2.2 Nature of the Contribution and Novelty Boundary.....	3
1.3 Aim and Objectives of the Project.....	3
1.3.1 Aim.....	3
1.3.2 Research Questions.....	3
1.3.3 Specific Objectives.....	4
1.4 Scope of the Project.....	4
1.4.1 Within Scope.....	4
1.4.2 Out of Scope (Identified as Future Work).....	5
1.5 Significance of the Project.....	5
1.5.1 Significance to Industry.....	5
1.5.2 Significance to Organisations.....	5
1.5.3 Significance to Policy and Society.....	6
1.5.4 Significance to Professional Practice.....	6
1.5.5 Significance to the Master of Information Technology Programme.....	6
CHAPTER TWO: LITERATURE REVIEW AND TECHNOLOGY CONTEXT.....	7
2.1 Conceptual Review.....	7
2.1.1 Cloud-Native Observability and the Three Pillars.....	7
2.1.2 Site Reliability Engineering and Incident Management.....	7
2.1.3 AIOps: Artificial Intelligence for IT Operations.....	7
2.1.4 Large Language Models and Agentic AI.....	8
2.1.5 Retrieval-Augmented Generation.....	8
2.1.6 Statelessness, Alert Deduplication, and Agent Memory.....	8
2.1.7 Human-Automation Decision Support, Alert Fatigue, and Trustworthy AI.....	9
2.1.8 Theoretical Foundations, Domain Concepts, and Design Constructs.....	10
2.2 Review of Existing Systems and Solutions.....	12
2.2.1 Comparative Table of Thirteen Recent and Related Studies.....	12
2.2.2 Synthesis of the Reviewed Studies.....	13
2.2.3 Commercial and Open-Source State of the Art.....	14
2.2.4 Feature-Level Comparison of Related Operator-State Mechanisms.....	15
2.3 Review of Relevant Technologies, Tools, and Frameworks.....	16
2.3.1 Programming Language and Runtime.....	16
2.3.2 Web and API Framework.....	16
2.3.3 LLM Orchestration and Provider.....	16
2.3.4 Observability and Telemetry Sources.....	17
2.3.5 Data Stores.....	17
2.3.6 Security and Deployment.....	17
2.3.7 Relevant Standards and Specifications.....	17
2.4 Gap Analysis.....	18
2.4.1 Grounding and response validation.....	18
2.4.2 Deployment control.....	18
2.4.3 Inspectable entry point.....	18
2.4.4 Recurring-condition acknowledgement.....	19
2.4.5 Operator approval for enforcement.....	19
2.4.6 Organisation-specific runbooks.....	19

2.4.7 Reproducibility.....	19
CHAPTER THREE: METHODOLOGY AND SYSTEM DESIGN.....	20
3.1 Project Methodology.....	20
3.1.1 Methodological Phases.....	20
3.1.2 Methodology Rationale, Tools and Evidence Alignment.....	20
3.1.3 Human Evaluation Design and Evidence Separation.....	23
3.1.4 Research Ethics and Data Provenance.....	24
3.2 Requirements Analysis.....	24
3.2.1 Functional Requirements.....	25
3.2.2 Non-Functional Requirements.....	26
3.2.3 Actors and Use Cases.....	30
3.3 System Architecture.....	30
3.3.1 Architectural Style.....	31
3.3.2 Components.....	31
3.3.3 Communication Patterns.....	32
3.3.4 High-Level Architecture.....	32
3.3.5 Deployment Topology.....	33
3.3.6 Heartbeat Verdict Pipeline.....	35
3.4 System Design.....	37
3.4.1 Database Design (Entity-Relationship Model).....	37
3.4.2 Use-Case Model.....	37
3.4.3 Sequence Diagram: One Heartbeat Cycle.....	38
3.4.4 Entity-Relationship Model.....	39
3.4.5 Verdict-Memory Design.....	40
3.4.6 State Machine: LangGraph Reasoning Agent.....	40
3.4.7 Workflow: Runbook RAG Indexing.....	41
3.5 Tools and Technologies Used.....	41
3.5.1 Backend and Orchestration.....	41
3.5.2 Security and Deployment.....	42
3.5.3 Telemetry Sources.....	42
3.5.4 Design Trade-offs and Alternatives.....	42
CHAPTER FOUR: SYSTEM IMPLEMENTATION.....	44
4.1 Development Environment.....	44
4.1.1 Development Environment and Tooling.....	44
4.2 Implementation Details.....	44
4.2.1 Repository Layout.....	44
4.2.2 Reasoning, Prompt Validation and Verdict Memory.....	46
4.2.3 Telemetry, Runbook Retrieval and Threat Response.....	48
4.2.4 API, Persistence and Retention.....	48
4.2.5 The Dashboard.....	49
4.2.6 API Endpoints.....	50
4.3 Security, Performance, and Scalability Considerations.....	51
4.3.1 Authentication, Output Hygiene and Auditability.....	51
4.3.2 Performance, Scalability and Deployment Boundary.....	52
4.3.3 Data Governance and Cloud-LLM Boundary.....	53
4.3.4 Security Threats Specific to LLM-Assisted Incident Triage.....	54
4.4 Challenges Encountered.....	55
CHAPTER FIVE: TESTING, RESULTS AND EVALUATION.....	57
5.1 Testing Strategy.....	57
5.1.1 Automated Test Scope.....	57

5.2 Automated Test Results.....	58
5.2.1 Coverage by Module.....	58
5.2.2 Representative Test Cases.....	59
5.3 Acknowledgement-Memory Evaluation.....	60
5.4 Limited Researcher-Observed Functional Verification.....	61
5.4.1 Runbook Retrieval Convenience Pilot.....	61
5.4.2 Controlled Local-Model Incident and RAG Benchmark.....	62
5.4.3 Descriptive Exploratory System Usability Scale Assessment.....	67
5.5 Evaluation Against the Objectives.....	68
5.6 Discussion and Threats to Validity.....	69
5.6.1 Supported Findings.....	69
5.6.2 Limitations.....	70
5.6.3 Validity.....	70
CHAPTER SIX: SUMMARY, CONCLUSION AND RECOMMENDATIONS.....	71
6.1 Summary of the Project.....	71
6.2 Conclusion.....	71
6.2.1 Answers to the Research Questions.....	72
6.3 Research and Professional Contributions.....	72
6.4 Recommendations for Future Work.....	74
6.4.1 Evaluation.....	74
6.4.2 Test and Security Coverage.....	75
6.4.3 Architecture.....	75
REFERENCES.....	77
APPENDIX A: API ENDPOINT REFERENCE.....	82
A.1 Authentication and Health.....	82
A.2 Status, History, and Configuration.....	82
A.3 Verdict Memory.....	82
A.4 Threats.....	82
A.5 Runbooks (RAG).....	83
APPENDIX B: SAMPLE CODE SNIPPETS.....	84
B.1 Verdict Fingerprint and Signature Derivation.....	84
B.2 Severity Safeguard.....	84
B.3 Known-Conditions Memory Block.....	85
B.4 Deterministic Threat Detection.....	85
B.5 LangGraph Reasoning Loop.....	86
APPENDIX C: DOCKER COMPOSE CONFIGURATION.....	87
APPENDIX D: PRACTITIONER USABILITY INSTRUMENT AND DESCRIPTIVE EXPLORATORY SUS RESULTS.....	88
D.1 Task Script.....	88
D.2 System Usability Scale Questionnaire.....	88
D.3 Executed Descriptive Exploratory SUS Study.....	89
APPENDIX E: CONTROLLED INCIDENT AND RAG EVALUATION PROTOCOL AND OBJECTIVE RESULTS.....	91
E.1 Evaluation Questions and Fixed Conditions.....	91
E.2 Controlled Incident Scenario Set.....	91
E.3 Diagnostic Scoring Rubric and Metrics.....	93
E.4 Labelled RAG Baseline.....	94
E.5 Execution and Reporting Procedure.....	94
E.6 Evidence Status.....	95
E.7 Reproducibility Record.....	95

APPENDIX F: PRACTITIONER ROLE-REPORT PROVENANCE AND PERMITTED USE.....	98
F.1 Evidence Inventory and Provenance Boundary.....	98
F.2 Qualitative Role-Report Themes.....	98
F.3 Requirements for a Future Quantitative Practitioner Study.....	99

LIST OF FIGURES

Figure 2.1: Conceptual Framework for Operator-Hosted, LLM-Assisted Incident Triage.....	12
Figure 3.1: High-Level Architecture of InfraGuard AI.....	33
Figure 3.2: Intended Single-VPS Topology for DevPlanner and InfraGuard AI.....	34
Figure 3.3: Heartbeat Pipeline and Remediation Boundary.....	36
Figure 3.4: InfraGuard AI Use-Case Model.....	38
Figure 3.5: Sequence of One Heartbeat Cycle.....	39
Figure 3.6: Verdict and Acknowledgement Data Model.....	40
Figure 3.7: LangGraph Agent State Machine.....	41
Figure 4.1: Repository Layout of the Reference Implementation.....	45
Figure 4.2: Verdict-Memory Fingerprint and Acknowledgement Flow.....	47
Figure 4.3: InfraGuard AI Operations Dashboard.....	49
Figure 4.4: Local Runbook Indexing and Retrieval Process.....	50
Figure 4.5: Cloud-LLM Data Boundary and Local Retention Points.....	54
Figure 5.1: Selected-Module Coverage after Post-Review Verification on 29 August 2026..	59
Figure 5.2: Deterministic 30-Cycle Illustration of Default-View Duplicate Presentation.....	60
Figure 5.3: Proposed Five-Case Practitioner Usability Workflow.....	62

LIST OF TABLES

Table 2.1: Comparative Review of Thirteen Studies in AIOps and LLM-Assisted Operations.....	13
Table 2.2: Thematic Synthesis of Findings, Tensions and Design Implications.....	14
Table 2.3: Feature-Level Comparison of Related Operator-State and Memory Mechanisms.....	15
Table 2.4: Theoretical Foundations and Application to InfraGuard AI.....	10
Table 2.5: Relevant Standards and Specifications.....	17
Table 3.1: Research-Question, Objective, Method, Evidence, and Current-Answer Alignment.....	21
Table 3.2: Design-Science Mapping for InfraGuard AI.....	23
Table 3.3: Functional Requirements of InfraGuard AI.....	25
Table 3.4: Non-Functional Requirements of InfraGuard AI.....	26
Table 3.5: Requirement Sources, Acceptance Criteria and Verification Evidence.....	27
Table 3.6: Telemetry Sources and Collection Tools.....	42
Table 3.7: Principal Design Choices, Alternatives, and Trade-offs.....	42
Table 4.1: Repository Module Map and Responsibilities.....	45
Table 4.2: API Endpoint Reference.....	50
Table 4.3: Security and Privacy Controls by Evidence Classification.....	52
Table 5.1: Verified Software-Test Chronology and Evidence Boundaries.....	58
Table 5.2: Representative Automated Test Cases and Results.....	59
Table 5.3: Live Runbook-Retrieval Pilot Configuration.....	61
Table 5.4: Controlled Benchmark Configuration and Provenance.....	63
Table 5.5: Objective Incident-Benchmark Results.....	63
Table 5.6: Severity Confusion Matrix for 72 Incident Responses.....	64
Table 5.7: Objective RAG and No-RAG Benchmark Results.....	65
Table 5.8: Practitioner Role-Report Evidence Status and Permitted Use.....	66
Table 5.9: RAG Evaluation Dimensions, Evidence Status, and Supported Conclusions.....	66
Table 5.10: Practitioner Role-Report Engineering Hypotheses for Future Testing.....	67
Table 5.11: Descriptive Exploratory System Usability Scale Results.....	68
Table 5.12: Objective and Evidence Matrix.....	68
Table 5.13: Provider and Model Interface versus Empirical Evidence Status.....	69
Table 6.1: Research Contribution Map.....	73
Table 6.2: Evidence-Claim Boundary.....	74
Table 6.3: Principal Contribution and Limitations.....	74
Table D.1: Included Human SUS Participant Scores.....	89

Table D.2: Mean Raw Response by SUS Item.....	90
Table E.1: Gold Severity Policy for the Controlled Benchmark.....	91
Table E.2: Controlled Incident Benchmark Scenarios and Gold Expectations.....	92
Table E.3: Per-Response Diagnostic Scoring Rubric.....	93
Table E.4: Labelled Runbook Question Set for RAG and No-RAG Comparison.....	94
Table E.5: Controlled Benchmark Reproducibility Record.....	96
Table F.1: Practitioner Evidence Inventory and Permitted Use.....	98

CHAPTER ONE: INTRODUCTION

1.1 Background to the Project

Containerised services continuously produce logs, metrics and service events. Although these signals are useful, their volume and distribution make incident review difficult for a small operations team that must compare several sources before judging whether a service is healthy, degraded or failing.

Observability uses system outputs to infer internal state. Prometheus, Grafana Loki, OpenTelemetry and related tools collect and expose telemetry, but a person must still interpret the evidence and choose the response.

Site reliability engineering treats repetitive operational work as toil and recommends automation where the work is predictable and reviewable (Beyer et al., 2016). Initial incident triage fits this description in part: the inputs are available as telemetry, but a useful judgement still depends on context and experience. The purpose of this project is to assist that first review, not to replace the operator who remains responsible for action.

Large language models can summarise technical evidence and retrieve additional context, but they may infer unsupported facts, misread absent optional integrations or violate the required response structure. Prompt constraints, output validation and human approval reduce these risks without proving verdict correctness.

Nigerian organisations that operate digital services must also account for data-protection and sector-specific cybersecurity obligations. The Nigeria Data Protection Act 2023 sets duties for responsible processing of personal data. For institutions within its scope, the Central Bank of Nigeria's 2024 cybersecurity framework includes monitoring, reporting, and resilience controls (Central Bank of Nigeria, 2024; Federal Republic of Nigeria, 2023). Local deployment keeps the application records and access controls on the operator's host, but any prompt sent to a cloud LLM provider leaves that host.

LivWell (Integrated Wellness Inc.) provided the operational setting that informed the requirements: several environments, containerised workloads, a small team, and a need for clear incident records. These constraints led to a single-host design, bounded telemetry collection, request auditing, operator-approved threat response, and an acknowledgement feature for recurring conditions. The result is a working reference implementation called InfraGuard AI.

1.2 Statement of the Problem

Five practical issues remain even when monitoring tools are already in place:

1. Triage time. When several telemetry sources report a problem, a responder must compare the evidence before stating the likely cause and next action. This work tests whether a bounded first-pass summary can support that review.
2. Repeated low-risk findings. A known condition may appear on successive heartbeat cycles and occupy the same dashboard space as an unreviewed finding.
3. Ungrounded model output. An LLM can infer a cause that is not supported by the supplied telemetry or treat an optional integration as a fault. Its response therefore needs scope constraints, structured parsing, and operator review.
4. Deployment and data handling. Managed platforms and cloud model APIs differ in cost, hosting model, and the telemetry they receive. A small team needs a design whose data boundary can be inspected and configured.
5. Limited operator memory. A recurring condition may appear on every heartbeat even after an operator has reviewed it. Without an acknowledgement mechanism, the dashboard provides no durable way to distinguish a known low-risk condition from an unreviewed one.

These issues lead to the explicit research questions in Section 1.3.2. They examine the construction of bounded telemetry context, the operator-hosted architecture, the acknowledgement mechanism, the scope of the completed evidence, and the deployment and governance constraints of cloud or local inference.

1.2.1 Research Gap

Knowledge gap. Existing research demonstrates LLM-based incident summarisation, root-cause assistance, tool use and retrieval, but does not establish that a compact local model will classify operational severity reliably in a small-team, single-host setting. The project therefore examines bounded behaviour rather than assuming diagnostic effectiveness.

Design gap. Alert acknowledgement, grouping, deduplication, suppression, incident-management state and agent memory address related operator-state problems. The reviewed sources did not establish the same combination of evidence-bounded context, provider/model traceability, operator-controlled action, a model- and prompt-bound acknowledgement rule, and an independent severity safeguard for recurring LLM-assisted verdicts. This scoped distinction motivates the governance-by-design framework but does not by itself prove universal novelty or superiority.

Engineering gap. Small teams need an inspectable prototype that combines selected telemetry, provider-portable interfaces, local runbooks, structured validation, operator-approved enforcement and reproducible evidence. Deployment control and integration form the engineering contribution.

Empirical evaluation gap. Evidence remains limited on comparative model performance, human diagnostic agreement, task completion, workload, alert fatigue, resource cost and production effectiveness in this context. The present study addresses feasibility and a frozen single-model baseline while retaining those broader outcomes as future work.

1.2.2 Nature of the Contribution and Novelty Boundary

What is new? InfraGuard AI does not claim invention of observability, RAG, human oversight, alert acknowledgement or governance-by-design. Its contribution is their scoped operationalisation in one inspectable, operator-hosted incident-triage artefact with explicit evidence, data and action boundaries.

Conceptual contribution. A risk-driven governance-by-design model connects imperfect model behaviour to bounded context, visible provenance, validation, retained human authority and continuing oversight.

Architectural contribution. Telemetry collection, evidence construction, model inference, output validation, operator approval and auditable state are separated so their trust boundaries can be reviewed.

Engineering contribution. The single-host reference implementation and versioned evaluation package make the integration and its limitations inspectable.

Distinctive implemented construct. A condition-and-ruleset acknowledgement fingerprint binds a reviewed condition to the model name and manually maintained prompt version. A separate application rule preserves verdicts labelled high or critical; it does not independently determine actual incident severity.

Empirical contribution. Configuration-specific evidence shows that schema validity, retrieval success and favourable perceived usability do not establish diagnostic reliability. The novelty claim is therefore a scoped integration and operationalisation, not universal uniqueness or superiority.

1.3 Aim and Objectives of the Project

1.3.1 Aim

The aim of this design-science project is to design, implement and verify an operator-hosted, LLM-assisted observability and incident triage artefact that produces structured verdicts from selected telemetry, supports local runbook retrieval and operator-approved threat response, and records acknowledgements for recurring low-risk conditions.

1.3.2 Research Questions

RQ1. How can selected heterogeneous observability telemetry be collected and represented as a bounded, structured and reviewable incident verdict?

RQ2. What operator-hosted architecture supports LLM-assisted analysis with local runbook retrieval, structured validation, human oversight and provider/model traceability?

RQ3. How can prior operator acknowledgement mask an unchanged low-risk finding from the default view without hiding changed or high-risk conditions?

RQ4a. Which implemented behaviours are supported by automated software verification?

RQ4b. What does the frozen qwen2.5:3b incident and RAG/no-RAG benchmark establish about severity agreement, signature stability and runbook retrieval?

RQ4c. What does the retained SUS study indicate about perceived usability within the participating convenience sample?

RQ5. Which governance, security and data-flow controls are implemented or specified for the single-host InfraGuard AI reference architecture, and what evidence supports their status across local and cloud inference paths?

1.3.3 Specific Objectives

The project pursued five objectives organised around the research lifecycle:

1. RO1 - Requirements. To derive, document and analyse functional, non-functional, security, data-governance and operational requirements for a bounded operator-hosted incident-triage artefact.
2. RO2 - Design and implementation. To design and implement a requirements-driven, multi-source telemetry and bounded LLM reasoning architecture that produces structured incident triage verdicts.
3. RO3 - RAG and operational assistance. To design and implement a retrieval-augmented runbook mechanism that provides operational guidance conditioned on locally maintained procedures.
4. RO4 - Human oversight and acknowledgement. To implement operator-controlled acknowledgement and threat-response mechanisms that manage recurring low-risk conditions while preserving visibility of high- and critical-severity findings.
5. RO5 - Verification and evaluation boundary. To verify implemented behaviour through automated tests and deterministic scenarios; to examine model behaviour and retrieval through a controlled benchmark; and to describe perceived usability from retained SUS items. RQ4a-RQ4c separate these activities. Their limits arise from one evaluated model, researcher-defined synthetic scenarios, unavailable public item-level assessor ratings and the absence of field evaluation.

1.4 Scope of the Project

1.4.1 Within Scope

- Collection of application/system logs (Loki), infrastructure metrics (Prometheus), endpoint health (HTTP probes), and optional Docker container telemetry, on a configurable heartbeat interval.
- Model analysis through the Gemini Developer API, Anthropic, OpenAI-compatible services, or Ollama, selected through environment configuration.
- Push notification of high- and critical-severity verdicts via the ntfy.sh service.
- Deterministic detection of HTTP/SSH brute-force and port-scan patterns in logs, with operator-approved CrowdSec IP banning (operating in dry-run mode when CrowdSec is not configured).
- A local runbook retrieval path based on Markdown files, ONNX all-MiniLM-L6-v2 embeddings and a ChromaDB vector index.

- A stateful acknowledgement memory with condition-and-ruleset fingerprinting and a configurable time-to-live. A changed signature, prompt version, or model produces a different fingerprint.
- A single-page operations dashboard with session authentication, rate limiting, security headers, request auditing, and output escaping. Production deployment requires HTTPS termination and restricted network access.

1.4.2 Out of Scope (Identified as Future Work)

- Autonomous code remediation, including ingesting security-scanner output such as SARIF, generating code or configuration patches, and opening pull requests. The agent diagnoses and recommends; it does not modify application code.
- A comparative production evaluation of local and hosted models, including capacity planning for self-hosted inference, remains outside the implemented evaluation scope.
- Multi-server fleet operation. The present work targets a single host monitoring its co-located workloads; a distributed control-plane-and-satellite topology is future work.
- Custom training, fine-tuning, or distillation of the underlying LLMs. Models are treated as black-box providers selected through the common interface: hosted models are accessed through their APIs, while Ollama uses the local service.
- Identity and access-management federation with external single-sign-on providers; the system uses cookie-based session authentication only.
- Native mobile or desktop client applications; the dashboard is delivered exclusively as a responsive web application.
- Formal security certification (e.g. SOC 2 or an ISO 27001 audit). The deliverable is a reference implementation and architectural blueprint, not a certified product.

1.5 Significance of the Project

1.5.1 Significance to Industry

Industry significance lies in an inspectable single-host prototype and a reproducible evaluation package that small teams can study without first adopting a large managed platform. The contribution is bounded engineering evidence and documented failure behaviour, not claimed superiority over commercial products.

1.5.2 Significance to Organisations

A small organisation can deploy, test, and modify InfraGuard AI on one host without first adopting a large observability platform. Whether that arrangement is suitable depends on the organisation's scale and controls. Running cost also depends on the LLM provider, heartbeat interval, prompt size, and surrounding infrastructure.

1.5.3 Significance to Policy and Society

The Nigeria Data Protection Act 2023 is relevant to organisations processing personal data; the Central Bank of Nigeria cybersecurity framework applies to institutions within its sector-specific scope (Central Bank of Nigeria, 2024; Federal Republic of Nigeria, 2023). Operational logs can contain account identifiers, IP addresses, request paths or free text that may relate to an identified or identifiable person. A relevant deployment must therefore define its purpose and lawful basis, minimise prompt content, restrict access, set retention periods, and document applicable processor or cross-border transfer arrangements. InfraGuard AI's controls support these decisions but do not by themselves establish legal or regulatory compliance.

1.5.4 Significance to Professional Practice

Professional-practice significance lies in making governance and evidence boundaries explicit: operators can inspect selected telemetry, provider/model provenance, the structured verdict, acknowledgement rule, threat-response approval and controlled benchmark. The two provenance-qualified role reports and the separate descriptive SUS workbook add exploratory interpretation without converting the framework into a validated diagnostic system.

1.5.5 Significance to the Master of Information Technology Programme

For the Master of Information Technology programme, the work links an operational problem to a software artefact, automated tests, measured coverage, a reproducible benchmark, provenance-qualified qualitative practitioner-role interpretation, and a separately retained ten-response human SUS analysis.

CHAPTER TWO: LITERATURE REVIEW AND TECHNOLOGY CONTEXT

2.1 Conceptual Review

The conceptual review connects observability and SRE with AIOps, LLM agents, retrieval-augmented generation, acknowledgement memory, human-automation decision support and socio-technical oversight. The purpose is not to inventory technologies, but to identify the claims, risks and design principles that the artefact can test.

2.1.1 Cloud-Native Observability and the Three Pillars

Observability supplies evidence from which operators infer system state, but telemetry alone does not establish cause. InfraGuard AI therefore selects Prometheus metrics, Grafana Loki logs, HTTP probes and optional Docker telemetry for interpretation; distributed tracing remains outside the implemented scope.

2.1.2 Site Reliability Engineering and Incident Management

Site reliability engineering uses telemetry, service-level objectives, and operational automation to improve reliability. Beyer et al. (2016) use the term toil for repetitive manual work that scales with service growth. Alert review and repeated handling of known conditions are relevant examples. InfraGuard AI addresses a limited part of this work by generating a first-pass verdict and recording operator acknowledgements.

2.1.3 AIOps: Artificial Intelligence for IT Operations

AIOps applies machine learning and analytics to operations data for tasks such as anomaly detection, event correlation, fault diagnosis, and remediation support. Chen et al. (2025) present AIOpsLab as a reproducible environment for deploying cloud systems, injecting faults, exporting telemetry, and evaluating LLM agents across operational tasks. Their results also show that agent capability depends on the task and evaluation setting. InfraGuard AI does not train an anomaly detector or claim autonomous remediation. It asks a general-purpose LLM to interpret a bounded set of collected evidence and returns the result for operator review.

For this study, alert correlation groups related signals; anomaly detection identifies departures from an expected pattern; root-cause analysis seeks an underlying cause; summarisation condenses evidence; and triage interprets and prioritises evidence for review. Remediation recommendation proposes an action, whereas autonomous remediation executes it without case-specific approval. InfraGuard AI studies bounded triage and advisory runbook assistance, with a separate operator-approved threat-action path. Studies of these tasks differ

in telemetry access and scoring and are not direct performance comparators (Ahmed et al., 2023; Chen et al., 2024, 2025; Xu et al., 2025).

2.1.4 Large Language Models and Agentic AI

Large language models can generate from supplied context and invoke tools that retrieve evidence (Gemini 2.5 Team, 2025; Yao et al., 2023). Reflexion demonstrates verbal feedback across attempts (Shinn et al., 2023), while InfraGuard AI uses a bounded LangGraph workflow and an optional small LangChain telemetry tool set (LangChain, n.d.). Neither orchestration nor structured output guarantees a correct diagnosis, so operational action remains the operator's responsibility.

2.1.5 Retrieval-Augmented Generation

The retrieval-augmented generation layer uses local Markdown runbooks as its knowledge source (Lewis et al., 2020). Each approved Markdown file is loaded as one retrievable document, embedded locally with the ONNX all-MiniLM-L6-v2 model and stored in ChromaDB. The four most relevant documents are supplied to the selected model. The current implementation does not split files into smaller chunks.

Es et al. (2024) distinguish faithfulness, answer relevance and context relevance in RAG evaluation. For operational runbook assistance, this study additionally separates answer correctness and actionable safety; neither is established by retrieval success alone. InfraGuard AI retains objective top-four retrieval records. Completed original item-level ratings for grounding, correctness and actionable safety are absent from the public package, so these dimensions remain quantitatively unresolved. The qualitative role reports may motivate future hypotheses, while the absence of supplied sources in the no-RAG condition is a traceability condition rather than a human score or causal RAG estimate.

2.1.6 Statelessness, Alert Deduplication, and Agent Memory

A scheduled triage loop can show the same condition on successive cycles even after it has been reviewed. Alert grouping and log-template research show why the identity used for matching matters. A broad key can merge different conditions, while exact raw text often fails to match because timestamps, identifiers, and values change. Drain, for example, derives stable log templates by separating fixed and variable tokens (He et al., 2017). Conventional alert grouping and deduplication merge similar events; suppression rules hide matching alerts; incident acknowledgement records operator ownership; and agent memory can influence later model reasoning. InfraGuard AI instead binds an operator acknowledgement to the condition signature, prompt version, and model. A match changes presentation for an ok or warning verdict but does not prevent the next model call or suppress high- and critical-severity visibility.

The current condition signature can be supplied by the same model whose verdict is being remembered. This creates a circularity risk: an unstable or incorrect signature may cause a recurring condition to be missed, merged with another condition or associated with the wrong acknowledgement. The benchmark exposed this weakness: only 10 of 24 scenarios (41.7%) produced one identical signature across all three runs. Prompt/model binding, expiry and the severity safeguard limit the consequences, but a stronger design would derive primary condition identity deterministically from telemetry before inference and use model text only as supporting description.

2.1.7 Human-Automation Decision Support, Alert Fatigue, and Trustworthy AI

Human-automation research distinguishes appropriate use from misuse, disuse and abuse, and relates the appropriate level of automation to task risk and retained human responsibility (Parasuraman & Riley, 1997; Parasuraman et al., 2000). Trust should be calibrated to demonstrated capability and supported by access to the basis for a recommendation (Lee & See, 2004).

Automation bias and complacency can persist among novice and experienced users when an imperfect aid competes for attention (Parasuraman & Manzey, 2010). Guidance for human-AI interaction therefore emphasises capability disclosure, correction, user control and visible system change (Amershi et al., 2019), while cognitive forcing can reduce overreliance by requiring active engagement with evidence (Bućinca et al., 2021).

Alarm-reliability experiments show a cry-wolf effect in which response behaviour tracks perceived signal reliability (Bliss et al., 1995). A clinical-monitoring review likewise links excessive nuisance alarms with desensitisation, mistrust and delayed or absent response (Cvach, 2012). The clinical setting differs from IT operations, so this literature motivates careful notification design but does not prove that InfraGuard AI reduces alert fatigue.

Trustworthy AI requires more than users reporting trust: reliance should be warranted by evidence of reliability, safety, transparency and accountability (Jacovi et al., 2021). Human-centred AI similarly combines substantial automation with substantial human control rather than treating them as opposites (Shneiderman, 2020). The NIST Generative AI Profile adds risk identification, measurement, governance and monitoring as continuing lifecycle duties (National Institute of Standards and Technology, 2024).

For InfraGuard AI, these principles map to visible telemetry evidence, structured validation, retained provenance, an operator veto and explicit approval before disruptive action.

Acknowledgement only masks a qualifying recurring verdict from default presentation; inference and storage continue. The measured 40.3% exact agreement with researcher-defined severity labels means reliability was not established for unattended triage, so human review is a control requirement rather than a ceremonial approval step.

Human oversight requires more than presenting an approval button. Bućinca et al. (2021)

found that cognitive forcing reduced overreliance on incorrect AI suggestions compared with their simple explanation conditions, while the designs that reduced overreliance most received the least favourable subjective ratings. This exposes a design tension between comfortable interaction and active scrutiny of advice; it does not establish the same effect in operational triage. For InfraGuard AI, the implication is to retain visible evidence and operator authority while evaluating perceived usability separately from error-sensitive task performance. The SUS result describes the interface experience of the study sample; whether

operators detect incorrect advice, choose safe actions or complete incidents more effectively requires task-level evidence that the present study does not provide.

2.1.8 Theoretical Foundations, Domain Concepts, and Design Constructs

Primary methodological foundation. Design Science Research (DSR) structures the build-and-evaluate cycle and positions contribution as an evaluated prescriptive design rather than invention by assertion (Gregor & Hevner, 2013; Hevner et al., 2004; Peffers et al., 2007; Venable et al., 2016).

Primary governance foundation. Governance-by-design, informed by organisational AI-governance scholarship, embeds governance choices in architecture, workflows and evidence records. It does not replace organisational judgement or legal accountability (Mäntymäki et al., 2022; Morley et al., 2020; Mulligan & Bamberger, 2018; National Institute of Standards and Technology, 2023, 2024).

Organisational AI governance combines rules, practices, processes and technological tools across the AI lifecycle, rather than residing in a model or interface alone (Mäntymäki et al., 2022). The NIST AI RMF similarly places governance across risk mapping, measurement and management, with documented responsibilities and accountability for deployment decisions (National Institute of Standards and Technology, 2023). Applied to InfraGuard AI, this distinction connects selected-data boundaries, provider/model provenance, acknowledgement rules and operator approval to inspectable application mechanisms. It also identifies what the artefact cannot supply by itself: accountable organisational ownership, risk acceptance and continuing review. The proposed framework therefore maps each design principle to an implemented control, its evidence and its remaining assurance duty, rather than treating implementation as proof of complete governance.

Supporting theoretical lenses. Human-automation reliance and trustworthy-AI scholarship supply the appropriate-reliance, transparency and retained-control boundary (Lee & See, 2004; Shneiderman, 2020). These lenses explain why human approval must be substantive when model reliability is limited.

Domain and technical foundations. Observability, SRE, AIOps, incident management and RAG define the problem vocabulary and motivate the telemetry, retrieval and operator-workflow choices; they are not treated as explanatory theories. The design constructs are bounded context, structured verdicts, provider/model provenance, inspectable retrieval, operator-controlled data and action boundaries, ruleset-bound acknowledgement, explicit approval and a high/critical visibility safeguard.

Table 2.4: Theoretical Foundations and Application to InfraGuard AI.

Foundation	Constructs or role	Application to InfraGuard AI
Design Science Research	Artefact, design principles and evaluation	Research method and contribution chain
Governance-by-design	Accountability, controls and inspectable evidence	Architecture and assurance boundaries

Foundation	Constructs or role	Application to InfraGuard AI
Human-automation reliance	Calibrated reliance and retained human authority	Evidence review and operator approval
Trustworthy AI	Transparency, safety, accountability and monitoring	Provenance, validation and continuing oversight
Observability, SRE, AIOps and RAG	Domain and technical concepts	Telemetry, incident triage and runbook retrieval

The NIST Generative AI Profile distinguishes direct prompt injection through a model-facing input from indirect injection through data retrieved by an LLM-integrated application, and recommends adversarial testing of relevant attack surfaces (National Institute of Standards and Technology, 2024). In InfraGuard AI, attacker-controlled log text, tool responses or runbook content could therefore introduce indirect instructions through an evidence path. The design implication is to separate evidence from authorised instructions, constrain accessible tools and retain approval before supported disruptive action. These measures address different parts of the workflow: output escaping protects browser presentation, structural validation checks response form, and operator approval limits action authority. None alone demonstrates resistance to manipulated model advice. The thesis accordingly distinguishes verified application behaviour from the adversarial model evaluation still required.

Figure 2.1 relates risks to application controls, operator authority and evaluation evidence. Selected inputs and source labels constrain context; structural validation constrains output form; persistence and provenance support inspection; and acknowledgement and approval rules constrain presentation and action. These mechanisms do not establish correct model reasoning. The separate assurance boundary identifies organisational duties and subsequent evaluation. The figure is a prescriptive design model rather than an empirically validated causal theory.

Governance controls across evidence inference and action

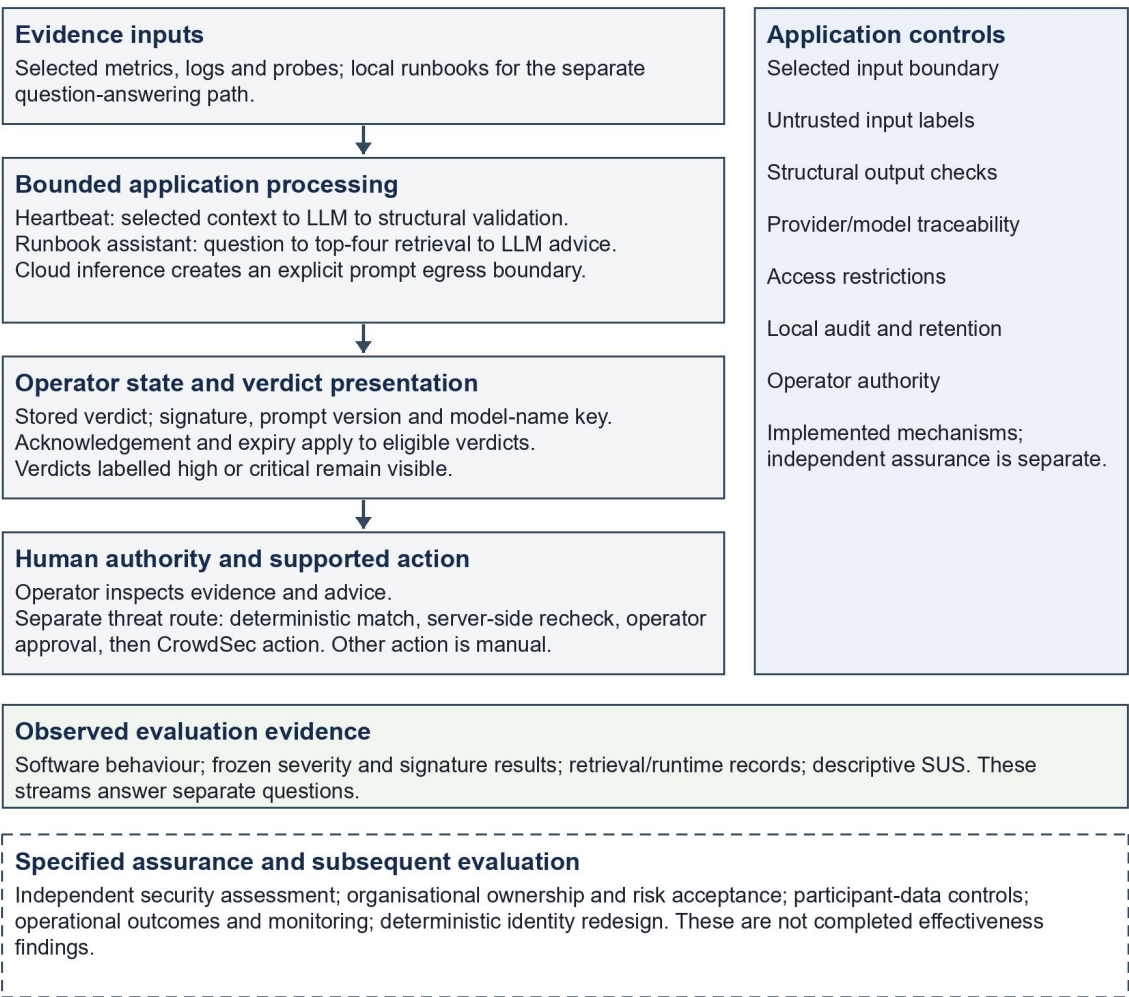


Figure 2.1: Conceptual Framework for Operator-Hosted, LLM-Assisted Incident Triage.

2.2 Review of Existing Systems and Solutions

Thirteen studies were reviewed across site reliability engineering, AIOps, log parsing, retrieval, and LLM-assisted operations. They are compared by method, evidence, limitations, and relevance to InfraGuard AI. Product documentation is considered separately in the discussion of commercial and open-source tools.

2.2.1 Comparative Table of Thirteen Recent and Related Studies

Table 2.1 provides a compact comparison of thirteen studies by method, evidence basis, finding, limit and relevance. The synthesis in Section 2.2.2, rather than the table alone, establishes the known, contested and unresolved claims that informed the design.

Table 2.1: Comparative Review of Thirteen Studies in AIOps and LLM-Assisted Operations.

#	Study	Method	Basis	Principal finding	Limit	Use in this study
1	Beyer et al. (2016)	SRE practitioner synthesis	Operational practice	Defines telemetry-led operations and toil.	Pre-LLM; human interpretation assumed.	Frames repeated triage as bounded operator work.
2	Chen et al. (2025)	Cloud-agent benchmark	AIOpsLab	Agent capability varies by task and setting.	Benchmark, not small-team deployment.	Motivates reproducible controlled evaluation.
3	He et al. (2017)	Streaming log parsing	Drain	Templates stabilise volatile log events.	No reasoning or operator memory.	Motivates deterministic identity before inference.
4	Yao et al. (2023)	Reason-and-act prompting	LLMs plus tools	Tool use can outperform study baselines.	Domain-agnostic; no operations trial.	Supports bounded read-only tool orchestration.
5	Shinn et al. (2023)	Verbal reflection loop	GPT-4 memory	Reflection improved selected multi-step tasks.	Benchmark decision-making, reasoning and coding; no incident-triage field trial.	Contrasts model reflection with operator acknowledgement.
6	Yuan et al. (2025)	Retrieval-assisted diagnosis	RAIDR	Demonstrates IoT incident reporting with retrieval.	Short IoT demonstration.	Supports local runbook retrieval with visible sources.
7	Ahmed et al. (2023)	Prompting/fine-tuning	40,000+ cloud incidents	Reports root-cause and mitigation recommendations.	Proprietary hyperscale context.	Motivates evidence-bounded advisory output.
8	Jin et al. (2023)	Outage assessment/su mmarisation	18 cloud systems	Reports empirical and owner evaluation.	Proprietary data and deployment.	Supports structured records, not generalisable claims.
9	Chen et al. (2024)	LLM-assisted RCA	RCACopilot	Reports root-cause accuracy up to 0.766.	Hyperscale diagnostic services.	Motivates selected-source collection and inspectability.
10	Roy et al. (2024)	Agent RCA study	Tool-augmented LLMs	Grounding and tool choices affect results.	Microsoft data/services.	Supports human control and explicit tool boundaries.
11	Xu et al. (2025)	Open RCA benchmark	335 failures; 68+ GB	Best reported setup solved 11.34%.	Offline benchmark.	Supports mandatory review and model-specific evaluation.
12	Hou et al. (2024)	Systematic review	395 studies	Finds uneven methods and evidence practices.	No operations artefact.	Motivates reproducibility and claim calibration.
13	Guo et al. (2024)	Domain model/benchm ark	OWL	Domain tuning improves IT-ops QA in the study.	Model-centric; no live telemetry loop.	Supports comparison as future work, not equivalence.

2.2.2 Synthesis of the Reviewed Studies

The studies examine different tasks and cannot be ranked on one common accuracy scale. Ahmed et al. (2023) and Chen et al. (2024) investigate recommendations and root-cause assistance using cloud-incident evidence. AIOpsLab instead provides controlled fault injection, workloads, telemetry and an agent-evaluation interface (Chen et al., 2025). OpenRCA tests root-cause identification on 335 failures from three enterprise systems; its best reported configuration solved 11.34% of cases (Xu et al., 2025). These differences in tasks, telemetry access and scoring help explain why successful assistance does not establish reliable operational diagnosis.

Retrieval and memory expose related measurement problems. Lewis et al. (2020) evaluate retrieval-augmented generation on knowledge-intensive tasks, while Es et al. (2024) separate retrieval relevance, faithful use of context and generation quality. Reflexion retains linguistic feedback to improve later attempts (Shinn et al., 2023); Drain stabilises log templates through deterministic parsing (He et al., 2017). Neither mechanism establishes durable acknowledgement identity for this incident-triage architecture. This distinction motivates separate retrieval measures and a direct test of signature stability.

The human-reliance evidence reviewed in Section 2.1.7 motivates a separate evaluation of perceived usability and error-sensitive task performance. InfraGuard retains operator authority while reporting SUS and model errors as distinct evidence streams.

The unresolved relationship is between a useful local interaction and a dependable operational outcome. Proprietary incident datasets, controlled benchmarks, general language-agent tasks and short human experiments supply complementary evidence, but do not establish the same deployment conditions or outcome measures. Table 2.2 synthesises their implications without treating differences in study design as direct experimental contradictions. The synthesis supports bounded evidence, visible model provenance, separate retrieval and answer-quality assessment, and explicit operator control. InfraGuard implements these design choices and evaluates their local behaviour. The study examines the stability of its model-dependent acknowledgement identity rather than assuming that persistence alone provides reliable operational memory.

Table 2.2: Thematic Synthesis of Findings, Tensions and Design Implications.

Theme	Shared finding	Tension or methodological difference	Evidence limitation	Implication for InfraGuard
LLM incident analysis	Assistance is feasible in bounded tasks (Ahmed et al., 2023; Chen et al., 2024).	Injected cloud faults and enterprise root-cause cases measure different capabilities (Chen et al., 2025; Xu et al., 2025).	Task, telemetry access, labels and scoring differ; headline rates are not directly comparable.	Retain human review and evaluate the configured model against an explicit severity policy.
Retrieval	Retrieved knowledge can support generation (Lewis et al., 2020).	Relevant retrieval, faithful context use and generation quality are separate dimensions (Es et al., 2024).	Knowledge-task or automated scores do not establish operational action safety.	Measure top-four retrieval separately from grounding, correctness and safety.
Memory and identity	Feedback and stable representations can support repeated processing.	Reflexion stores linguistic feedback; Drain derives log templates (Shinn et al., 2023; He et al., 2017).	Neither study tests durable identity for this acknowledgement mechanism.	Evaluate deterministic telemetry-derived identity; do not infer stable identity from persisted model text.
Human oversight	People can overrely on AI advice (Buçinca et al., 2021).	Cognitive forcing reduced overreliance but received less favourable subjective ratings.	A controlled human experiment is not an SRE field study.	Keep operator authority and assess perceived usability separately from error-sensitive task outcomes.

2.2.3 Commercial and Open-Source State of the Art

Four products provide useful points of comparison. The descriptions below are limited to capabilities stated in their current product documentation.

Datadog Bits AI and Watchdog

Datadog Bits AI supports investigations using Datadog telemetry, runbooks, environment context, feedback, and investigation memories (Datadog, n.d.). It is part of Datadog's managed commercial platform.

New Relic AI

New Relic AI provides natural-language access to telemetry held in the New Relic platform and can return explanations, summaries, charts, and troubleshooting guidance (New Relic, n.d.). It is a managed platform feature rather than an operator-hosted reference implementation.

PagerDuty AIOps

PagerDuty AIOps provides alert grouping, noise reduction, triage, root-cause features, event orchestration, and automation within PagerDuty's managed incident platform (PagerDuty, n.d.). Its event-grouping functions are related to, but not identical with, the acknowledgement memory studied here.

K8sGPT (Open Source)

K8sGPT is an open-source tool that analyses Kubernetes resources and sends selected information to a configured AI backend for explanation (K8sGPT, n.d.). Its primary scope is Kubernetes diagnosis rather than the multi-source heartbeat implemented by InfraGuard AI.

2.2.4 Feature-Level Comparison of Related Operator-State Mechanisms

Table 2.3 compares related operator-state, governance and memory mechanisms at feature level using scholarly and practitioner sources. The matrix establishes a scoped combination-level distinction only: 'not reported' does not mean absent, and the entries do not establish universal uniqueness, superiority or exhaustive coverage of changing commercial features.

Table 2.3: Feature-Level Comparison of Related Operator-State and Memory Mechanisms.

Mechanism	Identity or rule basis	Human and model-version treatment	Evidence-bounded distinction
Alert acknowledgement	Alert or incident record	Explicit operator state; model binding is not inherent	Tracks ownership or review of a recorded alert (Beyer et al., 2016; PagerDuty, n.d.).
Suppression or routing rules	Fields, thresholds, rules or time windows	Configured by an operator or administrator; prompt/model binding is not inherent	Redirects or hides matching events and can conceal matches if rules are too broad.
Alert correlation taxonomy	Rule, similarity, statistical or model-based correlation	Human review varies; LLM prompt/model identity is not part of the taxonomy	Classifies established correlation approaches rather than an acknowledgement standard (Salah et al., 2013).
Event deduplication or grouping	Event keys, similarity, correlation or templates	Usually automatic before human review; no LLM rationale identity is required	Clusters related noise rather than preserving a bounded judgement (He et al., 2017; PagerDuty, n.d.).

Mechanism	Identity or rule basis	Human and model-version treatment	Evidence-bounded distinction
Incident-management or AIOps memory	Incident timeline, ownership, resolution and investigation context	Acknowledgement and investigation memory are platform-dependent	Preserves lifecycle context within managed incident workflows (Datadog, n.d.; PagerDuty, n.d.).
Agent memory or reflection	Prior textual traces or model feedback	Human approval is not inherent; state may depend on model or prompt	Supports iterative reasoning but is not an incident-acknowledgement standard (Shinn et al., 2023).
AI governance and audit frameworks	Lifecycle risks, roles, controls and evidence	Organisational accountability and review are central	Provide cross-cutting governance foundations rather than this incident-triage implementation (Morley et al., 2020; National Institute of Standards and Technology, 2023; Raji et al., 2020).
InfraGuard AI reference framework	Condition signature + prompt version + active model within bounded evidence/action controls	Explicit for verdicts labelled ok/warning; a separate rule preserves verdicts labelled high or critical, and supported disruptive action requires operator approval.	Instantiates a scoped governance-by-design combination; universal novelty, superiority, lower workload and lower inference cost are not established.

2.3 Review of Relevant Technologies, Tools, and Frameworks

This section records only the selection rationale for the principal technologies; Chapter Three specifies the research design and Chapter Four documents implementation. Choices were assessed for maintainability, licensing, operator control, provider portability and suitability for a small single-host deployment.

2.3.1 Programming Language and Runtime

Python was selected so FastAPI, LangGraph and LangChain orchestration, HTTPX integrations, ChromaDB, ONNX sentence embeddings, the Docker SDK and provider clients could share one testable runtime.

2.3.2 Web and API Framework

FastAPI was selected for asynchronous integration routes, dependency-based route controls and generated OpenAPI documentation. Co-hosting the dashboard and JSON endpoints preserves one session-authentication boundary and avoids a separate dashboard service.

2.3.3 LLM Orchestration and Provider

Provider dispatch is controlled by LLM_PROVIDER. The source code currently defaults to gemini-3.6-flash through the Gemini Developer API, but this is a configuration fact rather than evaluated model evidence. The acknowledgement fingerprint contains the normalised condition signature, manually maintained prompt version and active model name. It contains no separate provider identifier, model digest or automatic prompt-content hash; switching providers with an unchanged model-name string does not by itself invalidate acknowledgement.

The researcher-observed retrieval pilot used DeepSeek V4 Flash through an OpenAI-compatible route, whereas the controlled benchmark used local qwen2.5:3b through Ollama. One interface supports Gemini, Anthropic, OpenAI-compatible and Ollama paths, but equivalent behaviour or performance across providers was not empirically demonstrated.

2.3.4 Observability and Telemetry Sources

Prometheus and Grafana Loki are the primary metric and log sources and are queried through their HTTP APIs. The deployment expects those services to be configured separately; it does not deploy a log shipper or monitoring backend. HTTP probes provide endpoint checks, the Docker Engine API provides optional local-container telemetry, and CrowdSec is available for operator-approved IP bans. Distributed tracing is outside the project scope.

2.3.5 Data Stores

Runbook embeddings are generated locally with the ONNX all-MiniLM-L6-v2 model. The vectors and document metadata are stored in ChromaDB, allowing retrieval without sending the runbook corpus to an embedding API.

2.3.6 Security and Deployment

Application controls include signed timestamped session cookies, rate limiting, response headers, output escaping, and request logging. Docker Compose packages the API and agent, Terraform provisions a Google Compute Engine host, and GitHub Actions runs tests before the deployment job builds and publishes images. A production deployment still requires HTTPS termination, restricted firewall rules, and protected secret handling.

2.3.7 Relevant Standards and Specifications

Table 2.5 lists the standards and specifications referenced in the design.

Table 2.5: Relevant Standards and Specifications.

Standard / Specification	Source	Role in InfraGuard AI
Prometheus Exposition Format	Prometheus Authors (n.d.)	Metric data format consumed by the metrics-collection tool.
Loki HTTP API (LogQL)	Grafana Labs (n.d.)	Log query interface used to retrieve recent log lines over an explicit time window.
OpenAPI 3.1	OpenAPI Initiative (2025)	Automatic description of the control-plane REST surface generated by FastAPI.
System Usability Scale (SUS)	Brooke (1996)	Standardised ten-item instrument used for the completed human survey; coded item-level responses and reproducible scoring are retained for ten complete cases.
ISO/IEC 27001:2022	International Organization for Standardization (2022)	Information-security management reference informing audit-trail and access-control design.

Standard / Specification	Source	Role in InfraGuard AI
Nigeria Data Protection Act 2023	Federal Republic of Nigeria (2023)	Regional legal context for access control, accountability, and responsible processing.
Risk-Based Cybersecurity Framework for DMBs and PSBs	Central Bank of Nigeria (2024)	Sector-specific context for monitoring, reporting, and resilience controls.
NIST AI 600-1	National Institute of Standards and Technology (2024)	Generative-AI risk reference for grounding, output validation, human oversight, and post-deployment monitoring.
OWASP Top Ten	OWASP Foundation (2025)	Reference for the dashboard's security-header, session, and threat-handling choices.

2.4 Gap Analysis

The review exposed seven gaps that informed the system design. They are not all gaps in academic knowledge: deployment control, inspectability and reproducibility are primarily engineering gaps, while stable acknowledgement across repeated LLM-assisted verdicts is a focused design-research problem. The central contribution is a governance-by-design reference framework for bounded LLM-assisted incident triage. Its distinctive subordinate construct is the fingerprint-based operator acknowledgement pattern integrated with bounded telemetry reasoning, local evidence retrieval and human-approved enforcement.

2.4.1 Grounding and response validation

An LLM can infer an unsupported cause or return malformed output. The NIST Generative AI Profile identifies confabulation, information security, human oversight, and post-deployment monitoring as risk-management concerns (National Institute of Standards and Technology, 2024). InfraGuard AI supplies selected telemetry, tells the model not to treat absent integrations as faults, and checks the response fields and severity. These controls constrain the interface, but they do not establish diagnostic accuracy.

2.4.2 Deployment control

The commercial platforms reviewed are vendor-managed services. InfraGuard AI keeps the API, dashboard, database and runbook index on the operator's host. This is an engineering and governance distinction rather than, by itself, a new academic capability. A prompt still leaves the host when the operator selects a cloud LLM provider.

2.4.3 Inspectable entry point

A small reference implementation allows the collection and reasoning paths to be inspected without adopting a full observability platform. This does not imply lower operating cost; cost depends on the host, provider, prompt size, and request rate.

2.4.4 Recurring-condition acknowledgement

A scheduled triage loop needs a durable distinction between a reviewed low-risk condition and a new finding. InfraGuard AI stores a fingerprinted acknowledgement and sets a presentation flag on a matching ok or warning verdict so default API/dashboard views may hide it. The next heartbeat still performs inference and stores its verdict. A change to the signature, prompt version, or model produces a different fingerprint.

2.4.5 Operator approval for enforcement

IP bans can interrupt legitimate traffic. InfraGuard AI therefore applies a CrowdSec ban only after an operator approves the detected threat. Acknowledgement rules also prevent high and critical findings from being hidden.

2.4.6 Organisation-specific runbooks

Operational procedures are maintained as local Markdown files under the runbooks directory. Docker Compose mounts this directory read-only into the API container; subdirectories provide category metadata for retrieval.

2.4.7 Reproducibility

Private datasets and managed infrastructure limit direct reproduction of several reviewed systems. InfraGuard AI keeps the collection, matching, persistence, and API logic in one repository so another evaluator can inspect those decisions.

These gaps guide the requirements and architecture in Chapter Three. Chapter Five examines the completed software, model, retrieval and usability evidence. The principal contribution is the governance-by-design reference framework, with the acknowledgement fingerprint as its distinctive implemented construct. The broader empirical questions remain specified in the evaluation protocol and future-work recommendations.

CHAPTER THREE: METHODOLOGY AND SYSTEM DESIGN

3.1 Project Methodology

An iterative design-science research method guided the project. It connects problem identification, objectives, artefact design, demonstration, evaluation and communication rather than treating implementation as the research result by itself (Hevner et al., 2004; Peffers et al., 2007). Short cycles allowed requirements, code, tests and documentation to change together, while the evaluation boundary distinguishes verified software behaviour from operational effectiveness that remains unmeasured.

3.1.1 Methodological Phases

The work moved through six overlapping DSR phases. Test results or code review sometimes required an earlier decision to be revisited.

1. Problem identification. Reviewed observability, SRE, AIOps, incident-analysis, RAG, and agent research, then defined the narrow problem of first-pass telemetry interpretation for a small team.
2. Objective definition. Converted the problem into five implementation and evaluation objectives.
3. Design and development. Implemented telemetry adapters, the reasoning workflow, provider abstraction, runbook retrieval, threat handling, persistence, API, dashboard, and acknowledgement memory.
4. Demonstration. Exercised the main workflow paths with mocked upstream services and controlled test fixtures.
5. Evaluation. Separated software verification; objective controlled-model and retrieval measures; provenance-qualified qualitative role-report interpretation; descriptive item-level SUS evidence; and security/data-governance analysis. No quantitative human assessor result is adopted.
6. Communication. Updated the report, diagrams, references, and appendices so that they describe the implemented system and measured evidence.

3.1.2 Methodology Rationale, Tools and Evidence Alignment

Methodology rationale. A strictly sequential method would have been a poor fit because output parsing, acknowledgement matching and middleware order became clearer during implementation. The six-phase DSRM provides a transparent process for revisiting those

decisions while maintaining traceability from problem and objectives to demonstration, evaluation and communication (Peffer et al., 2007).

Tooling. The Git repository contains the source code, infrastructure definitions, tests, and report sources. Two GitHub Actions workflows are included: pull requests run the test suite, while pushes to the main branch run tests before the container build and deployment steps.

Evidence alignment. Table 3.1 makes the research chain explicit. A current answer is reported only where the completed evidence supports it; unresolved effectiveness questions remain bounded as future empirical work.

Evidence boundary. Software verification concerns specified application behaviour; the frozen benchmark concerns one recorded model configuration and researcher-defined policy; retrieval records concern source reachability; SUS concerns perceived usability; and practitioner reports supply provenance-qualified engineering hypotheses. These streams do not substitute for one another. Sections 5.6.2 and 5.6.3 state their threats to validity. A working tree is the local source files, including changes not yet recorded in a Git commit; the dated 180-test receipt applies to that local snapshot.

The benchmark operationalises severity through a researcher-defined policy. Its 40.3% exact agreement is correspondence with that policy, not independently established diagnostic truth. Labels were frozen before execution; Appendix E.1 records their definitions and the C20 sensitivity analysis. The absence of independent label adjudication is a central construct and internal-validity limitation.

Table 3.1: Research-Question, Objective, Method, Evidence, and Current-Answer Alignment.

RQ	Objective	Method and Evidence	Current Answer and Boundary
RQ1	RO1-RO2	Requirements analysis; architecture and adapter implementation; unit and orchestration tests.	A bounded context and structured-verdict path were implemented and verified with fixtures; live diagnostic accuracy remains unmeasured.
RQ2	RO2-RO4	Architecture analysis; output-schema tests; RAG pilot; review of operator approval boundaries.	The operator-hosted design, local runbooks, validation and approval boundary functioned in the tested environment.
RQ3	RO4	Fingerprint, expiry, mismatch and severity-safeguard tests; 30-cycle display scenario; frozen signature-stability result.	Exact fingerprint matching masks a qualifying repeated low-risk row and preserves visibility for verdicts labelled high or critical, but only 41.7% of frozen scenarios produced repeat-stable model signatures; dependable condition identity and workload reduction remain unresolved.
RQ4a	RO5	Dated source-scoped automated tests and deterministic software scenarios.	Selected implementation paths verified in the local working tree; no clean-release or operational-effectiveness claim.
RQ4b	RO3, RO5	Frozen qwen2.5:3b incident responses, signature repetitions, retrieval ranks and RAG/no-RAG runtime records.	Configuration-specific researcher-label agreement, identity instability and corpus retrievability; human-rated answer quality and causal RAG benefit remain unresolved.
RQ4c	RO5	Ten complete item-level SUS responses from eleven consented submissions.	Descriptive perceived usability within a convenience sample; task performance, workload and population usability remain unresolved.

RQ	Objective	Method and Evidence	Current Answer and Boundary
RQ5	RO1, RO4-RO5	Threat and data-flow analysis; architecture review; source inspection and selected functional tests.	Implemented controls and specified assurance duties are distinguished for this single-host reference architecture; independent security and compliance are not established.

Design-science mapping. The design-science logic used in the project is summarised in Table 3.2. Its evaluation strategy moves from artificial, controlled tests toward limited naturalistic practitioner access, consistent with the distinction in the FEDS framework (Venable et al., 2016). The completed evidence remains weighted toward controlled evaluation and is not proof of production effectiveness.

Table 3.2: Design-Science Mapping for InfraGuard AI.

Design-Science Element	InfraGuard AI Application	Evidence Location
Problem relevance	Incident-triage burden, repeated findings, grounding risk and data-boundary concerns.	Chapter One
Artefact	Operator-hosted InfraGuard AI agent, API, dashboard, persistence and runbook retrieval.	Chapters Three and Four
Design principles	Bounded context, structured output, human approval, local evidence and acknowledgement safeguards.	Chapters Two to Four
Demonstration	Single-host architecture, mocked telemetry fixtures, a researcher-observed convenience runbook-retrieval pilot, and a controlled local-model benchmark.	Chapter Five
Evaluation	Automated tests, measured coverage, acknowledgement scenario, objective incident metrics, objective RAG retrieval, provenance-qualified qualitative role reports, and a reproducible descriptive SUS study.	Chapter Five
Contribution	Governance-by-design reference framework (primary); condition-and-ruleset acknowledgement fingerprint (distinctive implemented construct); inspectable reference implementation and bounded empirical findings.	Chapters Five and Six
Outstanding evaluation	Broader independent assessor panel; independently adjudicated gold-label review; cross-model and production comparison; adversarial model evaluation; full resource cost; instrumented task study.	Appendices D and E

3.1.3 Human Evaluation Design and Evidence Separation

Two unchanged DevOps and SRE practitioner reports are retained with their hashes. The researcher identifies them as reports supplied by human operations practitioners, and the repository records confidential identity and original email evidence as held outside the public package. They provide exploratory report-level observations. Completed original item-level ratings are not present in the inspected public package, so aggregate assessor scores and inter-rater statistics cannot be independently recomputed from that package.

The public A/B worksheets are uncompleted scoring templates. Separately retained development score files explicitly labelled AI-simulated are excluded from human findings; their labels do not establish that the practitioner reports were generated by AI. The thesis uses the reports for qualitative engineering hypotheses and does not report unrecomputable A1/A2 means, kappa or adjudicated scores. Appendix F records the file distinctions and the requirements for a stronger subsequent study.

Descriptive exploratory System Usability Scale study.

The distinct human-usability stream used the ten-item System Usability Scale after practitioners accessed the dashboard. SUS is a global perceived-usability measure, not a measure of workload, task success or diagnostic correctness (Bangor et al., 2008; Brooke, 1996). Eleven consented submissions were received; complete-case analysis retained ten and excluded P9 because Question 3 was blank, with no imputation.

Odd-numbered items were scored as response minus 1; even-numbered items were scored as 5 minus response. The ten adjusted contributions were summed and multiplied by 2.5. The exported form's quiz Score column contains zeros and is not a SUS score, so it was excluded. The supporting workbook retains the unchanged source sheet, inclusion decisions, formulas, participant scores, summary statistics, item means and source hashes.

Participant codes P1-P11 are coded survey identifiers, not role labels. According to the researcher's provenance confirmation, the survey records are original human-practitioner responses. Identity and contact evidence was supplied separately to the supervisor and is not reproduced in the public document. The analysis is descriptive: the small convenience sample and absence of task-level timing, error, assistance and free-text records prevent population, causal or task-performance claims.

3.1.4 Research Ethics and Data Provenance

The separate SUS survey retained eleven submissions received between 22 and 26 August 2026. Its consent item stated, 'I consent to my responses being used for this academic evaluation'; all eleven retained submissions answered 'Yes, I consent'. Complete-case analysis included ten responses and excluded P9 because Question 3 was blank, without imputation. The analysis workbook preserves the response copy and scoring record. Public results use coded participant identifiers; the researcher reports that the confidential identity/contact mapping is held separately from the public research repository.

The researcher holds the participant records and has specified a 60-day retention period. The inspected study records do not establish the event from which that period runs, its coverage across response, identity and correspondence records, the detailed access/storage controls or the deletion procedure. No completed deletion is asserted. This research-record period is separate from the application's configurable verdict retention.

Affirmative consent responses establish consent to the stated academic use, but the retained package does not establish the complete participant-information and withdrawal arrangements or an institutional ethics approval, exemption or determination that review was unnecessary. Those matters remain unconfirmed; no institutional disposition is inferred. The two separately retained practitioner reports support provenance-qualified qualitative engineering hypotheses only. Original item-level assessor ratings are absent from the inspected public package, so assessor aggregates and inter-rater statistics remain excluded. File hashes identify preserved copies rather than establishing authorship or consent; explicitly AI-simulated development scores remain excluded from human findings.

3.2 Requirements Analysis

No formal stakeholder-interview or elicitation sample was retained. Requirements were researcher-derived from the operational problem, reviewed literature and standards, repository constraints, and the supervisor-agreed project boundary. The later practitioner role reports and SUS respondents were evaluation materials and participants, not sources of initial requirements.

Prioritisation used Must for the heartbeat, bounded evidence, structured verdicts, persistence, operator control and safety constraints. Should identifies optional integration or deployment requirements outside the core demonstration. Tables 3.3 and 3.4 state the requirements, and Table 3.5 adds their source, acceptance criterion and verification reference. The evidence classification distinguishes inspected implementation, asserted test behaviour and outcomes still awaiting operational evaluation.

Selected need-to-evidence traces are:

Bounded telemetry and verdict need → FR-01/FR-02 → agent tools, prompts, schema and orchestration → unit and orchestration tests.

Recurring-condition control → FR-07/FR-08/FR-09 → agent/memory.py, api/store.py and acknowledgement routes → memory, store and API tests.

Local runbook assistance → FR-12/FR-13 → runbook loader, ONNX embeddings and ChromaDB retrieval → runbook and vector-store tests plus the frozen RAG benchmark.

Human-controlled threat response → FR-10/FR-11 and NFR-04-NFR-07 → deterministic detector, CrowdSec adapter and authenticated middleware → threat-response and API tests.

Data and deployment governance → NFR-08/NFR-10/NFR-13/NFR-14 → Compose, Terraform, prompt selection and provider traceability → configuration review and focused tests, not independent security or legal assessment.

Literature-to-requirement justification. Human-control and reliance literature motivates FR-10/FR-11 and the separation of perceived usability from task effectiveness (Lee & See, 2004; Buçinca et al., 2021). Retrieval research motivates separate source and answer assessment in FR-12/FR-13 (Lewis et al., 2020; Es et al., 2024). Log-template and memory research motivates explicit identity handling in FR-07–FR-09 (He et al., 2017). Organisational governance and NIST guidance motivate bounded inputs, access, auditability, retention and traceable inference paths in NFR-02/NFR-04/NFR-07/NFR-10/NFR-11/NFR-13 (Mäntymäki et al., 2022; National Institute of Standards and Technology, 2023, 2024). These are researcher-derived design justifications, not evidence of stakeholder elicitation.

3.2.1 Functional Requirements

Table 3.3: Functional Requirements of InfraGuard AI.

ID	Requirement	Description	Priority
FR-01	Telemetry Collection	The system shall collect logs (Loki), metrics (Prometheus), endpoint health (HTTP probes), and optional container state (Docker Engine API) on a configurable heartbeat interval.	Must
FR-02	Structured Verdict Generation	The system shall send collected context to the configured LLM provider and request a verdict containing severity, summary, root cause, recommended action, and signature.	Must
FR-03	Severity Classification	Each verdict shall be classified into one of four severities: ok, warning, high, or critical.	Must
FR-04	Dual Reasoning Modes	Support both direct provider calls and LangChain multi-tool reasoning mode.	Must

ID	Requirement	Description	Priority
FR-05	Notification	The system shall dispatch a push notification via ntfy.sh for verdicts of high or critical severity.	Must
FR-06	Verdict Persistence and Retention	Verdicts shall be persisted to SQLite and automatically pruned after a configurable retention window.	Must
FR-07	Verdict Memory (Acknowledgement)	The artefact shall fingerprint each verdict on its condition signature plus ruleset version and allow an operator to acknowledge a low-risk condition so that a matching row is masked from the default view while its record is retained.	Must
FR-08	Memory Matching	A changed condition signature, prompt version, or model shall produce a different fingerprint; acknowledgements may also expire after a configurable time-to-live.	Must
FR-09	Severity Safeguard	High- and critical-severity verdicts shall never be masked from visibility by an acknowledgement.	Must
FR-10	Threat Detection	The system shall scan recent logs for HTTP/SSH brute-force and port-scan patterns and surface detected threats with their source IPs.	Must
FR-11	Operator-Approved Threat Response	On explicit operator approval, the system shall build and apply a CrowdSec ban for a detected threat, operating in dry-run mode when CrowdSec is unconfigured.	Should
FR-12	Runbook Indexing	Index and retrieve local Markdown runbooks using local embeddings and ChromaDB.	Must
FR-13	Runbook Query (RAG)	The system shall answer operator questions with an advisory response conditioned on retrieved runbook text and return source titles.	Must
FR-14	Operations Dashboard	The system shall provide a web dashboard exposing current status, integration configuration, check history, the threat panel, and the runbook assistant.	Must
FR-15	Integration Status	The system shall report which integrations are configured, exposing booleans only and never secret values.	Should

3.2.2 Non-Functional Requirements

Table 3.4: Non-Functional Requirements of InfraGuard AI.

ID	Quality Attribute	Requirement	Target
NFR-01	Cost Control	The heartbeat interval and prompt size shall be configurable so provider usage can be bounded.	One scheduled analysis cycle per heartbeat
NFR-02	Grounding Controls	The prompt shall include only configured evidence sections and shall instruct the model not to treat absent integrations as failures.	Covered by prompt-construction tests
NFR-03	Responsiveness	Blocking runbook indexing and query work shall run outside the API event loop, while indexing and embeddings remain local to the deployment.	No direct blocking call in route coroutine
NFR-04	Authentication	All routes other than /health and /login shall require a valid signed session cookie.	24-hour maximum age
NFR-05	Rate Limiting	The API shall enforce request limits, with a stricter limit on the login route.	60/min; 5/min on login

ID	Quality Attribute	Requirement	Target
NFR-06	Output Hygiene	Server-derived text rendered in the dashboard shall be HTML-escaped and response security headers shall be applied.	Escaping and headers covered by tests
NFR-07	Auditability	Each request shall be logged with timestamp, IP, route, method, user, status, and latency.	Structured local request log
NFR-08	Portability	The API and agent shall deploy through Docker Compose on one Linux host.	Single-host composition
NFR-09	Maintainability	The backend shall have an automated suite with measured line coverage.	Coverage reported, not used as a sole quality measure
NFR-10	Data Minimisation	Only selected telemetry sections shall be included in the prompt sent to the configured LLM provider.	No full observability-store export
NFR-11	Storage Retention	Verdict storage shall be bounded by automatic retention pruning.	Default 30 days, configurable
NFR-12	Signature Stability	Fallback signature derivation shall remove volatile IP, hash, and numeric tokens.	Deterministic tests
NFR-13	LLM Data Boundary	Prompt construction shall include only selected telemetry, and the configured provider and model shall be identifiable for governance and audit purposes.	Documented provider path and minimised prompt context
NFR-14	Production Network Security	A production deployment shall use HTTPS ingress and restrict telemetry, administration and application-origin ports to trusted networks.	Demonstration and production postures explicitly separated

Table 3.5 gives an acceptance criterion and verification reference for every requirement. Sources refer to the research questions and objectives, not an unrecorded stakeholder interview. Must denotes a core requirement; Should denotes an optional or production-deployment requirement. Test references identify inspected assertions in the dated local suite; they do not establish broader live performance. Source inspection and outcomes without completed verification are identified explicitly.

Table 3.5: Requirement Sources, Acceptance Criteria and Verification Evidence.

ID	Source and priority	Acceptance criterion	Verification reference and evidence boundary
FR-01	RQ1 / RO2; Must	One configured heartbeat cycle collects available logs, metrics and probe results; optional Docker input is omitted when unconfigured.	test_tools.py, test_docker_events_paths.py and test_agent_main_scheduler.py; fixture and mocked-adaptor checks.
FR-02	RQ1 / RO2; Must	A verdict contains exactly the required fields, or analysis fails closed with a visible pipeline alert.	test_llm_security.py and test_agent.py; parser and orchestration assertions, not diagnostic correctness.
FR-03	RQ1 / RO2; Must	Accepted verdict severity is one of ok, warning, high or critical.	test_providers.py and test_llm_security.py; canonical severity and schema checks.
FR-04	RQ2 / RO2; Must	The selected mode dispatches through the direct provider or LangChain reasoning path.	test_agent.py and test_langchain_agent_paths.py; mocked dispatch and tool paths.

ID	Source and priority	Acceptance criterion	Verification reference and evidence boundary
FR-05	RQ2 / RO4; Must	High/critical verdicts trigger notification dispatch; an ok verdict skips it.	test_agent.py; dispatch is asserted. External push receipt is not established by these tests.
FR-06	RQ1 / RO2; Must	Verdicts round-trip through SQLite and insertion prunes records outside configured retention.	test_store.py; persistence and retention assertions.
FR-07	RQ3 / RO4; Must	Acknowledging an eligible stored fingerprint masks matching low-risk rows in the default view and retains the verdict record.	test_api.py and test_store.py; acknowledgement, lookup and suppression assertions.
FR-08	RQ3 / RO4; Must	Changing signature, prompt version or model changes the fingerprint; expired acknowledgement is inactive.	test_memory.py and test_store.py; deterministic identity-change and expiry assertions.
FR-09	RQ3 / RO4; Must	High/critical verdicts remain visible and cannot be acknowledged for masking.	test_api.py and test_store.py; severe-verdict rejection and suppression checks. Applies to predicted severity.
FR-10	RQ5 / RO4; Must	Configured deterministic rules identify HTTP/SSH brute-force and port-scan patterns with source IPs.	threat_response.py inspection plus test_api.py/test_threat_response.py fixtures; broader attack-detection effectiveness unverified.
FR-11	RQ5 / RO4; Should	An authenticated operator selects a current server-side threat before a CrowdSec decision; unconfigured enforcement uses dry run.	test_api.py and test_llm_security.py; dry run, stale selection and target validation. Live rollback unverified.
FR-12	RQ2 / RO3; Must	Local Markdown documents are indexed with local embeddings, and rebuilding removes stale records.	test_rag.py and test_vector_store_paths.py; loader, embedding adapter and index assertions.
FR-13	RQ2 / RO3; Must	A runbook question invokes the provider with retrieved context and returns source titles or a structured error.	test_rag.py and frozen retrieval records; interface and retrieval evidence, not answer safety.
FR-14	RQ2 / RO2; Must	The dashboard exposes status, history, configuration, threats and the runbook assistant.	dashboard/index.html inspection and API tests; complete browser end-to-end acceptance is unverified.
FR-15	RQ5 / RO2; Should	Integration availability is exposed as booleans without returning secret configuration values.	test_api.py integration-status assertion and api/main.py inspection.
NFR-01	RO1 / RO2; Must	The heartbeat interval is configurable and one cycle is scheduled per interval. Prompt construction remains bounded.	test_agent_main_scheduler.py and prompt inspection. Multi-tool reasoning may make additional provider calls; total cost is unmeasured.

ID	Source and priority	Acceptance criterion	Verification reference and evidence boundary
NFR-02	RQ1 / RQ5; Must	Prompts include configured evidence and mark telemetry/runbooks as untrusted input; absent integrations are not treated as observed failures.	test_llm_security.py and prompts.py inspection; prompt construction verified, live model resistance unverified.
NFR-03	RQ2 / RO3; Must	Blocking indexing/query calls use asyncio.to_thread; local embedding/index paths are retained.	api/main.py inspection and runbook API tests; concurrent responsiveness under load is unverified.
NFR-04	RQ5 / RO4; Must	Protected routes reject missing/invalid sessions; signed sessions enforce the configured 24-hour maximum age.	test_api.py authentication redirects; api/auth.py and middleware inspection.
NFR-05	RQ5 / RO4; Must	The default limit is 60 requests per minute per IP, with five login attempts per minute.	test_api.py login-limit test and middleware/rate_limit.py inspection.
NFR-06	RQ5 / RO4; Must	Dashboard text is escaped and security headers are attached, including to unauthorised responses.	test_api.py header assertion and dashboard source inspection. Full DOM-injection/adversarial assurance unverified.
NFR-07	RQ5 / RO4; Must	A local structured audit record includes time, IP, route, method, user, status and elapsed time.	middleware/audit.py inspection; complete audit delivery and tamper evidence remain unverified.
NFR-08	RQ2 / RO2; Must	Compose defines compatible API/agent services and persistent volumes for one Linux host.	docker-compose.yml and Dockerfile inspection; no production deployment receipt is inferred.
NFR-09	RO5 / RQ4a; Must	Retain a dated source-scoped test/coverage record and disclose the tested checkout boundary.	2 September local receipt: 180 passed, 89% coverage; not a clean published-release result.
NFR-10	RQ5 / RO1; Must	Only selected configured telemetry enters the prompt; complete observability stores are not exported.	Prompt assembly and test_llm_security.py; selected construction paths verified, complete DLP unimplemented.
NFR-11	RQ5 / RO2; Must	Configured retention prunes expired verdicts, with a 30-day default.	test_store.py and api/store.py inspection; record lifecycle assertions.
NFR-12	RQ3 / RO4; Must	Fallback derivation normalises volatile tokens and produces repeatable output for equivalent tested text.	test_memory.py; deterministic fallback checks only. Model-generated signatures remain 41.7% stable in the frozen benchmark.
NFR-13	RQ5 / RO1; Must	The provider/model path is identifiable and cloud-bound prompt content is selected explicitly.	test_providers.py, payload and prompt inspection; external provider retention/compliance unverified.

ID	Source and priority	Acceptance criterion	Verification reference and evidence boundary
NFR-14	RQ5 / RO1; Should	An operational deployment exposes HTTPS ingress and restricts application-origin, telemetry and administration ports to trusted sources.	Terraform and Compose configuration inspection. Production deployment and independent network-security acceptance remain unverified.

3.2.3 Actors and Use Cases

Three actors appear in the use-case model. The Operator is responsible for the monitored infrastructure; the InfraGuard Agent runs each heartbeat without direct input; and the configured LLM Provider supplies the external model service. Their interactions are shown in Figure 3.4.

- UC-01: View the current status and verdict (Operator → System).
- UC-02: Inspect the root cause and recommended action of a verdict (Operator → System).
- UC-03: Acknowledge a verdict as a known non-issue (Operator → System).
- UC-04: Un-acknowledge a condition so it re-opens (Operator → System).
- UC-05: Review detected threats (Operator → System).
- UC-06: Apply a CrowdSec ban for a detected threat (Operator → System).
- UC-07: Ask the runbook assistant a question (Operator → System).
- UC-08 — Consult a Local Runbook: the operator submits an incident question, the application retrieves relevant whole Markdown documents from the indexed corpus, and the selected model produces an advisory answer conditioned on the supplied text with source titles.
- UC-09: Generate a verdict on a heartbeat, consulting the LLM provider (Agent → LLM Provider).
- UC-10: Dispatch a notification on a high or critical verdict (Agent → Operator).

3.3 System Architecture

InfraGuard AI runs as two processes. The agent process executes the reasoning heartbeat, while the API process serves the dashboard and REST surface. Both share the same SQLite database. Long-running integration calls are moved to worker threads so they do not block the API event loop. Figure 3.1 shows the main components.

Terminology. The agent is the scheduled application process; a heartbeat is one analysis cycle; the reasoning workflow is the bounded orchestration of collection, inference and validation;

and the LLM is the selected inference model. The separate runbook assistant handles operator questions. These terms distinguish application control flow from model generation.

3.3.1 Architectural Style

The single-host architecture keeps collection, verdict generation, and memory logic separate from the Loki, Prometheus, HTTP-probe, Docker, and LLM-provider adapters. Each adapter has a small interface, which makes a source easier to omit, replace, or test independently.

3.3.2 Components

1. Agent (Heartbeat). A long-running async process that, on each interval, prepares optional Docker log context and active acknowledgements, runs the LangGraph reasoning loop, including any required notification attempt, and persists the completed cycle result. Implemented in `agent/main.py` and `agent/orchestrator.py`.
2. FastAPI Service. Hosts the dashboard and the REST API (status, alerts, configuration, threats, runbooks, and acknowledgement endpoints) behind authentication, rate-limiting, security-header, and audit middleware. Implemented in `api/main.py`.
3. Reasoning Substrate. A LangGraph state machine implements the collect-analyse-decide-notify loop with two interchangeable analysis modes: a single structured provider call and a LangChain multi-tool agent.
4. LLM Client. A provider layer supporting the Gemini Developer API, Anthropic, OpenAI-compatible endpoints and optional local Ollama models through a common verdict schema.
5. Verdict-Memory. The fingerprinting and acknowledgement subsystem (`agent/memory.py` and the acknowledgements table) records matching low-risk verdicts with a flag used by default API/dashboard views. Later prompts receive only validated canonical condition identifiers for exact reuse; operator notes are excluded, and an identifier is neither an instruction nor evidence of health. The subsystem does not bypass inference or storage.
6. RAG Service. A retrieval pipeline over local Markdown runbooks, local ONNX all-MiniLM-L6-v2 embeddings, and a ChromaDB vector store.
7. Threat Subsystem. A deterministic detector that scans recent logs for attack patterns and an operator-approved CrowdSec adapter.
8. SQLite Store. The persistence layer for verdicts and acknowledgements, with automatic retention pruning.
9. Dashboard. A single self-contained HTML, CSS, and JavaScript page served as a static asset by FastAPI and communicating over JSON.

10. External Services. The selected cloud-model API (Gemini, Anthropic, or an OpenAI-compatible endpoint), ntfy.sh, and the optional CrowdSec Local API. Ollama provides an optional local-model path.

3.3.3 Communication Patterns

During each heartbeat, the agent queries the Loki and Prometheus HTTP APIs, runs the configured HTTP probes, and may read from the Docker Engine API. Verdicts and acknowledgements are stored in the SQLite database shared with the API. The dashboard exchanges JSON with the API and uses a session cookie for authentication. HTTPS termination is left to the deployment environment.

3.3.4 High-Level Architecture

Figure 3.1 presents the high-level architecture. The scheduled agent and FastAPI service share the SQLite verdict store, while the API also uses the local ChromaDB index and a read-only mount containing twenty Markdown runbooks. The agent reads configured telemetry sources and calls the selected provider. It sends ntfy alerts for high or critical verdicts. The API calls the CrowdSec Local API only after an operator approves an IP ban; other remediation remains manual.

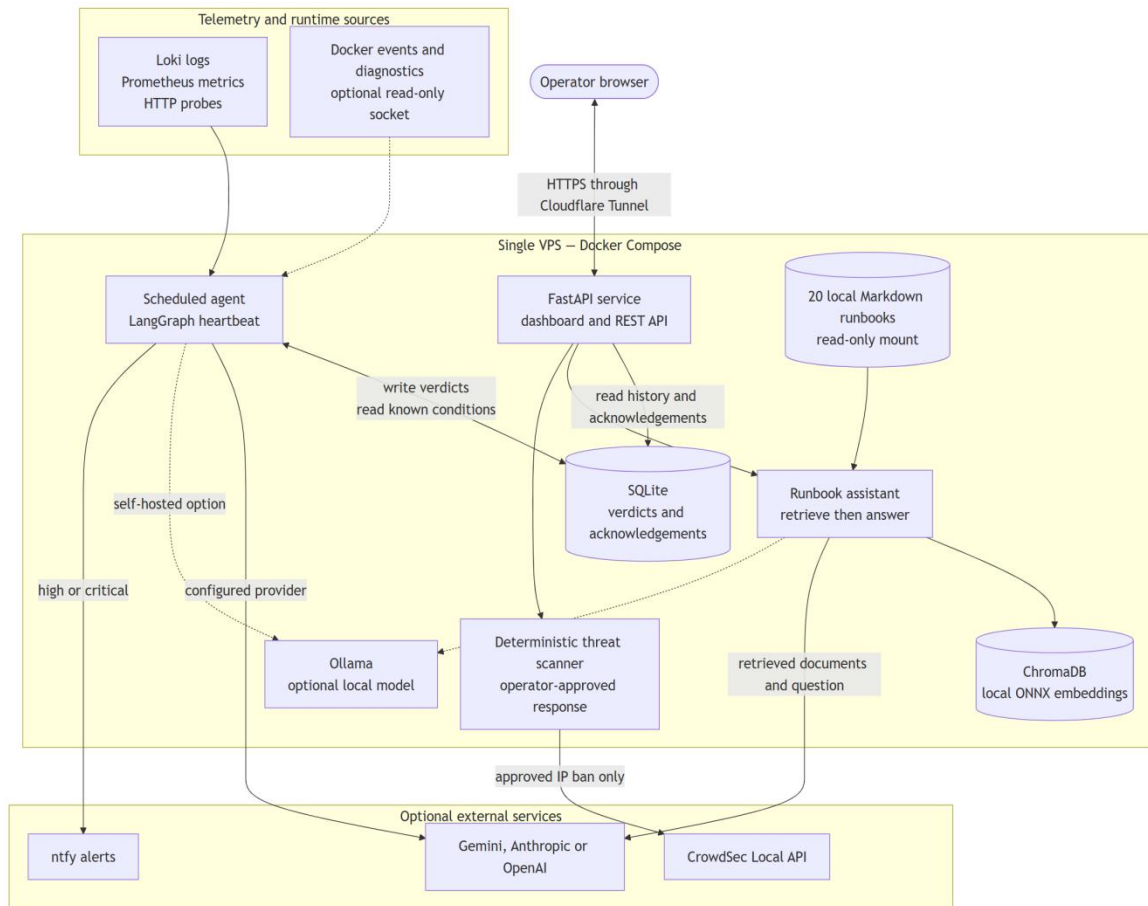


Figure 3.1: High-Level Architecture of InfraGuard AI.

3.3.5 Deployment Topology

Figure 3.2 depicts the intended single-VPS topology. DevPlanner and InfraGuard AI run as separate Docker Compose projects on the same Linux host. Cloudflare Tunnel supplies the proposed public HTTPS entry point, while InfraGuard reaches its API, Loki, Prometheus, and CrowdSec through loopback-bound origins. Runbooks and application state remain on local volumes. Only the selected cloud-model API and ntfy require outbound access; Ollama can be used for local inference. This diagram is an architecture description, not a retained deployment receipt.

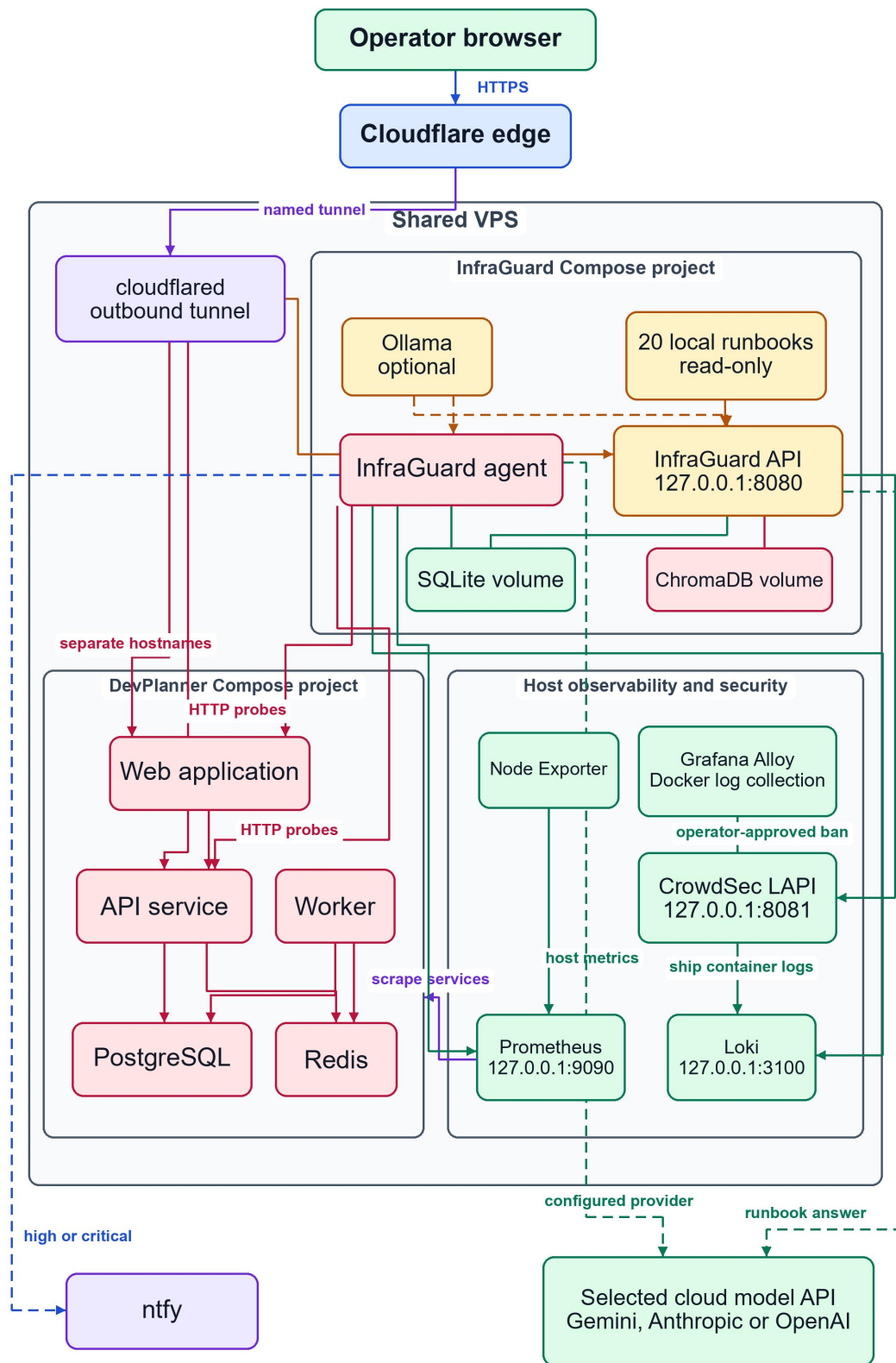


Figure 3.2: Intended Single-VPS Topology for DevPlanner and InfraGuard AI.

3.3.6 Heartbeat Verdict Pipeline

Figure 3.3 traces the heartbeat and remediation boundary. The agent prepares optional Docker log context and active acknowledgements, collects configured telemetry and obtains a validated structured verdict from the selected model. For high or critical results, the graph may collect additional Docker diagnostics and attempts an ntfy notification when configured. After the graph returns, the agent computes the fingerprint and stores the verdict together with the diagnostic and notification results. Separately, deterministic log rules may identify a threat, but an IP ban is submitted to CrowdSec only after operator approval. The LLM does not restart services, delete data, change configuration or alter the firewall.

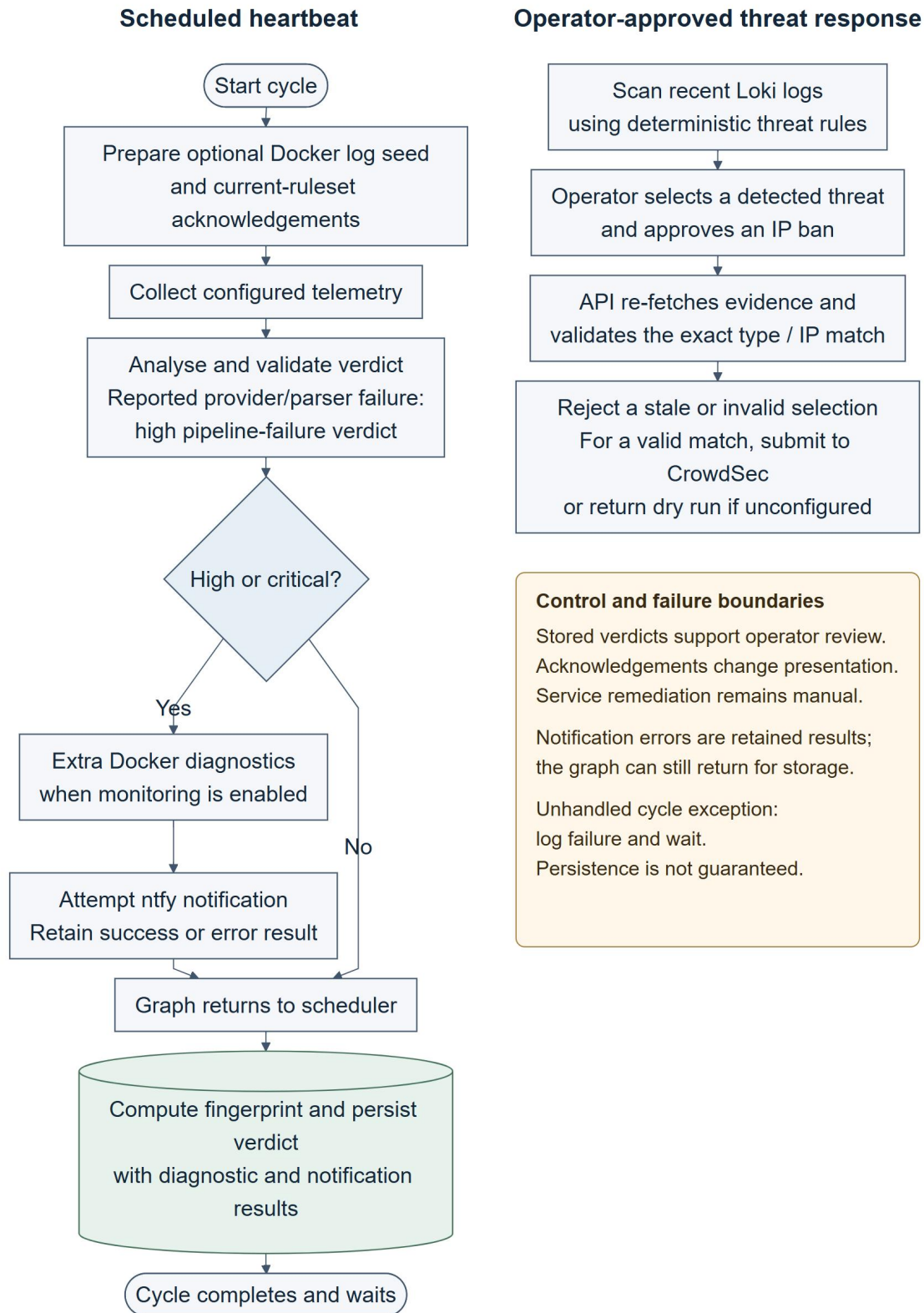


Figure 3.3: Heartbeat Pipeline and Remediation Boundary.

3.4 System Design

The design work focused on five areas: the database schema, the normal heartbeat sequence, acknowledgement matching, the reasoning state machine, and runbook indexing.

3.4.1 Database Design (Entity-Relationship Model)

Operational state is kept in two SQLite tables. ChromaDB holds the runbook embeddings, while API audit events are written to an append-only file. Figure 3.6 shows the entity-relationship model, followed by a field-level description.

Entity: verdicts

Columns: id (PK, AUTOINCREMENT), created_at (TEXT, UTC ISO-8601), severity (TEXT), summary (TEXT), payload (TEXT, JSON of the full verdict and extras), signature (TEXT), fingerprint (TEXT). Each heartbeat appends one row; rows older than the retention window are pruned on insert.

Entity: acknowledgements

Columns: fingerprint (PK, TEXT), signature (TEXT), severity (TEXT), summary (TEXT), note (TEXT), acked_by (TEXT), created_at (TEXT), expires_at (TEXT, nullable). One row per acknowledged condition; an acknowledgement is active while expires_at is null or in the future.

Verdicts and acknowledgements are matched by fingerprint. Several verdict rows may share a fingerprint when the same condition recurs, while each fingerprint can have at most one active acknowledgement. A matching verdict is marked acknowledged; only an ok or warning verdict receives a presentation-masking flag. The stored record remains available, and every later heartbeat still invokes the configured model and stores its verdict.

3.4.2 Use-Case Model

Figure 3.4 shows the use-case model. Through the dashboard, the operator reviews current and historical verdicts, marks a low-risk condition as known, queries or re-indexes local runbooks, reviews detected threats, and may approve a CrowdSec IP ban. The heartbeat scheduler collects telemetry, obtains and stores a structured verdict from the configured model, and sends a high- or critical-severity alert when configured. Service remediation remains an operator action.

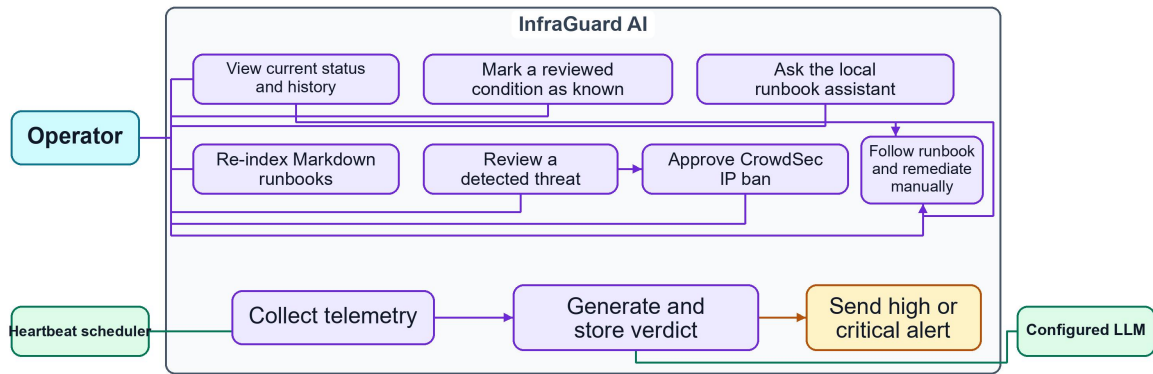


Figure 3.4: InfraGuard AI Use-Case Model.

3.4.3 Sequence Diagram: One Heartbeat Cycle

A heartbeat prepares optional Docker log context and active acknowledgements before collecting bounded telemetry from the configured sources, as shown in Figure 3.5. Only validated canonical acknowledgement identifiers enter the model context for exact signature reuse; notes are excluded and acknowledgement does not authorise a severity downgrade. After a validated verdict is returned, high or critical results may trigger additional Docker diagnostics and an ntfty notification attempt. The graph then returns, and the agent computes the fingerprint and persists the verdict with those results. No service-changing command is executed by the heartbeat.

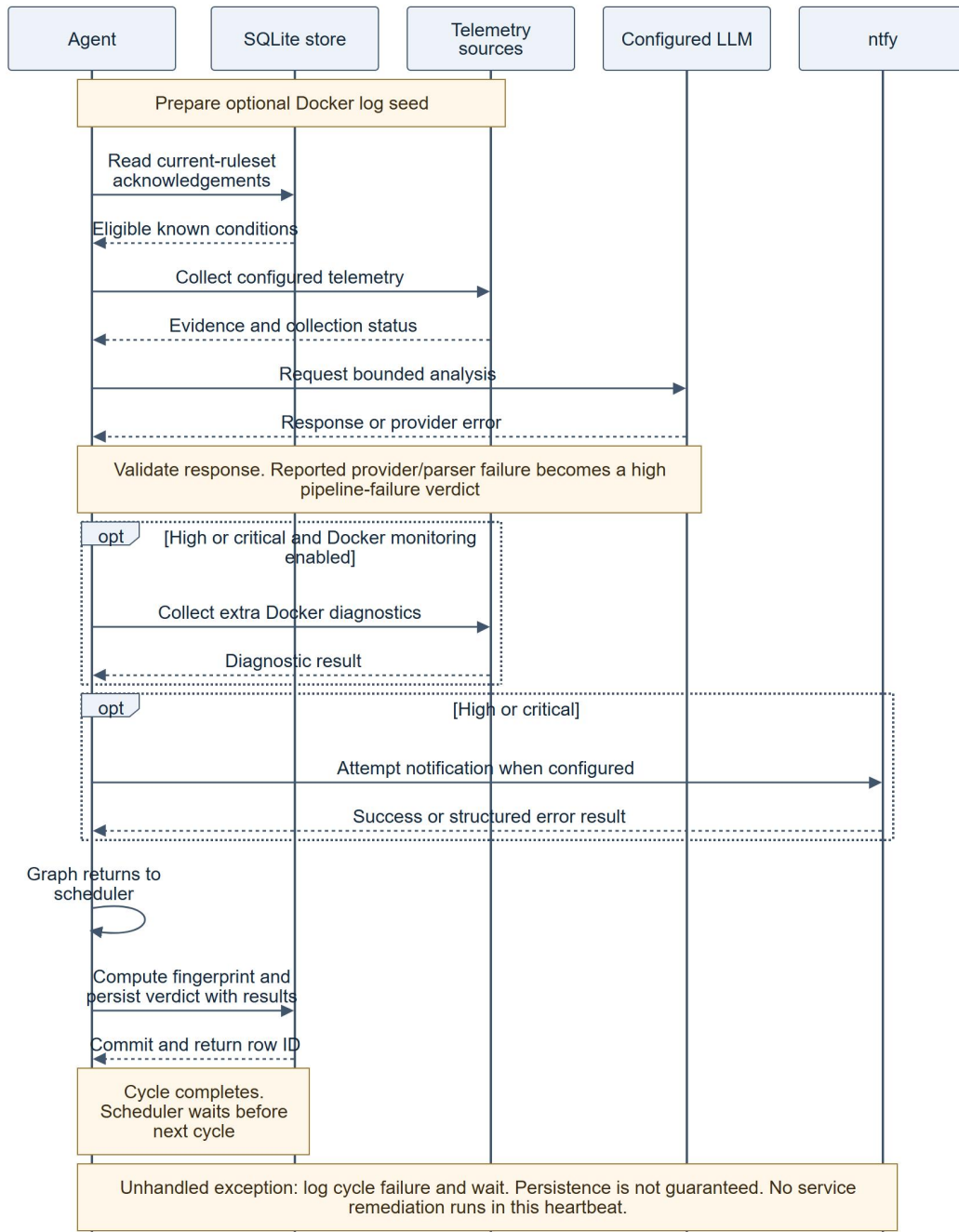


Figure 3.5: Sequence of One Heartbeat Cycle.

3.4.4 Entity-Relationship Model

Figure 3.6 visualises the two-table schema described above. Many verdict rows may carry the same fingerprint, while the acknowledgements table stores at most one row for that fingerprint together with its note, operator, creation time, and optional expiry.

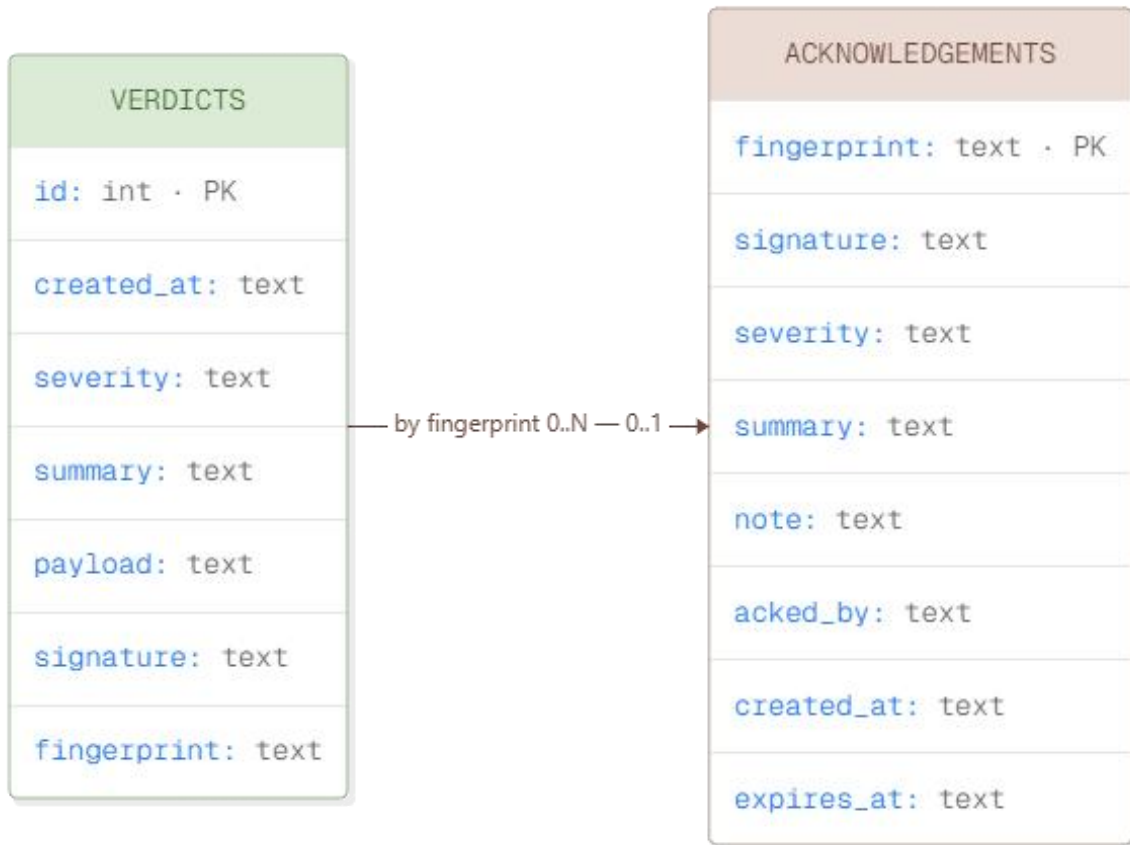


Figure 3.6: Verdict and Acknowledgement Data Model.

3.4.5 Verdict-Memory Design

The acknowledgement memory combines the condition signature, prompt version, and model in a SHA-256 fingerprint: $\text{fingerprint} = \text{SHA-256}(\text{signature} \mid \text{prompt_version} \mid \text{model})$. Under prompt-contract version 2, a model verdict must include a canonical three-part signature; a missing or malformed signature fails validation and produces the non-acknowledgeable high-severity pipeline:analysis-failed:agent sentinel. A deterministic canonical fallback exists only as a defensive persistence path for missing legacy/internal input. An operator acknowledgement stores the fingerprint with an optional note and expiry time. A changed signature, prompt version, or model produces a new fingerprint. Matching ok and warning rows may be masked from the default view; high and critical rows cannot be masked.

3.4.6 State Machine: LangGraph Reasoning Agent

Figure 3.7 depicts the LangGraph state machine that governs the reasoning agent. Four nodes, collect_data, analyze, decide_action, and notify, are used on each heartbeat. The graph begins at collect_data, proceeds to analyze and decide_action, and routes high- and critical-severity verdicts to notify. Other verdicts end without notification. When local Docker monitoring is

enabled, `decide_action` can also gather container diagnostics for high- and critical-severity verdicts.

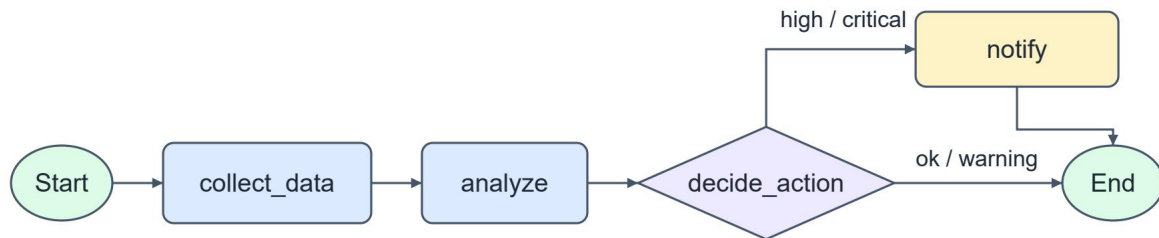


Figure 3.7: LangGraph Agent State Machine.

3.4.7 Workflow: Runbook RAG Indexing

Runbook indexing starts when the operator calls `POST /api/runbooks/index`. The loader recursively reads approved Markdown files from the configured local directory and retains title, source, and category metadata. Each whole file is embedded locally with the ONNX all-MiniLM-L6-v2 model and stored as one ChromaDB document; no chunk splitting is implemented. For a query, up to four closest whole documents and the operator question are serialised as untrusted data inside explicit boundaries. The API returns an advisory answer conditioned on supplied runbook text together with source titles. The operator reviews and executes any selected step manually.

3.5 Tools and Technologies Used

The implementation stack is grouped below by layer. Table 3.6 lists the telemetry sources and their collection modules.

3.5.1 Backend and Orchestration

- Language and runtime: Python 3.11+ with asyncio.
- Web/API framework: FastAPI with Uvicorn.
- LLM orchestration: LangGraph and LangChain.
- LLM providers: Gemini Developer API, Anthropic, OpenAI-compatible endpoints, or optional local Ollama, selected by configuration.
- Vector store and embeddings: ChromaDB with local ONNX all-MiniLM-L6-v2 embeddings.
- Persistence: SQLite via aiosqlite.
- HTTP client: httpx; runbook source: local Markdown files mounted read-only in the API container.

3.5.2 Security and Deployment

- Sessions: itsdangerous signed cookies; rate limiting: slowapi; security headers and CSP via custom middleware.
- Threat response: CrowdSec Local API.
- Notifications: ntfy.sh.
- Packaging and deployment: Docker Compose on a shared Linux VPS, Cloudflare Tunnel for HTTPS ingress, and GitHub Actions for CI.
- Frontend: a single self-contained HTML/CSS/JavaScript dashboard served by FastAPI.

3.5.3 Telemetry Sources

Table 3.6 enumerates the telemetry sources and the modules that collect them.

Table 3.6: Telemetry Sources and Collection Tools.

Source	Collection Module	Signal	Notes
Logs	agent/tools/loki.py	Recent log lines	Loki query_range, newest-first, configurable window
Metrics	agent/tools/prometheus.py	CPU, memory, disk, HTTP 5xx ratio	Prometheus instant queries
Endpoint health	agent/tools/http_probe.py	Status code and latency	Comma-separated PROBE_URLS
Container state	agent/tools/docker_api.py, docker_events.py	Events, stats, health, logs	Optional (ENABLE_DOCKER_MONITORING=1)
Threats	agent/tools/threat_response.py	Brute-force / port-scan patterns	Deterministic regex over recent logs
Local runbooks	agent/rag/local_runbooks_loader.py	Read-only Markdown corpus mounted into the API container.	Local Markdown source; no external documentation service

3.5.4 Design Trade-offs and Alternatives

The implementation choices favour inspectability and a small single-host footprint. Table 3.7 records the principal alternatives and the boundary introduced by each choice.

Table 3.7: Principal Design Choices, Alternatives, and Trade-offs.

Choice	Alternative	Reason Selected	Trade-off
SQLite	PostgreSQL	Zero external database service and simple shared local state.	Single-host concurrency and horizontal scaling are limited.
ChromaDB	Managed vector database	Local persistence and a compact Python integration.	Retrieval scaling and operational redundancy were not evaluated.

Choice	Alternative	Reason Selected	Trade-off
all-MiniLM-L6-v2 ONNX	Cloud embeddings or a larger local model	Local embedding avoids exporting the runbook corpus and reduces deployment cost.	Retrieval quality may be lower than larger models and requires benchmarking.
Top-four retrieval	Dynamic or reranked retrieval	A maximum of four retrieved documents limits source count; context length varies with document length.	The value four was an engineering default, not an empirically optimised setting.
Separate agent and API processes	Single process or distributed workers	A blocking heartbeat cannot stall dashboard request handling.	Both processes still share one host and SQLite store.
Signature + prompt version + model fingerprint	Signature-only matching	A changed prompt-version value or active model name invalidates prior matching acknowledgements.	Every heartbeat still incurs inference and storage work.
Deterministic threat detection	LLM-based threat classification	Thresholds and matching rules remain inspectable before an operator-approved ban.	Coverage is limited to the implemented attack patterns.

CHAPTER FOUR: SYSTEM IMPLEMENTATION

The implemented security controls are functional safeguards and architectural mitigations. Software tests and source review do not constitute independent adversarial assessment, penetration testing, certification or production security assurance. Section 4.3 records the control boundaries and Section 5.6 the evaluation limits.

4.1 Development Environment

Development and validation used a workstation configured to approximate the intended single-host deployment.

4.1.1 Development Environment and Tooling

Platform. Primary development was conducted on a Windows 11 workstation running Docker Desktop. All services run in Linux containers based on the `python:3.11-slim` image. The intended operational environment is a single Linux VPS running native Docker, while the repository's Terraform definitions provide an alternative Google Compute Engine path. This environment description is not a retained deployment receipt.

Source control and CI. The repository defines two GitHub Actions workflows. `test.yml` runs the `pytest` suite for pull requests to the main branch. `deploy.yml` repeats the tests after a push to main, then builds the agent and API images, publishes them to Google Artifact Registry, and updates the target virtual machine. Because these steps share one job, deployment proceeds only if the tests pass.

Editor and tooling. Development was performed in Visual Studio Code with Python and Docker tooling. Application dependencies are listed in `requirements.txt` and installed into each container at build time.

4.2 Implementation Details

This section maps the implemented design decisions to repository evidence. File paths are retained for reproducibility, while the surrounding explanation emphasises rationale, trade-offs, failure boundaries and what was not evaluated.

4.2.1 Repository Layout

Figure 4.1 and Table 4.1 provide the reproducibility map. The important architectural choice is separation of the scheduled agent, API, adapters, reasoning substrate and persistence boundaries so that failures can be recorded and individual integrations can be omitted or tested. The single-host design reduces deployment complexity but shares one host, store and network failure domain.

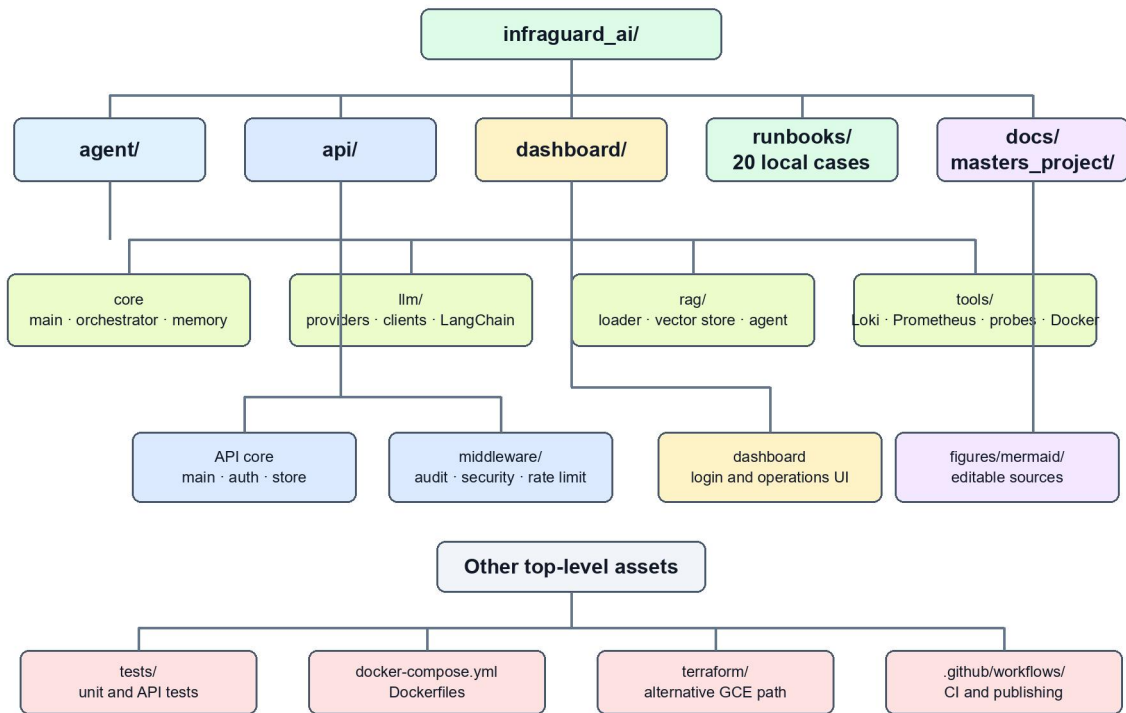


Figure 4.1: Repository Layout of the Reference Implementation.

Table 4.1: Repository Module Map and Responsibilities.

Path	Responsibility
agent/main.py	Heartbeat entry point; fetches acknowledgements, awaits the reasoning/notification cycle and persists its result.
agent/orchestrator.py	The LangGraph state machine wiring collect_data, analyze, decide_action, and notify.
agent/memory.py	Verdict fingerprinting (signature + ruleset version) and deterministic signature fallback.
agent/llm/providers.py	Gemini, Anthropic, OpenAI-compatible and Ollama provider dispatch
agent/llm/schema.py	Prompt-contract v2: exact five-field raw-JSON validation, canonical signatures, bounded strings, duplicate/control rejection and severity/signature consistency.
agent/llm/gemini_client.py	Gemini Developer API client
agent/llm/anthropic_client.py	Single-call Anthropic Claude client.
agent/llm/openai_client.py; agent/llm/ollama_client.py	OpenAI-compatible and locally hosted Ollama clients
agent/llm/langchain_agent.py	LangChain multi-tool agent (ReAct-style) over the telemetry tools.
agent/llm/prompts.py	Prompt assembly, evidence constraints, and the known-conditions memory block.
agent/rag/local_runbooks_loader.py	Loads Markdown runbooks and attaches category metadata
agent/rag/vector_store.py	ChromaDB binding: index, load, and similarity search.

Path	Responsibility
agent/rag/runbook_agent.py	Retrieval-augmented runbook question answering.
agent/tools/loki.py, prometheus.py, http_probe.py	Telemetry collection tools (logs, metrics, endpoint health).
agent/tools/docker_api.py, docker_events.py, docker_logs.py	Optional Docker Engine telemetry (events, diagnostics, log tail).
agent/tools/threat_response.py	Deterministic threat detection and the CrowdSec adapter.
agent/tools/notify.py, langchain_tools.py	ntfy.sh notifications; @tool wrappers for the multi-tool agent.
api/main.py	FastAPI application: routes, middleware registration, auth, and the acknowledgement and threat endpoints.
api/auth.py	Signed session-token creation and validation.
api/store.py	SQLite persistence for verdicts and acknowledgements, with retention pruning.
api/middleware/audit.py, security.py, rate_limit.py	Request auditing, security headers/CSP, and rate limiting.
dashboard/index.html, login.html	The single-page operations dashboard and the login page.
tests/	Source-scoped pytest suite, including LLM-security, prompt-boundary, memory, store, API, RAG, threat-response, telemetry and orchestration cases.
terraform/	Google Compute Engine infrastructure-as-code.
docker-compose.yml, agent/Dockerfile, api/Dockerfile	Container composition and image definitions.
.github/workflows/test.yml, deploy.yml	CI test workflow and CD deployment workflow.

4.2.2 Reasoning, Prompt Validation and Verdict Memory

Reasoning workflow. The reasoning workflow lives in `agent/orchestrator.py` and is started on a schedule by the `asyncio` heartbeat in `agent/main.py`. At each interval, the heartbeat loads active acknowledgements and, when Docker monitoring is enabled, may tail error logs from a monitored container. The compiled `LangGraph` workflow runs on a worker thread so a blocking model call cannot stall the event loop. Its `collect_data` node gathers telemetry, analyze requests a verdict, and `decide_action` may add container diagnostics for a high or critical result. A conditional edge routes those two severities to notify; all other verdicts end the cycle. The scheduler persists the returned verdict and results after the graph completes.

Provider modes. Two settings control LLM analysis: `USE_LANGCHAIN_AGENT` selects the analysis mode, and `LLM_PROVIDER` selects Gemini, Anthropic, an OpenAI-compatible endpoint, or Ollama. The active model name is included in the acknowledgement fingerprint. Direct mode sends the assembled prompt in one request and parses the returned JSON through the shared schema module. In multi-tool mode, the provider chat model may call the Loki, Prometheus, and HTTP-probe tools before returning a verdict, subject to an iteration limit. Both paths produce the same normalised fields.

Prompt validation. Prompt construction in `agent/llm/prompts.py` serialises each available telemetry source as untrusted JSON data inside explicit boundaries and instructs the model not to treat an absent optional integration as an incident. Prompt-contract version 2 accepts only one raw JSON object with exactly five non-empty string fields: `severity`, `summary`, `root_cause`, `recommended_action`, and `signature`. It rejects fences, surrounding prose, duplicate, missing or extra fields, disallowed control characters, overlong values, unsupported severities, non-canonical signatures and severity/signature inconsistencies.

Verdict memory. Acknowledgement behaviour spans `agent/memory.py`, `api/store.py`, the prompt assembler, and the acknowledgement endpoints; Figure 4.2 traces the flow. A condition signature, prompt version and model name form the SHA-256 fingerprint. An operator may acknowledge an ok or warning verdict, add a note, and choose an expiry time. Later prompts receive only validated canonical identifiers: notes are omitted, the identifier supports exact reuse only, and it never authorises a severity downgrade. Every heartbeat still invokes the model and stores the verdict. A matching low-risk row may be masked from the default view; changed identities and all high, critical or pipeline-failure rows remain visible.

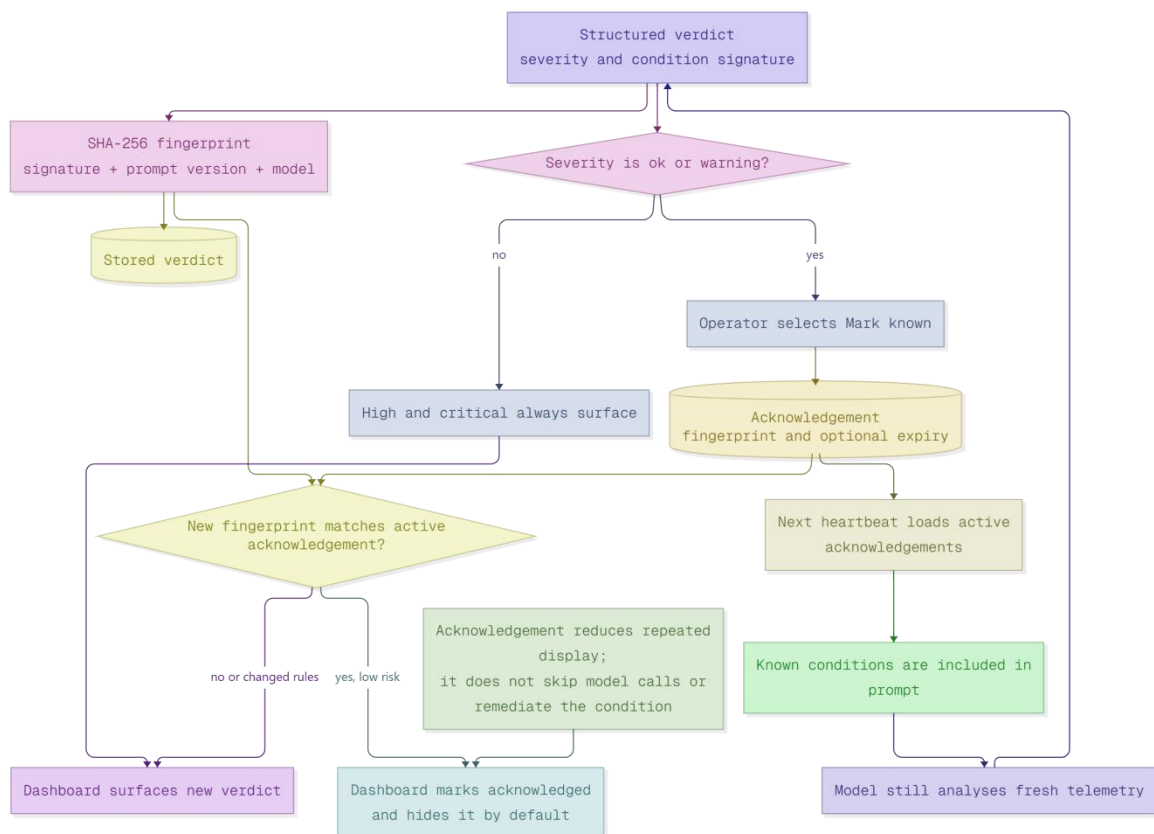


Figure 4.2: Verdict-Memory Fingerprint and Acknowledgement Flow.

4.2.3 Telemetry, Runbook Retrieval and Threat Response

Telemetry collection. Each telemetry adapter returns structured data or a structured error. The Loki adapter in `agent/tools/loki.py` uses `query_range` for a fixed recent window, orders results newest first, and enforces a configurable limit. Prometheus instant queries collect CPU, memory, disk, and HTTP 5xx-rate signals. HTTP probes record the status and latency of each configured endpoint. Docker events, diagnostics, and error logs are collected only when Docker monitoring is enabled.

Runbook retrieval. The runbook service in `agent/rag/` recursively loads approved Markdown files from `RUNBOOKS_DIR` while retaining title, source, and category metadata. Each file remains one whole retrievable document, embedded locally with ONNX all-MiniLM-L6-v2 and stored in ChromaDB; the current code does not create smaller chunks. At query time, up to four closest whole documents and the question are serialised as untrusted data and supplied to the configured LLM. The answer is conditioned on that text and includes source titles. Operators trigger re-indexing, the source mount is read-only, and the application executes no runbook command.

Threat response. Threat detection in `agent/tools/threat_response.py` does not use an LLM. It counts repeated HTTP 401/403 responses, SSH authentication failures, and rapid connection attempts by source IP. When an operator requests a ban, the API validates the type and address, freshly re-fetches Loki logs, reruns detection, and accepts only an exact server-derived type/IP match. Stale or fabricated selections return HTTP 409; client-supplied counts and descriptions are ignored. A matched decision is then sent to CrowdSec, or logged as a dry run when CrowdSec is unconfigured.

4.2.4 API, Persistence and Retention

API and middleware. The FastAPI application in `api/main.py` serves both the dashboard and the JSON REST API. Four middlewares are registered: audit logging, security headers, per-IP rate limiting, and authentication. The authentication layer requires a valid signed session cookie except on the public health and login endpoints, and the login route has its own stricter rate limit. Runbook queries, indexing, and Loki-backed threat scans run on worker threads so their blocking integration calls do not stall the event loop.

Persistence and retention. SQLite persistence is implemented in `api/store.py` with `aiosqlite` and uses the verdicts and acknowledgements tables described in Section 3.4.1. The schema is created and migrated idempotently whenever a connection opens, allowing an existing database to gain the signature and fingerprint columns in place. Each insert also prunes verdicts older than the configured retention window, so no separate maintenance job is needed to bound storage growth.

4.2.5 The Dashboard

The dashboard (dashboard/index.html) is a single page served by FastAPI. It displays the current verdict, integration status, agent staleness, detected threats, runbook queries, and recent checks. Root-cause and recommended-action text can be expanded when needed.

For ok and warning verdicts, the page provides controls to mark or unmark a condition as known, a known tag, and a toggle for acknowledged rows. Text from the server, model, or logs passes through a single HTML-escaping helper before it is inserted into the page. This limits the cross-site-scripting risk posed by untrusted log or model content. Figure 4.3 shows the dashboard.

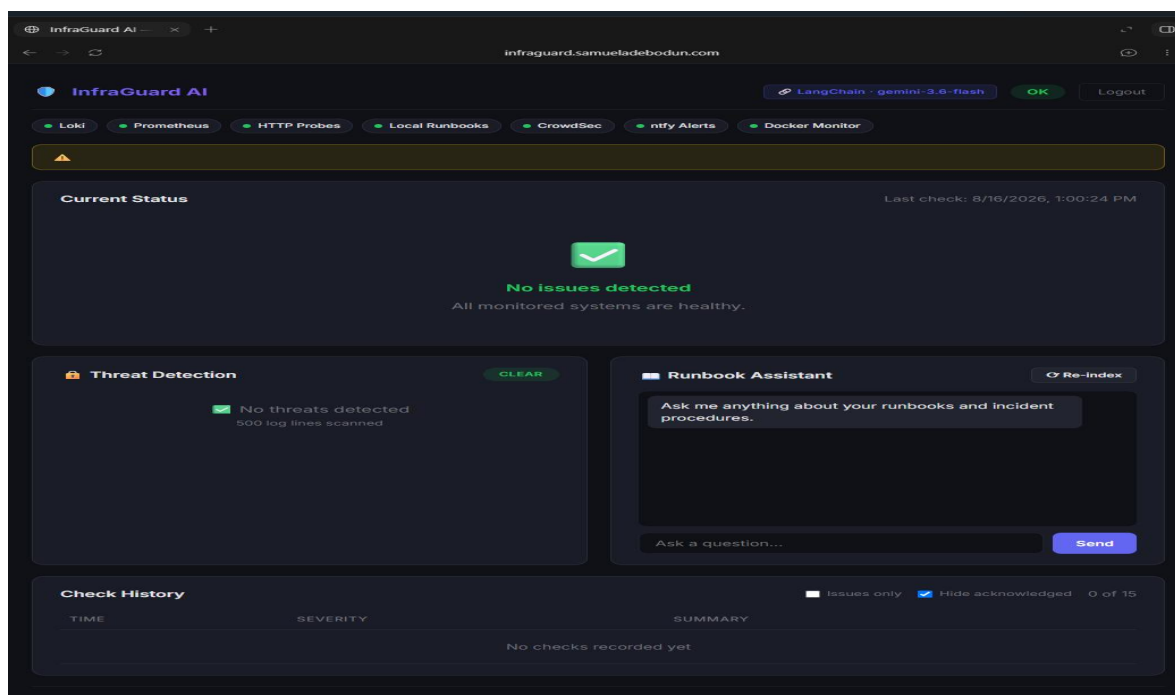


Figure 4.3: InfraGuard AI Operations Dashboard.

The dashboard runbook panel exposes the retrieval workflow described in Section 4.2.3. Figure 4.4 summarises whole-document local indexing, top-four document retrieval, an answer conditioned on supplied runbook text with source titles, and the human-review boundary.

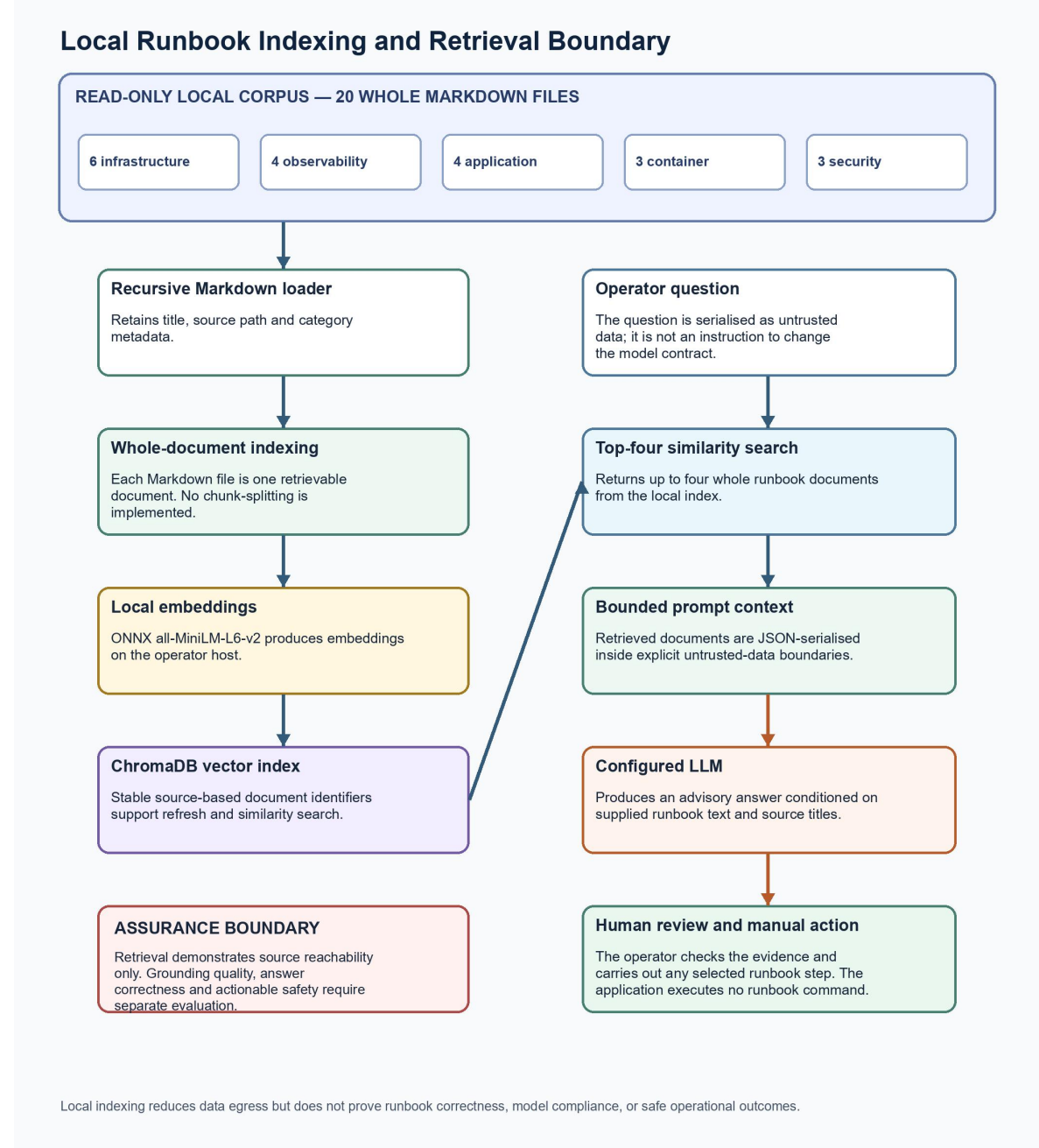


Figure 4.4: Local Runbook Indexing and Retrieval Process.

4.2.6 API Endpoints

Table 4.2: API Endpoint Reference.

Endpoint	Method	Purpose
/	GET	Serve the dashboard (authenticated).

Endpoint	Method	Purpose
/login	GET/POST	Serve the login page or submit credentials; five login attempts per minute.
/logout	GET	Clear the authenticated session cookie.
/health	GET	Liveness check (public).
/status	GET	Latest verdict with staleness and memory (fingerprint, acknowledged, suppressed) fields.
/alerts	GET	Recent verdict history with per-row memory fields.
/api/config	GET	Which integrations are configured (booleans only).
/api/agent/mode	GET	Active reasoning mode and model.
/api/threats	GET	Scan recent Loki logs for brute-force and port-scan patterns.
/api/threats/apply	POST	Validate a type/IP selection, re-fetch and re-detect current Loki evidence, then apply only an exact server-derived CrowdSec decision; stale or fabricated selections return 409.
/api/verdicts/ack	POST	Acknowledge a verdict condition as a known non-issue.
/api/verdicts/unack	POST	Remove an acknowledgement so the condition re-opens.
/api/acks	GET	List the active acknowledgements.
/api/runbooks/query	POST	Answer a question over the indexed runbooks (RAG).
/api/runbooks/index	POST	Clear the derived index and rebuild it from mounted local Markdown files.

4.3 Security, Performance, and Scalability Considerations

4.3.1 Authentication, Output Hygiene and Auditability

Authentication. All non-public endpoints require a session cookie signed with an itsdangerous timestamped serialiser and an environment-provided secret. Sessions expire after twenty-four hours and the authentication middleware checks the cookie on every request. Credential comparison uses `hmac.compare_digest`. The cookie is `HttpOnly`; its `Secure` attribute is enabled only when `SESSION_COOKIE_SECURE=1`, so deployment configuration must set that flag whenever HTTPS is used.

Rate limiting and output hygiene. The `slowapi` middleware applies a general request limit and a stricter login limit. Dashboard rendering uses a shared escaping helper for server-derived text. The response middleware adds a content-security policy and other headers. The current policy permits inline script and style content because the dashboard is a single HTML file; this weakens the policy and should be removed in a hardened deployment by moving scripts and styles to separate files.

Browser escaping constrains DOM injection but does not make telemetry or retrieved runbooks safe model instructions. Malicious log text or runbook content could attempt prompt injection, distort a verdict or encourage unsafe action. Model text is not executed directly and a CrowdSec ban requires operator approval, but no retained adversarial prompt-injection evaluation or independent penetration test was found.

Auditability. The audit middleware writes one structured JSON line per request with timestamp, client IP, method, route, user, status, and elapsed time. The file is a local operational log. It is not cryptographically protected or tamper-evident, so external log shipping and retention controls are recommended for production use.

4.3.2 Performance, Scalability and Deployment Boundary

Performance and responsiveness. The agent and API run as separate processes. API routes that call blocking LLM, runbook-indexing, or Loki clients dispatch that work to a worker thread. The default heartbeat is 120 seconds, and one model analysis is performed per heartbeat. This design bounds request frequency. The implemented heartbeat path was not performance-profiled; the controlled qwen2.5:3b benchmark separately recorded response latency, token use and the local metered-cost boundary.

Scalability and degradation. The design targets one host and its co-located workloads; multi-host operation is future work. The API, scheduled agent and SQLite store share a failure domain, and no high-availability, failover or horizontal-scaling mechanism was implemented. Concurrent incident behaviour and workloads spanning 100 or 1,000 hosts were not measured. Each telemetry tool converts a failed request into a structured error so a cycle can continue with less evidence, while a provider or parser failure records the high-severity pipeline:analysis-failed:agent sentinel for operator review. These are degradation paths, not evidence of resilience under sustained outage.

The read-only Docker socket remains a powerful host interface, and ntfy notifications can send incident text to a public service endpoint. Production deployment requires a narrower integration boundary, confidential notification routing, capacity tests, backup and recovery exercises, and retained rollout and rollback evidence.

Deployment boundary. WARNING - PRODUCTION SECURITY BOUNDARY. The supplied Terraform now creates no ingress firewall rules by default. HTTPS port 443 is opt-in only through explicit source CIDR ranges; port 80 is optional for redirect-only use; ports 8080, 3100 and 9090 require trusted management CIDRs and reject world-open ranges. Docker Compose binds the API to 127.0.0.1:8080. These remediations remove the earlier development exposure, but the project does not bundle a TLS terminator or reverse proxy, or managed-secret integration. Operational deployment therefore still requires HTTPS ingress, private telemetry and administration, managed secret stores, hardened browser policy, backup and recovery controls, and security verification as summarised in Table 4.3.

Table 4.3: Security and Privacy Controls by Evidence Classification.

Area	Implemented or demonstrated state	Control and evidence class	Organisational, legal or deployment obligation
Ingress	No Terraform ingress by default; opt-in CIDRs for 443; loopback Compose binding	Implemented; code/configuration reviewed; not independently assessed	Retain a hardened HTTPS terminator, private origins and a deployment/penetration-test receipt.

Area	Implemented or demonstrated state	Control and evidence class	Organisational, legal or deployment obligation
Telemetry ports	Management ports disabled unless trusted CIDRs are supplied; world-open ranges rejected	Implemented configuration control; no live network assessment	Keep telemetry and administration private and verify the effective cloud firewall.
Secrets	Environment-provided credentials; no bundled managed-secret integration	Production control recommended, not implemented	Use least-privilege identities, managed secrets, rotation and auditable access.
Browser and request controls	Authentication, rate limits, escaping and security headers; CSP still permits unsafe-inline	Implemented and functionally tested; no independent security assessment	Remove inline assets, add deployment-appropriate CSRF/HSTS controls and conduct penetration testing.
Audit records	Structured local JSON request log without tamper evidence	Implemented; functional path tested; integrity not assessed	Forward to a protected external sink with retention, access and tamper-evidence controls.
Cloud LLM data path	Selected prompt context; provider/model traceability; local validation; optional local-model path	Technical controls present and partly software-tested; provider behaviour and legal compliance not assessed	Approve providers; minimise/redact fields; define lawful basis, processor terms, retention, DPIA and transfer safeguards; retain evidence.
Privileged integrations and notifications	Docker socket access; operator-mediated CrowdSec; incident text may be sent to ntfy.sh	Functional controls, fresh server-side detection recheck and invalid/special-address rejection; no complete protected-CIDR policy, live adversarial or rollback assessment	Remove or proxy the Docker socket; define protected deployment/admin CIDRs; use confidential notification transport; verify least privilege, rollback and effective network policy.

4.3.3 Data Governance and Cloud-LLM Boundary

Operational telemetry may contain account identifiers, source IP addresses, request paths, device identifiers, secrets or free text. Figure 4.5 distinguishes what remains on the operator host from what may cross to a cloud LLM. The cloud path can include selected telemetry, retrieved runbook excerpts, the question, prompt and provider/model metadata; the raw response returns for local validation, persistence and authenticated review. The Ollama path can keep model inference local.

Technical controls include prompt minimisation, local validation, access restrictions and retention settings. Organisational controls include approved providers, role assignment, incident procedures and review of what may enter prompts. Legal obligations include a lawful basis, controller/processor terms, a data privacy impact assessment where required and a documented transfer basis under the Nigeria Data Protection Act. Evidence of compliance requires retained assessments, contracts, configurations and operational records; application features alone are not such evidence (Federal Republic of Nigeria, 2023).

Provider-side processing, diagnostic logging, retention, residency and training use depend on the selected service, account configuration and contract. No provider-side deletion test, legal assessment, compliance certification or cross-border-transfer verification was completed.

Figure 4.5 therefore marks cloud exposure as a deployment decision and evidence obligation, not as a property proved by local hosting.

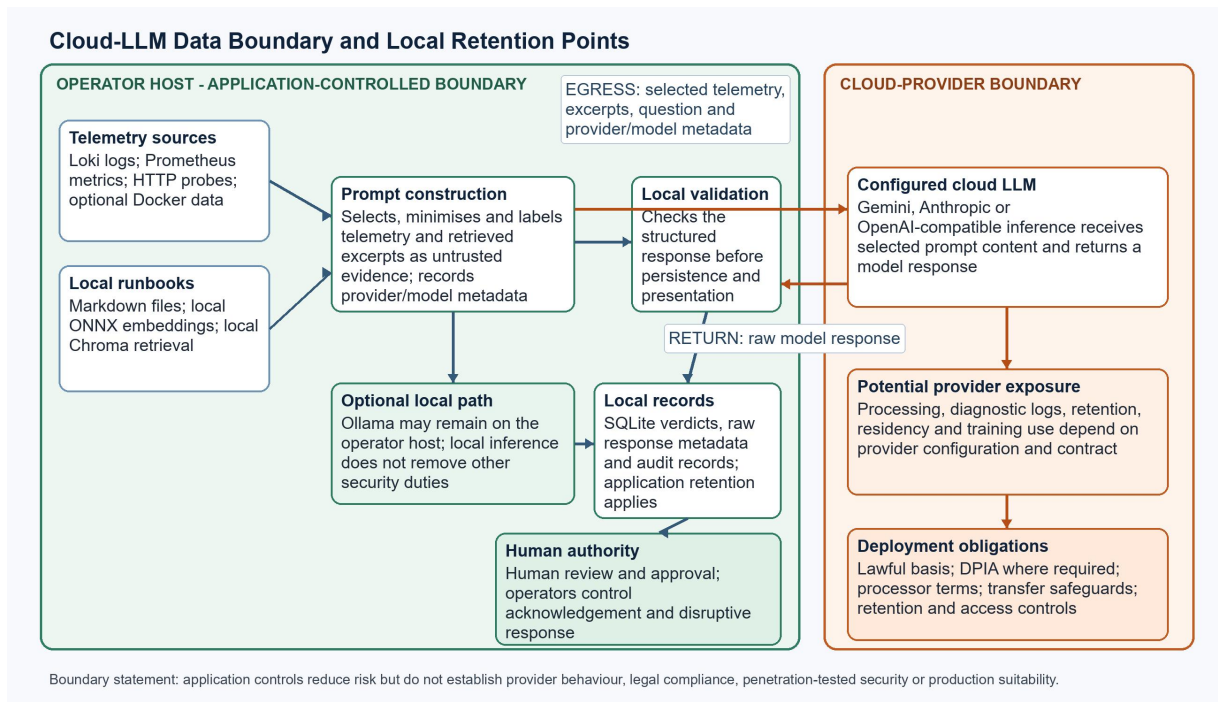


Figure 4.5: Cloud-LLM Data Boundary and Local Retention Points.

Figure 4.5 shows the application boundary rather than a guarantee of provider behaviour. It also records that local storage may retain raw response metadata and that optional ntfy notifications can create a separate external data path. Deployment review must therefore cover every configured egress, not only the LLM.

4.3.4 Security Threats Specific to LLM-Assisted Incident Triage

The LLM attack surface includes untrusted evidence, generated recommendations, persistent memory, cloud egress and model supply chains. The controls below reduce exposure but have only software-test evidence; no retained live-model red-team run, penetration test or independent security assessment was completed.

Indirect prompt injection through logs and telemetry. Attacker-controlled source text can instruct a model to ignore its rules or disclose data when the application incorporates that text into a prompt. Prompt construction labels telemetry as untrusted evidence and tests the instruction/data boundary, but resistance to injected instructions is not empirically established. Direct injection instead involves malicious instructions submitted through the model-facing interaction (National Institute of Standards and Technology, 2024).

Indirect injection through runbooks and tool output. A poisoned Markdown file or collector response can enter the prompt as retrieved evidence. Read-only mounting and fixed collectors constrain modification and tool choice, but no approved-content manifest, poisoning experiment or trust-scored retrieval is retained.

Data exfiltration through cloud prompts. Telemetry and retrieved excerpts may contain personal data or secrets. Minimisation and the local Ollama option reduce exposure; field-level DLP, provider retention verification and contractual assurance remain deployment obligations.

Model-output manipulation and unsafe action. A model can understate severity, add unsupported fields or recommend destructive commands. Post-review schema validation rejects incomplete or non-canonical verdicts, while recommendations remain advisory; actionable-safety scoring and live adversarial evaluation were not completed.

Poisoned telemetry and source authenticity. Fabricated metrics, logs or container events can distort the evidence base. The prototype records source-specific blocks but does not cryptographically authenticate upstream telemetry or establish that collected data is truthful.

Privilege escalation through integrations. The application has no generic command-execution tool and a CrowdSec ban requires authenticated operator action. Post-review validation rejects invalid, loopback, link-local, multicast and unspecified targets and rechecks a fresh server-side detection before applying a decision. A complete protected-CIDR policy is not implemented; the Docker socket remains a high-privilege interface and live rollback testing is absent.

Acknowledgement poisoning and replay. Model-generated signatures or free-text notes can corrupt future state. Post-review prompt assembly excludes operator notes and validates signature form; prompt/model binding, expiry and the high/critical safeguard remain. The 41.7% repeat-stability result means model-generated identity is still insufficiently stable for dependable acknowledgement semantics.

Model and software supply-chain drift. Mutable models, images, dependencies or provider behaviour can change risk without an application-code change. The benchmark records its model digest and source hashes, but dependency locking, signed images, SBOM evidence and equivalent provider evaluation remain future work.

Assurance boundary. The control-to-evidence distinction introduced at the start of this chapter applies to each threat above. The residual risks require separately recorded adversarial and deployment evaluation.

4.4 Challenges Encountered

Output conformance. A provider response may contain Markdown fences, surrounding prose, duplicate fields or an invalid contract. Prompt-contract version 2 fails closed: the shared parser accepts only one bounded raw JSON object with exactly the five required fields and a canonical severity/signature pairing. It rejects rather than extracts fenced or conversational JSON. Any provider or parser failure produces a high pipeline:analysis-failed:agent verdict that cannot be acknowledged.

Scope bounding and false alarms. The prompt contains explicit scope rules for optional integrations because absent evidence can otherwise be interpreted as a failure. Automated tests confirm that prompt construction includes only configured sections and the required instruction. The controlled qwen2.5:3b benchmark recorded zero escalations among the twelve healthy/no-impact response runs (C01–C03 and C21), with C23’s acknowledged-degradation runs separate, but production false-positive behaviour was not measured.

Signature stability was a principal design finding. The model can supply the condition signature used by its own acknowledgement mechanism. An unstable or incorrect signature can split one condition across fingerprints or merge different conditions. Only 10 of 24 benchmark scenarios (41.7%) produced an identical signature across all three runs. Prompt/model binding, expiry and the severity safeguard limit consequences but do not repair condition identity. For this tested configuration, model-generated identity is insufficiently stable for dependable durable acknowledgement; deterministic telemetry-derived identity is the next design to evaluate.

Security defects corrected during review. Implementation review identified two defects that were corrected: the rate limiter was configured without its middleware, and server-derived text was inserted into the dashboard without a shared escaping path. Regression tests cover the corrected behaviour. The remaining deployment and CSP limitations are recorded in Section 4.3.

Loki query semantics. An early implementation used Loki's instant-query endpoint and produced inconsistent recent-log results. The revised adapter uses a range query over an explicit window in newest-first order. This also gives the threat scanner enough log lines to evaluate its configured thresholds.

CHAPTER FIVE: TESTING, RESULTS AND EVALUATION

Software verification checks specified behaviour against requirements. Evaluation measures the artefact against the stated research criteria. Validation of operational usefulness requires evidence that the system meets intended needs in its deployment context. This chapter therefore separates software verification, controlled model and retrieval evaluation, report-level practitioner hypotheses, descriptive perceived usability, and security/governance analysis.

Objective benchmark measures are reproducible from retained response rows. The practitioner reports supply exploratory qualitative observations, while completed original item-level ratings are absent from the inspected public package. The thesis therefore omits assessor means, inter-rater statistics and adjudicated scores that cannot be recomputed from that package. Appendix F distinguishes these reports from the separate simulation-labelled development scores.

The SUS workbook retains coded item responses and formula-driven calculations for ten complete submissions from eleven consented submissions. Its results describe perceived usability within that convenience sample. Section 5.6 consolidates the construct, internal and external validity limits across the evidence streams.

5.1 Testing Strategy

Evaluation evidence is classified at five levels so software coverage is not confused with operational effectiveness:

Unit level — completed for selected parsing, provider, memory, telemetry, threat and retrieval functions.

Component/integration level — completed for FastAPI, SQLite, orchestration and adapter interactions using temporary stores and mocked external services.

System level — partially completed through the source-scoped automated suite and controlled benchmark in one development environment; external infrastructure and provider dependencies remained mocked or frozen.

Live-deployment level — limited to a researcher-observed three-question convenience pilot without retained raw answers, timings, deployment receipt or independent scoring.

Operational-field level — not completed; production resilience, security, diagnostic accuracy, task performance, workload, alert fatigue, cost and scaling remain unmeasured.

5.1.1 Automated Test Scope

Unit tests. Unit tests cover telemetry parsing, structured error returns, provider dispatch, verdict parsing, fingerprint generation, fallback-signature normalisation, deterministic threat detection and runbook helpers. The final remediation added dedicated fixtures for LangChain provider/tool/message/output and exception branches; scheduler environment, persistence, Docker-mode, interval and recovery paths; Docker API and event filtering, transport,

extraction and error paths; and ChromaDB embedding, index-build, load and similarity-search paths. External services remain mocked so the suite can run without credentials.

API and persistence. FastAPI tests exercise login, authenticated routes, rate limiting, security headers, configuration output, threat routes, verdict history, acknowledgements, and staleness reporting. Persistence tests use temporary SQLite databases to verify inserts, retention pruning, acknowledgement expiry, suppression, and removal.

Acknowledgement invariants. The memory tests check the full fingerprint rule. Identical signature, prompt-version, and model inputs must produce the same fingerprint, while changing any one of them must produce a different value. The tests also confirm that fallback signatures remove volatile tokens, active acknowledgements suppress only ok or warning verdicts, expired acknowledgements are inactive, and high or critical verdicts remain visible.

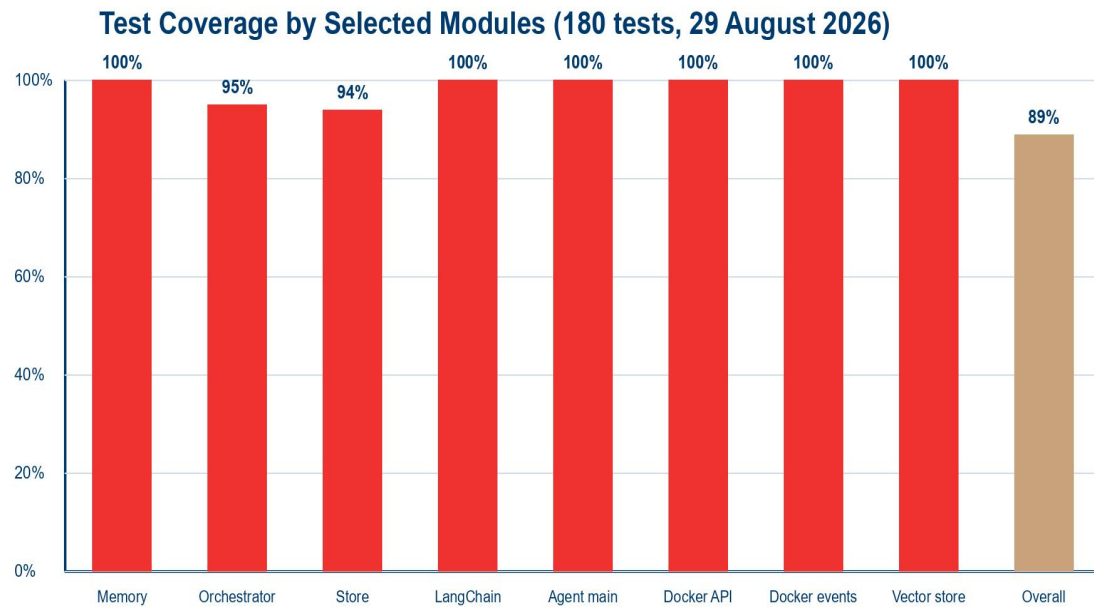
5.2 Automated Test Results

The dated 16 August 2026 baseline passed 82 tests at 66% coverage, and the 28 August remediation state passed 148 tests at 87% coverage. On 2 September 2026, the exact local working tree passed 180 source-scoped Python tests with 89% line coverage (1,655 statements; 190 missed) and emitted 45 deprecation warnings. Because that working tree contained uncommitted and untracked source and test files, including six untracked test modules, this verifies that local snapshot only; it does not show that a clean checkout or published commit reproduces the same test count or coverage. These are software-verification results, not a rerun of the frozen benchmark or a penetration test.

5.2.1 Coverage by Module

Table 5.1: Verified Software-Test Chronology and Evidence Boundaries.

Date	Activity	Test result	Coverage	Purpose and boundary
16 Aug 2026	Historical baseline	82 passed; 17 warnings	66% (1,476 statements; 508 missed)	Dated software baseline; not model or production validation.
18 Aug 2026	Frozen-benchmark regression	81 passed; 17 warnings; 27.57 s	Not retained as a comparable coverage snapshot	Confirms the benchmark-time tree passed its regression suite.
28 Aug 2026	Final source-scoped verification	148 passed; 0 failed; 23 dependency warnings	87% (1,516 statements; 201 missed); five targeted modules at 100%	Verifies exercised software paths under the current tests; mocks remain and live effectiveness is not established.
29 Aug 2026	29 August source-scoped verification	180 passed; 0 failed; 45 dependency warnings	89% (1,655 statements; 190 missed)	Verifies selected post-benchmark controls; does not alter v1 model evidence or establish adversarial security.
2 Sep 2026	Repeat local working-tree verification	180 passed; 0 failed; 45 deprecation warnings	89% (1,655 statements; 190 missed)	Confirms the recorded dirty local snapshot, including untracked tests; does not establish a clean checkout or change the frozen benchmark.



Six selected modules are at 100%; overall coverage rose from the 66% dated baseline to 89%.

Figure 5.1: Selected-Module Coverage after Post-Review Verification on 29 August 2026.

Table 5.1 separates five dated verification records, including the 2 September repeat check of the local working tree. Figure 5.1 retains the selected-module result recorded on 29 August: six modules at 100%, the orchestrator at 95%, the store at 94%, and overall source-scoped coverage of 89% across 180 tests. These records concern asserted software paths, while the frozen model benchmark retains its original date and configuration.

5.2.2 Representative Test Cases

Table 5.2: Representative Automated Test Cases and Results.

ID	Scenario	Expected Outcome	Result
TC-01	Loki range query returns multiple streams	Recent lines are parsed in newest-first order	Pass
TC-02	Prometheus collection	Configured metric keys are returned	Pass
TC-03	HTTP probe	Status and latency are recorded for each URL	Pass
TC-04	Critical verdict routing	Notification path is selected	Pass
TC-05	OK verdict routing	Notification path is skipped	Pass
TC-06	Fingerprint stability	Identical inputs yield the same fingerprint	Pass
TC-07	Fingerprint mismatch	Signature, prompt, or model change yields a different fingerprint	Pass
TC-08	Severity safeguard	High and critical verdicts cannot be masked from visibility	Pass
TC-09	Warning acknowledgement	Matching warning is acknowledged and masked from the default view; record retained	Pass
TC-10	Expired acknowledgement	Expired row is not active	Pass
TC-11	Critical acknowledgement request	API returns HTTP 409	Pass
TC-12	Retention pruning	Rows outside the window are removed on insert	Pass

ID	Scenario	Expected Outcome	Result
TC-13	HTTP brute-force fixture	Threshold crossing produces a threat record	Pass
TC-14	Login rate limit	Sixth rapid failed attempt returns HTTP 429	Pass
TC-15	Stale verdict	Old verdict is reported as stale	Pass
TC-16	Configuration response	Only integration booleans are returned	Pass
TC-17	LangChain multi-tool agent branches	Provider, tool-call, message-flow, output-shape, parsing and exception paths return a verdict or bounded error	Pass
TC-18	Scheduled agent entry point	Environment loading, persistence fallback, Docker modes, intervals, cycle recovery and module entry are exercised	Pass
TC-19	Docker API diagnostics	Disabled, client, found/not-found, extraction, API-error and resource-close paths are exercised	Pass
TC-20	Docker event collection	Filtering, Unix/TCP transports, streamed or malformed JSON, event limits and error paths are exercised	Pass
TC-21	ChromaDB vector-store operations	Embedding, index build/load and similarity-search success, empty-state and exception paths are exercised	Pass
TC-22	Malformed, fenced, duplicate, missing or extra verdict fields	The v2 parser rejects the response and the orchestrator records a non-acknowledgeable high pipeline failure	Pass
TC-23	Instruction-like telemetry, runbook text or acknowledgement note	Untrusted data is explicitly bounded; operator notes are omitted and identifiers cannot lower severity	Pass
TC-24	Stale or fabricated CrowdSec threat selection	The API freshly re-detects Loki evidence and applies only an exact server-derived type/IP match; otherwise HTTP 409	Pass

5.3 Acknowledgement-Memory Evaluation

Acknowledgement changes how repeated low-risk verdicts are presented. Figure 5.2 is a deterministic 30-cycle illustration, not an observed field experiment. The same warning fingerprint is stored on every cycle. If an operator acknowledges after cycle 3, the next 27 model calls and verdict records still occur, but matching warnings are hidden from the default view; the visible cumulative count remains 3. TC-08 and TC-09 test the underlying rules.

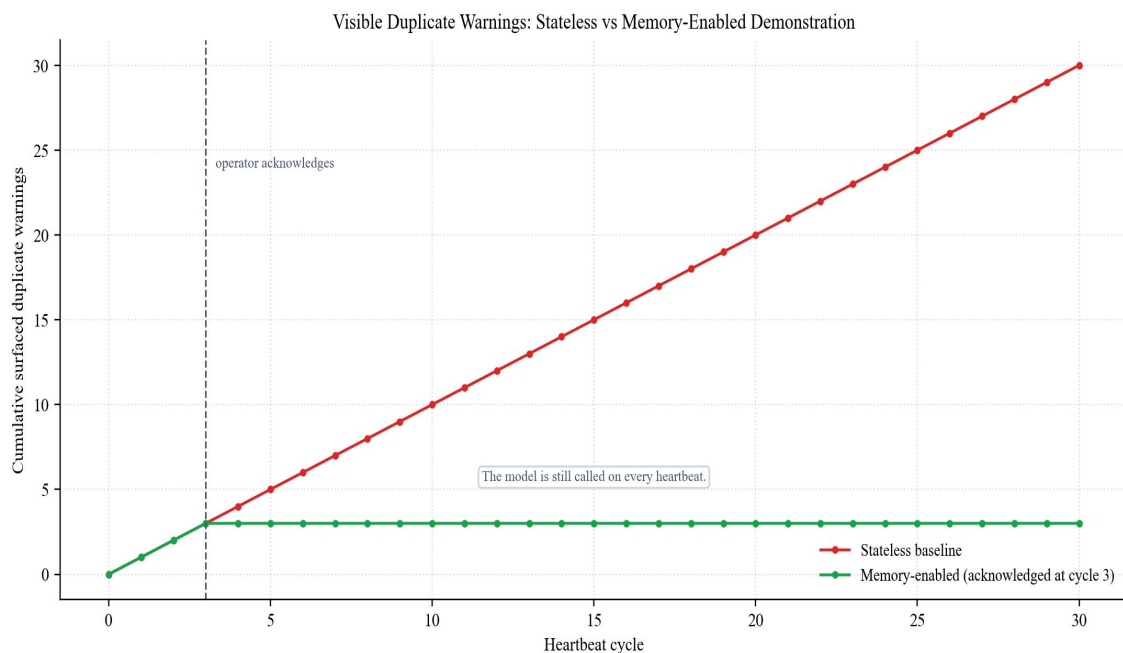


Figure 5.2: Deterministic 30-Cycle Illustration of Default-View Duplicate Presentation.

This result supports a narrow conclusion: the feature reduces repeated operator-facing warnings in the default dashboard view. It does not reduce the number of model calls, the number of stored heartbeat results, or inference cost.

5.4 Limited Researcher-Observed Functional Verification

5.4.1 Runbook Retrieval Convenience Pilot

On 16 August 2026, the researcher recorded a convenience pilot in which the dashboard re-indexed twenty local Markdown runbooks and used DeepSeek V4 Flash through the OpenAI-compatible LangChain path for three illustrative questions on disk capacity, memory pressure and Loki ingestion. The session suggests that loading, local embedding, retrieval, provider invocation and dashboard rendering could be exercised together, but no raw answers, screenshots, timings, token records, deployment receipt, independent score or no-RAG baseline were retained. Figure 5.3 records an intended five-case workflow rather than executed task-performance results; the later Appendix E benchmark supplies the controlled local-model baseline.

Table 5.3: Live Runbook-Retrieval Pilot Configuration.

Configuration Item	Recorded Value
Date	16 August 2026
Provider interface	OpenAI-compatible LangChain path
Model used	DeepSeek V4 Flash
Default configured model	gemini-3.6-flash through the Gemini Developer API
Embedding model	Local ONNX all-MiniLM-L6-v2
Retrieval depth	Four whole runbook documents
Runbook corpus	Twenty local Markdown files
Questions	Three illustrative questions: disk capacity, memory pressure and Loki ingestion
Heartbeat state	Agent intentionally stopped during the session
Evaluation boundary	No independent score, no baseline, no repeated trials, and no latency, token or cost record

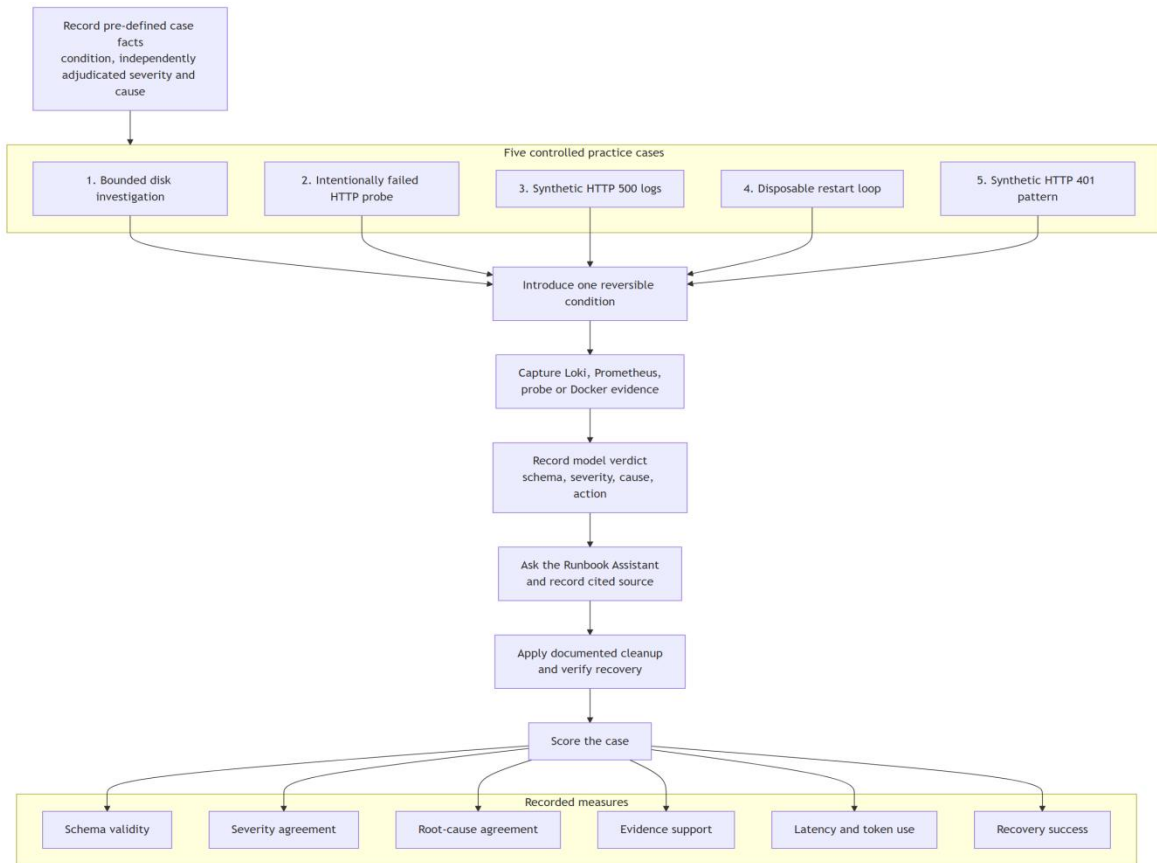


Figure 5.3: Proposed Five-Case Practitioner Usability Workflow.

5.4.2 Controlled Local-Model Incident and RAG Benchmark

The frozen Appendix E protocol was executed on 18 August 2026 for one local qwen2.5:3b configuration: 24 purposive synthetic scenarios were each run three times, producing 72 scenario-run observations. The separate RAG/no-RAG experiment retained 72 generations across twelve questions. Objective metrics derive from those retained rows. Later software hardening did not rerun or overwrite the historical benchmark.

The retained benchmark used prompt version 1. The subsequent implementation uses prompt-contract version 2 and was not model-benchmarked again; the frozen results therefore do not measure the revised prompt contract.

5.4.2.1 Fixed Configuration and Evidence Retention

The provider, model, prompt, retrieval depth, gold labels and repetition count were fixed before execution. The model ran locally, so no cloud prompt transfer or metered provider charge occurred. Energy consumption and hardware depreciation were not instrumented and are excluded from the cost statement. The 16 August 82-test/66% verification and the benchmark-time 81-test regression remain dated audit points. The later 28 August remediation run passed 148 tests with 87% coverage; it strengthened software verification but did not alter or rerun the frozen model benchmark.

Table 5.4: Controlled Benchmark Configuration and Provenance.

Item	Recorded value
Runtime and model	Ollama 0.30.11; qwen2.5:3b; 3.1B; Q4_K_M
Model digest	357c53fb659c5076de1d65ccb0b397446227b71a42be9d1603d46168015c9e4b
Sampling and repetitions	Temperature 0.0; three repetitions for every case
Incident set	24 frozen scenarios; 72 generated responses
RAG comparison	12 labelled questions; top-four retrieval; 36 RAG and 36 no-RAG responses
Benchmark specification	Version 1.0.0; SHA-256 7936721040238a95c57d51ec6fa86b9ee104b6b4021df83efdf903604ab58fee
Evidence retained	Raw and parsed responses, timestamps, latency, token counts, retrieval ranks, objective scores and source snapshot hashes
Cost boundary	Local metered API cost: US\$0.00; energy and hardware costs not measured

5.4.2.2 Validity of Benchmark Gold Labels

The researcher constructed 24 purposive synthetic scenarios and assigned one primary severity label to each before execution using the operational definitions in Table E.1. Each scenario was then repeated three times. C20 retains warning as its frozen primary label, with alternative handling reported only as post hoc sensitivity analysis; C23 retains the disclosed historical acknowledgement-conditioned v1 exception. These choices define the operational policy against which exact agreement is calculated.

No independent expert or SRE adjudication of the primary labels was performed or retained. The 40.3% result therefore measures exact agreement with the researcher-defined severity policy, not diagnostic accuracy against objectively verified incident truth. This limits internal and external interpretation. A subsequent benchmark should obtain independent SRE ratings, report agreement and reconciliation, freeze the adjudicated labels before model execution and preserve the original item-level decisions.

5.4.2.3 Objective Incident Results

Schema conformance was perfect in this run, but exact agreement with the researcher-defined severity policy was limited; real-world diagnostic accuracy was not measured. Table 5.5 reports the automatically verifiable aggregate metrics. Table 5.6 exposes class-level errors that would be hidden by schema validity alone.

Table 5.5: Objective Incident-Benchmark Results.

Metric	Result	Interpretation boundary
Schema-valid output	72/72 (100%)	All responses parsed to the required verdict structure.
Exact researcher-label agreement	29/72 (40.3%)	Agreement with the researcher-defined primary labels, not independently adjudicated truth. C20 sensitivity is unchanged; excluding C20 gives 29/69 (42.0%) only as a post hoc check.

Metric	Result	Interpretation boundary
Macro precision / recall / F1	0.325 / 0.583 / 0.383	Average performance across the four severity classes.
Healthy/no-impact false positives	0/12	No escalation among 12 runs of C01–C03/C21. C23 is acknowledged degradation and is reported separately.
High/critical-to-below-high run-level under-calls	6 (C15 and C17, each repeated three times)	All six were high-to-warning repeated outputs across two synthetic scenario families; no critical-labelled response was under-called.
Signature format	72/72 (100%)	Every parsed response included the required signature form.
Repeat-stable signatures	10/24 scenarios (41.7%)	Only ten scenarios returned one identical signature across all three runs.
Latency	p50 9.93 s; p95 14.53 s	Local runtime under the recorded benchmark environment.
Mean tokens	823.9 input; 136.2 output	Counts reported by the local runtime.
Metered API cost	US\$0.00	Energy and hardware costs were not measured.

The confusion matrix shows asymmetric severity-policy disagreement. Warning recall was 0%. Exact high-class recall was 8/24 (33.3%): ten other high-labelled responses were escalated to critical, while six were predicted warning. Across the combined high/critical-labelled group, 24/30 responses remained high or critical and 6/30 (20.0%) fell below high. All six under-calls came from C15 and C17, each repeated three times; no critical-labelled response was under-called. These are repeated runs from two synthetic scenarios, not six independent incidents.

The 40.3% aggregate is exact agreement with the frozen researcher-defined severity policy. Under-calls may delay urgent review, whereas over-calls may increase review burden; these are plausible consequences, not measured operator outcomes. The 80.0% combined high/critical recall is a descriptive threshold calculation from the same runs. The acknowledgement safeguard acts on predicted severity: it preserves verdicts labelled high or critical but cannot independently recognise a serious condition misclassified as warning. This design inference is not an observed suppression event in the benchmark. Probability calibration was not measured. That frozen policy includes C23's historical acknowledgement-conditioned ok label; Appendix E.2 explains why it differs from the current telemetry-only severity rule.

Gold-label sensitivity. The primary score retains the frozen warning label for C20. Its narrative could also support ok after one transient HTTP 500 followed by normal telemetry; however, all three qwen2.5:3b predictions were critical, so an acceptable set of {ok, warning} leaves the primary 29/72 result unchanged. Excluding C20 yields 29/69 (42.0%) only as a post hoc sensitivity result and does not replace the primary metric. The purposive synthetic set contains 15 ok, 27 warning, 24 high and 6 critical runs and is not an estimate of production prevalence.

Table 5.6: Severity Confusion Matrix for 72 Incident Responses.

Gold \ predicted	ok	warning	high	critical	Recall
ok	15	0	0	0	100.0%
warning	12	0	9	6	0.0%
high	0	6	8	10	33.3%
critical	0	0	0	6	100.0%

Gold \ predicted	ok	warning	high	critical	Recall
Precision	55.6%	0.0%	47.1%	27.3%	—

These results reject any inference that structured JSON alone makes the selected model diagnostically reliable. They apply only to the recorded qwen2.5:3b model, prompt, fixtures and local runtime; they do not establish the performance of Gemini, Anthropic, DeepSeek, other OpenAI-compatible models, larger Qwen variants, or qwen2.5:3b under different quantisation or prompting.

5.4.2.4 RAG Retrieval and Runtime Results

The labelled RAG set covered twelve operational questions. The implemented application retrieval path placed at least one frozen relevant runbook in the top four for all twelve questions. All retained RAG and no-RAG generations completed. Table 5.7 reports retrieval and runtime observations without treating them as human-rated answer quality.

Table 5.7: Objective RAG and No-RAG Benchmark Results.

Metric	RAG	No-RAG	Boundary
Generation requests	36/36 successful	36/36 successful	Three runs per question and condition
Top-four retrieval success	12/12 questions (100%)	Not applicable	Retrieval relevance, not answer correctness
Latency p50	10.07 s	9.91 s	Recorded local wall-clock time
Latency p95	35.65 s	24.49 s	RAG tail latency was higher
Mean prompt tokens	1510.0	66.25	RAG included retrieved excerpts
Mean completion tokens	130.4	180.5	Runtime-reported counts
Metered API cost	US\$0.00	US\$0.00	Energy and hardware costs excluded

The retrieval result establishes that a frozen relevant runbook was reachable in the top four for 12/12 questions. Completed item-level answer-quality ratings are absent from the public package, so grounding, correctness and safety remain quantitatively unresolved. The no-RAG condition supplied no sources; this is a difference in the evaluation protocol, not a grounding score or a measured causal RAG effect.

5.4.2.5 Practitioner Incident Evidence Status

Table 5.8 distinguishes the retained practitioner reports from the availability of original item-level ratings. The unchanged reports and hashes are inspectable as exploratory qualitative sources. Assessor means and agreement coefficients cannot be independently recomputed from the public worksheets and are not reported as quantitative findings.

Table 5.8: Practitioner Role-Report Evidence Status and Permitted Use.

Evidence component	Retained record	Recomputability	Permitted thesis use
Role-package metadata	Role reports and seed/correction records	Metadata inspectable; independent completion and blinding are not independently verifiable	Researcher-reported context only
DevOps and SRE role reports	Unchanged DOCX files and SHA-256 hashes	Report text inspectable	Qualitative engineering hypotheses only
Completed original per-item assessor files	Not present; public A/B templates are blank	Not recomputable	No human score, mean, agreement or ranking claim
Candidate score transcriptions	Hash-match explicitly AI-simulated JSON files	Not admissible as human evidence	Excluded from findings; no adjudication result

The role reports discuss recurring themes, including confusion between symptoms and causes, premature disruptive action, weak treatment of sustained degradation and unstable condition identity. These are retained as qualitative hypotheses for future testing. No category-level human score or inter-assessor agreement is claimed.

5.4.2.6 RAG Evidence Dimensions and Unresolved Outcomes

Table 5.9 separates retrieval relevance, grounding, answer correctness and actionable safety. Top-four retrieval is objectively recomputable. Completed original item-level answer-quality ratings are absent from the public package, leaving the other dimensions quantitatively unresolved.

Table 5.9: RAG Evaluation Dimensions, Evidence Status, and Supported Conclusions.

Dimension	Objective retained evidence	Human-evidence status	Supported conclusion
Retrieval relevance	Relevant runbook in top four for 12/12 labelled questions	No human rating required for the source-in-top-k measure	Retrievability under the frozen corpus and top-four setting
Grounding / traceability	RAG had supplied sources; no-RAG had none	Completed original grounding ratings absent from the public package	Source availability is documented; no quantitative grounding or causal effect is inferred.
Answer correctness	All 36 RAG and 36 no-RAG generations retained	Completed original correctness ratings absent from the public package	Answer correctness remains quantitatively unresolved.
Actionable safety	No dedicated safety instrument or retained item scores	Not evaluated	No claim of safe operational action or general RAG effectiveness.

The qualitative role-report themes identify issues for future testing but do not establish the direction or magnitude of a RAG effect. The no-RAG condition's lack of supplied sources must not be treated as causal evidence.

5.4.2.7 Practitioner Role-Report Hypotheses

The retained role reports describe engineering hypotheses about severity-policy alignment, evidence preservation, diagnostic checks, safe sequencing and signature identity. Table 5.10 preserves these themes for future testing without treating them as confirmed observations, population estimates or ranked human findings. Its P0–P2 labels are proposed engineering priorities, not measured assessor rankings.

Table 5.10: Practitioner Role-Report Engineering Hypotheses for Future Testing.

Priority	Role-report theme	Engineering response
P0	Severity-policy alignment was a reported concern for sustained resource pressure, recovered failures and partial telemetry loss.	Add deterministic severity guards, targeted regression cases and explicit escalation thresholds.
P0	Some recommendations jumped to restart, rollback, cleanup or threshold changes before diagnosis.	Enforce observe, isolate, preserve evidence, make the smallest safe change and verify.
P0	Security guidance could omit source validation, administrative-access protection and rollback planning.	Require validated source context, human approval, protected access paths, dry run and rollback.
P1	Broad hypotheses sometimes replaced a discriminating diagnostic check.	Require a next evidence check and explicit uncertainty whenever root cause is not established.
P1	Incorrect or unstable signatures could misroute acknowledgement and operator attention.	Derive and validate fingerprints deterministically and regression-test signature stability.
P1	The role reports discussed supplied runbooks, traceability and omitted safety boundaries; direction and magnitude are unresolved.	Retain citations, add abstention and grounding checks, and encode protected operational steps.
P2	Candidate scenarios and questions highlighted in the role reports warrant focused subsequent evaluation.	Rerun C04, C06, C17, C18, C20 and R03, R04, R06, R11, R12 after remediation; use a larger independent human panel.

5.4.3 Descriptive Exploratory System Usability Scale Assessment

A separate System Usability Scale survey received eleven consented submissions from human operations practitioners between 22 and 26 August 2026. Inclusion required consent and valid responses to all ten SUS items. P9 was excluded because Question 3 was blank; no value was imputed or reconstructed. The analysed sample therefore contains ten complete responses: five DevOps/DevSecOps practitioners and five SRE practitioners. Participant codes are coded survey identifiers rather than role labels. According to the researcher's provenance confirmation, all included submissions were completed by human practitioners; identity and contact records supplied to the supervisor remain outside the public repository.

Using the standard SUS calculation, the ten complete responses produced a mean of 79.25, a median of 83.75, a sample standard deviation of 18.18, and a range from 40.0 to 97.5. The completion rate was 90.9%. The DevOps/DevSecOps subgroup mean was 87.0 and the SRE

subgroup mean was 71.5; these subgroup values are descriptive only and are not tested as a role difference.

Table 5.11: Descriptive Exploratory System Usability Scale Results.

Metric	Result	Interpretation boundary
Consented submissions	11	Distinct consented survey submissions
Complete responses analysed	10	All ten SUS items present
Incomplete responses excluded	1	P9; Question 3 blank; no imputation
Completion rate	90.9%	Complete responses divided by consented submissions
Survey date range	22-26 August 2026	Dates retained in the source export
Role distribution	5 DevOps/DevSecOps; 5 SRE	Balanced complete sample
Mean SUS score	79.25	Descriptive small-sample result
Median SUS score	83.75	Descriptive small-sample result
Sample standard deviation	18.18	Variation across ten complete responses
Observed range	40.0-97.5	Minimum and maximum included scores

The descriptive result indicates favourable perceived usability within this exploratory convenience sample of ten complete respondents. The formula-driven workbook retains a raw-response copy, but the named source export and asserted source-file hash were not present in the repository; identity/contact mapping remains external. The sample does not establish population usability, reduced workload, task completion, fewer errors, diagnostic correctness or production effectiveness.

5.5 Evaluation Against the Objectives

Table 5.12: Objective and Evidence Matrix.

Obj.	Objective	Evidence and Qualification	Status
RO1	Derive, document and analyse functional, non-functional and governance requirements from the operational problem, literature, standards and repository constraints.	Functional, non-functional, security, data-governance and operational requirements are documented and linked to the design.	Achieved
RO2	Multi-source telemetry and bounded reasoning architecture.	Telemetry adapters, graph orchestration, provider dispatch, parsing and routing are implemented and tested. A 72-response controlled local-model benchmark measured severity behaviour, but production diagnostic accuracy was not evaluated.	Achieved for implementation; effectiveness limited
RO3	Local RAG and operational assistance.	The frozen relevant runbook appeared in the top four for 12/12 questions. Grounding, correctness and actionable safety were not established quantitatively.	Implemented; objective retrievability reported; answer-quality and safety outcomes unresolved
RO4	Human oversight, acknowledgement and threat response.	Fingerprint, expiry, default-view masking, removal and severity safeguards are tested. Threat detection is deterministic and a ban requires operator approval.	Achieved for implemented behaviour

Obj.	Objective	Evidence and Qualification	Status
RO5	Verification and evaluation boundary.	RQ4a: dated 180-test local verification. RQ4b: frozen qwen2.5:3b incident/retrieval benchmark. RQ4c: ten complete SUS responses from eleven submissions. Practitioner reports supply exploratory qualitative context. Cross-model, task, workload, scaling and production outcomes remain unmeasured.	Achieved for implementation and bounded descriptive evidence; operational validation unresolved

5.6 Discussion and Threats to Validity

5.6.1 Supported Findings

The 2 September local working tree passed 180 source-scoped tests at 89% line coverage across selected API, storage, orchestration, telemetry, provider-dispatch, validation and acknowledgement paths. This is a local verification receipt, not a clean published-release result. The frozen qwen2.5:3b v1 benchmark separately recorded 100% schema validity, 40.3% researcher-label agreement, macro-F1 0.383 and six high-to-warning under-calls across two repeated scenario families.

The principal architectural finding is the dependence of durable acknowledgement on stable condition identity. Only 10/24 scenarios (41.7%) produced identical signatures across three runs. The current implementation is therefore a prototype acknowledgement mechanism rather than a validated durable-condition identity mechanism. Deterministic telemetry-derived identity should be evaluated before extending durable suppression. Separately, 12/12 top-four retrieval demonstrates frozen-corpus retrievability, not answer correctness or a causal RAG benefit; the SUS mean of 79.25 describes favourable perceived usability within the exploratory convenience sample of ten complete responses. Table 5.13 distinguishes provider-interface support from actual model evidence.

Table 5.13: Provider and Model Interface versus Empirical Evidence Status.

Provider / model	Interface and software-test status	Retained empirical evidence	Permitted claim
Gemini (configured default label: gemini-3.6-flash)	Interface implemented; mocked/path tests	No controlled model evaluation	Portability path only; no performance claim
Anthropic	Interface implemented; mocked/path tests	No controlled model evaluation	Portability path only; no performance claim
OpenAI-compatible	Interface implemented; mocked/path tests	DeepSeek V4 Flash convenience pilot lacked raw reproducibility package	Pilot feasibility only; no controlled comparison
Ollama qwen2.5:3b	Local interface implemented and tested	Frozen v1 benchmark with raw rows, model digest and source hashes	Configuration-specific controlled results only
Other Ollama models	Configurable interface; mocked/path tests	No controlled retained evaluation	Interface support is not model equivalence

Table 5.13 records the provider-interface evidence boundary. Later security hardening changed the current source tree but did not transfer the frozen qwen2.5:3b result to other providers or to the revised code.

5.6.2 Limitations

The benchmark used 24 purposive synthetic scenarios, three repeated runs per scenario and one local 3.1B quantised model. Its 72 responses are nested repetitions rather than independent production incidents. The researcher assigned the primary severity labels without independent expert adjudication, so severity agreement measures correspondence with that operational policy. Two practitioner reports are retained, but their item-level scores cannot be recomputed from the inspected public package. SUS covers ten complete convenience responses from eleven consented submissions and lacks task timing, errors or workload measurements. Mocked dependencies and software coverage do not establish live resilience or adversarial security.

Practitioner-role-report boundary.

The two reports supply exploratory hypotheses, with their provenance and permitted use consolidated in Section 3.1.4 and Appendix F. Public recomputability of original item-level ratings remains distinct from researcher-reported human participation.

Signature stability and circularity.

Signature truth and stability remain unresolved. The safeguards constrain reuse of an acknowledgement, but do not correct a serious condition labelled warning. This limitation motivates the identity redesign in Section 6.4.3.

5.6.3 Validity

Construct validity is strongest for directly asserted software behaviour and objective benchmark measures such as parsing, researcher-defined label agreement, retrieval rank, latency and tokens. The role reports supply qualitative hypotheses only; SUS measures perceived usability rather than task effectiveness. Internal validity is supported by frozen prompts, labels, repetitions and hashes but constrained by the lack of independent gold-label review. External validity is restricted to the purposive fixtures, frozen corpus, qwen2.5:3b build, one host and ten complete convenience-sample SUS responses.

CHAPTER SIX: SUMMARY, CONCLUSION AND RECOMMENDATIONS

6.1 Summary of the Project

InfraGuard AI addresses the gap between collecting operational telemetry and interpreting it through an operator-hosted incident-triage prototype. It combines a scheduled agent, FastAPI service, dashboard, SQLite store, local runbook retrieval and operator-approved threat response.

A shared dispatch interface supports local and cloud inference paths. The provider-interface and evaluated-model distinction is recorded in Table 5.13; support for an interface does not demonstrate equivalent model behaviour.

Acknowledgement changes the default presentation of eligible stored verdicts while inference and storage continue. The implemented key binds the normalised signature, prompt version and model name. Its value depends on the stability of those inputs; the observed signature weakness prevents a claim of dependable condition identity.

The evaluation separates implemented software behaviour from model behaviour and exploratory usability. Its principal discovery is that a structurally valid response can still disagree with the severity policy, while persistence cannot compensate for unstable model-generated identity. Chapter Five records the dated results and their denominators.

6.2 Conclusion

InfraGuard AI implements a governance-by-design reference framework for bounded LLM-assisted incident triage. It connects telemetry, local runbook retrieval, structured verdicts, acknowledgement memory and operator-approved action through an inspectable architecture.

The local tests support selected implementation paths. The frozen model results expose severity-policy disagreement and signature instability, while the retrieval and SUS results answer narrower questions about source reachability and perceived usability. These findings support inspectability and retained human authority, rather than unattended diagnosis.

The resulting contribution is a bounded reference framework, its implemented acknowledgement construct and a testable identity-redesign direction. Evidence remains limited to one frozen model configuration, purposive synthetic scenarios and an exploratory convenience sample. Independent diagnostic, answer-quality, security and operational-effectiveness evaluation remains outside the completed study.

6.2.1 Answers to the Research Questions

RQ1. Selected adapters and prompt assembly represent available telemetry as an explicit bounded context, while strict parsing normalises the reviewable verdict. Software tests verify the path; live diagnostic accuracy is not established.

RQ2. The two-process architecture combines configurable provider calls, local runbook retrieval, response validation, authenticated presentation, provider/model traceability and operator-approved action. Cloud prompts still cross the host boundary.

RQ3. Fingerprint, expiry, mismatch and severity-rule tests verify masking for eligible acknowledged verdicts and continued visibility for verdicts labelled high or critical. They do not establish that model signatures capture every materially changed condition. The 41.7% repeat stability leaves dependable identity unresolved.

RQ4a. The 180-test local working-tree suite at 89% line coverage verifies selected implementation paths, including verdict handling, persistence and acknowledgement safeguards. The receipt does not identify a clean published commit or tagged release, and exact dependency-lock and container-image identifiers were not retained for that execution. It is therefore not an exact clean-snapshot or field-effectiveness result; Appendix E.7 separately identifies the frozen v1 benchmark supplement and its narrower reproducibility boundary.

RQ4b. The frozen qwen2.5:3b benchmark identifies limited severity agreement, six high-to-warning under-calls across two repeated scenario families, and unstable condition signatures. Its 12/12 top-four retrieval result concerns the frozen corpus; causal RAG effects on correctness and safety remain unmeasured.

RQ4c. Ten complete SUS responses from eleven consented submissions produced a descriptive mean of 79.25. The result indicates favourable perceived usability within that convenience sample, while population usability, workload and task performance remain unresolved.

RQ5. The reference architecture implements bounded and labelled input paths, structural output validation, access controls, local audit records, retention, provider/model traceability and operator-approved action. Source inspection and selected functional tests support these security controls. They establish controls implemented, not that the system is secured. Independent penetration testing, adversarial prompt-injection testing, live privilege-escalation testing, container-escape testing and formal security audit were not completed (Section 4.3).

6.3 Research and Professional Contributions

Design-science contribution — governance-by-design reference framework.

The design-science contribution is a governance-by-design reference framework that separates selected telemetry evidence, model inference, structural validation, persistent operator state and operational action. Its acknowledgement construct binds condition identity to a manually maintained prompt version and active model name. A separate application rule preserves verdicts labelled high or critical; because it uses predicted severity, it cannot independently identify a serious condition misclassified as warning. Table 2.3 supports a scoped combination-level distinction, not universal novelty.

Engineering contribution — inspectable reference implementation.

The engineering contribution is an inspectable single-host reference implementation connecting telemetry adapters, a provider-independent LLM interface, LangGraph orchestration, persistence, an authenticated API, a dashboard, automated tests and a versioned benchmark package. The retained raw benchmark and configuration records support later comparisons while preserving the original observations.

Empirical contribution and documented limits.

The empirical contribution is configuration-specific evidence that structural compliance did not establish reliable agreement with the researcher-defined severity policy and that model-generated identity was repeat-stable in only 10 of 24 scenarios. The retrieval baseline, C20 sensitivity analysis and descriptive SUS results answer separate questions. Together they make the next design and evaluation needs explicit, without establishing production effectiveness.

Table 6.1 connects the problem and research questions to the design principles, artefact evidence and resulting contribution. Tables 6.2 and 6.3 then state the final evidence-claim boundary and distinguish the principal contribution from its limitations. Tables 3.1 and 3.5 retain the detailed method and requirement mappings.

Table 6.1: Research Contribution Map.

Problem and gap	RQ and principle	Artefact and evidence	Finding and contribution
Fragmented telemetry and unsupported inference	RQ1/RQ2/RQ4a–b; bounded and inspectable processing	Adapters, prompts and parser; Tables 3.5 and 5.5	Schema validity coexists with policy disagreement; reference design
Retrieval mistaken for correct advice	RQ2/RQ4b; separate source and answer assessment	Local runbooks; Sections 5.4.2.4 and 5.4.2.6	12/12 top-four question retrieval; answer quality unresolved
Recurring conditions lack dependable identity	RQ3; bind state to condition and ruleset	Memory/store and signature benchmark; Section 4.4	10/24 stable scenarios; empirical identity weakness
Oversight mistaken for demonstrated task benefit	RQ2/RQ4c; retain authority and separate usability	Approval path and SUS; Section 5.4.3	SUS 79.25 for 10 complete responses; perceived usability only
Local hosting mistaken for governance assurance	RQ5; expose data, authority and assurance boundaries	Section 4.3 controls and Table 3.5	Inspectable implementation; independent assurance remains open

The following tables make the defensible claim boundary explicit for examination and archival use.

Table 6.2: Evidence-Claim Boundary.

Claim	Evidence	Supported boundary
System architecture was implemented	Source inspection and local software tests	Strong at the software level
Structured verdict contract works	72/72 schema-valid benchmark responses	Structural conformance only
Severity diagnosis is reliable	29/72 (40.3%) researcher-label agreement	Not established
RAG retrieves relevant runbooks	12/12 questions with a relevant runbook in the top four	Strong within the frozen corpus
RAG improves answer correctness	No independent retained answer-quality scoring	Not established
Acknowledgement works as designed	Automated tests and deterministic presentation illustration	Implemented behaviour; no workload or cost claim
Model-generated identity is stable	10/24 scenarios repeat-stable	Not established
Interface is perceived as usable	SUS mean 79.25; n = 10 complete responses	Descriptively supported in the exploratory sample
System reduces workload	No workload or task-performance study	Not established
System is production secure or effective	No independent adversarial assessment or field evaluation	Not established

Table 6.3: Principal Contribution and Limitations.

Dimension	Principal contribution	Limitation
Framework	Governance-by-design reference framework with explicit evidence, data and action boundaries	No universal uniqueness or comparative-superiority claim
Artefact	Inspectable operator-hosted single-host implementation	No production, fleet-scale or resilience validation
Acknowledgement	Condition, prompt-version and model binding with a predicted-severity safeguard	Model-generated identity was stable in only 10/24 scenarios
Evaluation	Transparent software, model, retrieval and descriptive SUS evidence streams	One model, nested synthetic runs, researcher labels and n = 10 SUS
Governance and security	Implemented access, provenance, validation and operator-approval controls	No independent security, compliance or operational-effectiveness assurance

6.4 Recommendations for Future Work

6.4.1 Evaluation

1. A subsequent benchmark should use independent expert review of scenarios and severity labels, report agreement before reconciliation, and freeze adjudicated labels before model testing. Retain original item-level assessor files before transformation and document any reconciliation. Compare stronger local and selected cloud models using recorded model/prompt versions, latency, tokens, monetary cost and local resource use. Version every benchmark change.

2. Repeat the usability evaluation with a larger relevant practitioner sample and retain de-identified task success, completion time, errors, assistance, free-text comments and item-level SUS responses in the approved research record. Compare results by role only with an adequately powered design, and record interface changes resulting from the findings before making broader usability claims.
3. Run a longer field evaluation to measure operator-facing duplicate presentation, acknowledgement errors, and the effect of signature changes. Do not use default-view masking as a proxy for reduced inference cost or workload.

6.4.2 Test and Security Coverage

1. Maintain 100% line coverage for the selected modules that reached that level: the LangChain agent, vector store, Docker API and event paths, and agent/main.py. Progressively improve overall source-scoped coverage beyond the recorded 89%. Retain regression checks and extend verification through controlled integration tests against disposable Docker, telemetry and ChromaDB services. Add checks for missing benchmark runs, parse errors, changed gold labels and incomplete provenance, while keeping software and model-quality evidence distinct.
2. Place the API behind an HTTPS reverse proxy, publish only the HTTPS port, restrict Prometheus, Loki, and administration ports to trusted networks, set secure cookies, and move credentials to a managed secret store.
3. Replace inline dashboard scripts and styles so the content-security policy no longer requires unsafe-inline. Send audit events to a protected external store if tamper evidence is required.

Conduct independent penetration testing, adversarial prompt-injection testing, live privilege-escalation testing, container-escape testing and a formal security audit before making production-security or compliance claims.

6.4.3 Architecture

1. Evaluate deterministic telemetry-derived condition identity before model inference as the next architectural development. Compare its stability and collision behaviour with model-generated signatures while preserving prompt/model binding, expiry and independent severity/freshness checks. Any later attempt to bypass inference for acknowledged conditions requires a separate safety evaluation.
2. Harden the locally hosted Ollama path where data-control requirements prohibit cloud inference. The qwen2.5:3b result establishes a reproducible baseline but not an acceptable diagnostic model; compare larger local models and constrained cloud alternatives for quality, response time, memory, energy and monetary cost before operational selection.

3. Treat autonomous remediation and multi-host operation as separate projects with their own threat models, approval policies, rollback mechanisms, and evaluations.

REFERENCES

- Ahmed, T., Ghosh, S., Bansal, C., Zimmermann, T., Zhang, X., & Rajmohan, S. (2023). Recommending root-cause and mitigation steps for cloud incidents using large language models. In *2023 IEEE/ACM 45th International Conference on Software Engineering (ICSE)* (pp. 1737–1749). IEEE.
<https://doi.org/10.1109/ICSE48619.2023.00149>
- Amershi, S., Weld, D., Vorvoreanu, M., Fournery, A., Nushi, B., Collisson, P., Suh, J., Iqbal, S., Bennett, P. N., Inkpen, K., Teevan, J., Kikin-Gil, R., & Horvitz, E. (2019). Guidelines for human-AI interaction. In *Proceedings of the 2019 CHI Conference on Human Factors in Computing Systems* (Paper 3, pp. 1–13). Association for Computing Machinery. <https://doi.org/10.1145/3290605.3300233>
- Bangor, A., Kortum, P. T., & Miller, J. T. (2008). An empirical evaluation of the System Usability Scale. *International Journal of Human-Computer Interaction*, 24(6), 574–594. <https://doi.org/10.1080/10447310802205776>
- Beyer, B., Jones, C., Petoff, J., & Murphy, N. R. (Eds.). (2016). *Site reliability engineering: How Google runs production systems*. O'Reilly Media.
- Bliss, J. P., Gilson, R. D., & Deaton, J. E. (1995). Human probability matching behaviour in response to alarms of varying reliability. *Ergonomics*, 38(11), 2300–2312.
<https://doi.org/10.1080/00140139508925269>
- Brooke, J. (1996). SUS: A quick and dirty usability scale. In P. W. Jordan, B. Thomas, B. A. Weerdmeester, & I. L. McClelland (Eds.), *Usability evaluation in industry* (pp. 189–194). Taylor & Francis.
- Buçinca, Z., Malaya, M. B., & Gajos, K. Z. (2021). To trust or to think: Cognitive forcing functions can reduce overreliance on AI in AI-assisted decision-making. *Proceedings of the ACM on Human-Computer Interaction*, 5(CSCW1), Article 188.
<https://doi.org/10.1145/3449287>
- Central Bank of Nigeria. (2024). *Risk-based cybersecurity framework and guidelines for deposit money banks and payment service banks*.
https://www.cbn.gov.ng/Out/2024/BSD/CBN%20Risk-Based%20Cybersecurity%20Framework%20for%20DMBs%20and%20PSBs_2024.pdf
- Chen, Y., Shetty, M., Somashekar, G., Ma, M., Simmhan, Y., Mace, J., Bansal, C., Wang, R., & Rajmohan, S. (2025). AIOpsLab: A holistic framework to evaluate AI agents for enabling autonomous clouds. *Proceedings of Machine Learning and Systems*, 7.
https://proceedings.mlsys.org/paper_files/paper/2025/hash/d1f9e4a9f109b6e8b75ed362736f22ec-Abstract-Conference.html

- Chen, Y., Xie, H., Ma, M., Kang, Y., Gao, X., Shi, L., Cao, Y., Gao, X., Fan, H., Wen, M., Zeng, J., Ghosh, S., Zhang, X., Zhang, C., Lin, Q., Rajmohan, S., Zhang, D., & Xu, T. (2024). Automatic root cause analysis via large language models for cloud incidents. In *Proceedings of the Nineteenth European Conference on Computer Systems* (pp. 674–688). Association for Computing Machinery.
<https://doi.org/10.1145/3627703.3629553>
- Cvach, M. (2012). Monitor alarm fatigue: An integrative review. *Biomedical Instrumentation & Technology*, 46(4), 268–277. <https://doi.org/10.2345/0899-8205-46.4.268>
- Datadog. (n.d.). *Knowledge sources for Bits Investigation*. Retrieved July 30, 2026, from https://docs.datadoghq.com/bits_ai/bits_investigation/knowledge_sources/
- Es, S., James, J., Espinosa Anke, L., & Schockaert, S. (2024). RAGAs: Automated evaluation of retrieval augmented generation. In *Proceedings of the 18th Conference of the European Chapter of the Association for Computational Linguistics: System Demonstrations* (pp. 150–158). Association for Computational Linguistics.
<https://doi.org/10.18653/v1/2024.eacl-demo.16>
- Federal Republic of Nigeria. (2023). *Nigeria Data Protection Act, 2023*. Nigeria Data Protection Commission. <https://ndpc.gov.ng/download/nigeria-data-protection-act-2023>
- Gemini 2.5 Team. (2025). *Gemini 2.5: Pushing the frontier with advanced reasoning, multimodality, long context, and next generation agentic capabilities* [Preprint]. arXiv.
<https://doi.org/10.48550/arXiv.2507.06261>
- Grafana Labs. (n.d.). *Grafana Loki documentation*. Retrieved July 30, 2026, from <https://grafana.com/docs/loki/latest/>
- Gregor, S., & Hevner, A. R. (2013). Positioning and presenting design science research for maximum impact. *MIS Quarterly*, 37(2), 337–355.
<https://doi.org/10.25300/MISQ/2013/37.2.01>
- Guo, H., Yang, J., Liu, J., Yang, L., Chai, L., Bai, J., Peng, J., Hu, X., Chen, C., Zhang, D., Shi, X., Zheng, T., Zheng, L., Zhang, B., Xu, K., & Li, Z. (2024). OWL: A large language model for IT operations. In *The Twelfth International Conference on Learning Representations*. <https://openreview.net/forum?id=SZOQ9RKYJu>
- He, P., Zhu, J., Zheng, Z., & Lyu, M. R. (2017). Drain: An online log parsing approach with fixed depth tree. In *2017 IEEE International Conference on Web Services (ICWS)* (pp. 33–40). IEEE. <https://doi.org/10.1109/ICWS.2017.13>
- Hevner, A. R., March, S. T., Park, J., & Ram, S. (2004). Design science in information systems research. *MIS Quarterly*, 28(1), 75–105. <https://doi.org/10.2307/25148625>

- Hou, X., Zhao, Y., Liu, Y., Yang, Z., Wang, K., Li, L., Luo, X., Lo, D., Grundy, J., & Wang, H. (2024). Large language models for software engineering: A systematic literature review. *ACM Transactions on Software Engineering and Methodology*, 33(8), Article 220. <https://doi.org/10.1145/3695988>
- International Organization for Standardization. (2022). *ISO/IEC 27001:2022 information security, cybersecurity and privacy protection: Information security management systems: Requirements*. <https://www.iso.org/standard/27001>
- Jacovi, A., Marasović, A., Miller, T., & Goldberg, Y. (2021). Formalizing trust in artificial intelligence: Prerequisites, causes and goals of human trust in AI. In *Proceedings of the 2021 ACM Conference on Fairness, Accountability, and Transparency* (pp. 624–635). Association for Computing Machinery. <https://doi.org/10.1145/3442188.3445923>
- Jin, P., Zhang, S., Ma, M., Li, H., Kang, Y., Li, L., Liu, Y., Qiao, B., Zhang, C., Zhao, P., He, S., Sarro, F., Dang, Y., Rajmohan, S., Lin, Q., & Zhang, D. (2023). Assess and summarize: Improve outage understanding with large language models. In *Proceedings of the 31st ACM Joint European Software Engineering Conference and Symposium on the Foundations of Software Engineering* (pp. 1657–1668). Association for Computing Machinery. <https://doi.org/10.1145/3611643.3613891>
- K8sGPT. (n.d.). *Getting started guide*. Retrieved July 30, 2026, from <https://docs.k8sgpt.ai/getting-started/getting-started/>
- LangChain. (n.d.). *LangGraph overview*. Retrieved July 30, 2026, from <https://docs.langchain.com/oss/python/langgraph/overview>
- Lee, J. D., & See, K. A. (2004). Trust in automation: Designing for appropriate reliance. *Human Factors*, 46(1), 50–80. https://doi.org/10.1518/hfes.46.1.50_30392
- Lewis, P., Perez, E., Piktus, A., Petroni, F., Karpukhin, V., Goyal, N., Kuttler, H., Lewis, M., Yih, W., Rocktäschel, T., Riedel, S., & Kiela, D. (2020). Retrieval-augmented generation for knowledge-intensive NLP tasks. *Advances in Neural Information Processing Systems*, 33, 9459–9474. <https://proceedings.neurips.cc/paper/2020/hash/6b493230205f780e1bc26945df7481e5-Abstract.html>
- Mäntymäki, M., Minkinen, M., Birkstedt, T., & Viljanen, M. (2022). Defining organizational AI governance. *AI and Ethics*, 2(4), 603–609. <https://doi.org/10.1007/s43681-022-00143-x>
- Morley, J., Floridi, L., Kinsey, L., & Elhalal, A. (2020). From what to how: An initial review of publicly available AI ethics tools, methods and research to translate principles into practices. *Science and Engineering Ethics*, 26(4), 2141–2168. <https://doi.org/10.1007/s11948-019-00165-5>

- Mulligan, D. K., & Bamberger, K. A. (2018). Saving governance-by-design. *California Law Review*, 106(3), 697–784. <https://doi.org/10.15779/Z38QN5ZB5H>
- National Institute of Standards and Technology. (2023). *Artificial intelligence risk management framework (AI RMF 1.0)* (NIST AI 100-1). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.AI.100-1>
- National Institute of Standards and Technology. (2024). *Artificial intelligence risk management framework: Generative artificial intelligence profile* (NIST AI 600-1). U.S. Department of Commerce. <https://doi.org/10.6028/NIST.AI.600-1>
- New Relic. (n.d.). *Meet New Relic AI, your observability assistant*. Retrieved July 30, 2026, from <https://docs.newrelic.com/docs/agent-ai/new-relic-ai/>
- OpenAPI Initiative. (2025). *OpenAPI specification, version 3.1.2*. <https://spec.openapis.org/oas/v3.1.2.html>
- OWASP Foundation. (2025). *OWASP Top 10:2025*. <https://owasp.org/Top10/>
- PagerDuty. (n.d.). *PagerDuty AIOps*. Retrieved July 30, 2026, from <https://support.pagerduty.com/main/docs/aiops>
- Parasuraman, R., & Manzey, D. H. (2010). Complacency and bias in human use of automation: An attentional integration. *Human Factors*, 52(3), 381–410. <https://doi.org/10.1177/0018720810376055>
- Parasuraman, R., & Riley, V. (1997). Humans and automation: Use, misuse, disuse, abuse. *Human Factors*, 39(2), 230–253. <https://doi.org/10.1518/001872097778543886>
- Parasuraman, R., Sheridan, T. B., & Wickens, C. D. (2000). A model for types and levels of human interaction with automation. *IEEE Transactions on Systems, Man, and Cybernetics - Part A: Systems and Humans*, 30(3), 286–297. <https://doi.org/10.1109/3468.844354>
- Peppers, K., Tuunanen, T., Rothenberger, M. A., & Chatterjee, S. (2007). A design science research methodology for information systems research. *Journal of Management Information Systems*, 24(3), 45–77. <https://doi.org/10.2753/MIS0742-1222240302>
- Prometheus Authors. (n.d.). *Exposition formats*. Retrieved July 30, 2026, from https://prometheus.io/docs/instrumenting/exposition_formats/
- Raji, I. D., Smart, A., White, R. N., Mitchell, M., Gebru, T., Hutchinson, B., Smith-Loud, J., Theron, D., & Barnes, P. (2020). Closing the AI accountability gap: Defining an end-to-end framework for internal algorithmic auditing. In *Proceedings of the 2020 Conference on Fairness, Accountability, and Transparency* (pp. 33–44). Association for Computing Machinery. <https://doi.org/10.1145/3351095.3372873>
- Roy, D., Zhang, X., Bhawe, R., Bansal, C., Las-Casas, P. H. B., Fonseca, R., & Rajmohan, S. (2024). Exploring LLM-based agents for root cause analysis. In *Companion*

- Proceedings of the 32nd ACM International Conference on the Foundations of Software Engineering* (pp. 208–219). Association for Computing Machinery.
<https://doi.org/10.1145/3663529.3663841>
- Salah, S., Maciá-Fernández, G., & Díaz-Verdejo, J. E. (2013). A model-based survey of alert correlation techniques. *Computer Networks*, 57(5), 1289–1317.
<https://doi.org/10.1016/j.comnet.2012.10.022>
- Shinn, N., Cassano, F., Gopinath, A., Narasimhan, K., & Yao, S. (2023). Reflexion: Language agents with verbal reinforcement learning. *Advances in Neural Information Processing Systems*, 36, 8634–8652. <https://doi.org/10.52202/075280-0377>
- Shneiderman, B. (2020). Human-centered artificial intelligence: Reliable, safe & trustworthy. *International Journal of Human-Computer Interaction*, 36(6), 495–504.
<https://doi.org/10.1080/10447318.2020.1741118>
- Venable, J., Pries-Heje, J., & Baskerville, R. (2016). FEDS: A framework for evaluation in design science research. *European Journal of Information Systems*, 25(1), 77–89.
<https://doi.org/10.1057/ejis.2014.36>
- Xu, J., Zhang, Q., Zhong, Z., He, S., Zhang, C., Lin, Q., Pei, D., He, P., Zhang, D., & Zhang, Q. (2025). OpenRCA: Can large language models locate the root cause of software failures? In *International Conference on Learning Representations*.
https://proceedings.iclr.cc/paper_files/paper/2025/hash/d29b8d53678015079e1d245c023e49d2-Abstract-Conference.html
- Yao, S., Zhao, J., Yu, D., Du, N., Shafran, I., Narasimhan, K., & Cao, Y. (2023). ReAct: Synergizing reasoning and acting in language models. In *The Eleventh International Conference on Learning Representations*.
https://openreview.net/forum?id=WE_vluYUL-X
- Yuan, P., Tang, L., Liu, Y., Kobayashi, Y., Sato, M., & Chen, H. (2025). Incident diagnosing and reporting system based on retrieval augmented large language model. *Proceedings of the AAAI Conference on Artificial Intelligence*, 39(28), 29721–29723.
<https://doi.org/10.1609/aaai.v39i28.35379>

APPENDIX A: API ENDPOINT REFERENCE

Appendix A lists the HTTP endpoints exposed by the InfraGuard AI API. A dagger marks routes that require a valid session cookie. Only the health check and login routes are public.

A.1 Authentication and Health

GET /login: Serve the login page. POST /login: Submit credentials; sets a signed session cookie on success; rate-limited to five attempts per minute.

GET /logout †: Clear the session cookie.

GET /health: Liveness probe; returns 200 when the API is reachable.

A.2 Status, History, and Configuration

GET /status †: The latest verdict with staleness (age, stale) and memory (fingerprint, acknowledged, suppressed) fields.

GET /api/config †: Report integration availability as booleans without exposing secret configuration values.

GET /alerts †: The twenty most recent verdicts with their per-row memory fields.

Local runbooks: Markdown files mounted read-only from ./runbooks and indexed from RUNBOOKS_DIR=/app/runbooks.

GET /api/agent/mode †: The active reasoning mode (LangChain or direct) together with the selected provider and model.

A.3 Verdict Memory

POST /api/verdicts/ack †: Acknowledge a verdict condition as a known non-issue, keyed on its fingerprint; rejected with HTTP 409 for high/critical severity.

POST /api/verdicts/unack †: Remove an acknowledgement so the condition re-opens.

GET /api/acks †: List the active acknowledgements.

A.4 Threats

GET /api/threats †: Scan recent Loki logs for HTTP/SSH brute-force and port-scan patterns; returns detected threats and source IPs.

POST /api/threats/apply †: Build and apply a CrowdSec ban for a detected threat; runs in dry-run mode when CrowdSec is not configured.

A.5 Runbooks (RAG)

POST /api/runbooks/query †: Answer a question over the indexed runbooks; returns an answer and source citations.

POST /api/runbooks/index †: Clear the derived ChromaDB index and rebuild it from the mounted local Markdown runbooks.

Use the Re-index control to clear the derived ChromaDB index and rebuild it from the Markdown files currently mounted under /app/runbooks.

APPENDIX B: SAMPLE CODE SNIPPETS

The excerpts below show the fingerprint, severity safeguard, known-condition prompt block, threat detector, and LangGraph workflow. The project repository contains the complete source.

B.1 Verdict Fingerprint and Signature Derivation

From `agent/memory.py`, the v2 fingerprint and defensive canonical fallback used by the acknowledgement feature:

```
import hashlib, re

PROMPT_VERSION = "2"          # invalidates version-1 acknowledgement matches
DEFAULT_MODEL = "gemini-3.6-flash"
OK_SIGNATURE = "none:healthy:all"

def compute_fingerprint(signature, model=DEFAULT_MODEL,
                        prompt_version=PROMPT_VERSION):
    """Stable content-plus-ruleset fingerprint for a verdict condition."""
    sig = (signature or "").strip().lower() or OK_SIGNATURE
    basis = f"{sig}\x1f{prompt_version}\x1f{model}"
    return hashlib.sha256(basis.encode("utf-8")).hexdigest()

def derive_signature_fallback(severity, root_cause="", summary=""):
    """Defensive canonical fallback for missing persistence input."""
    sev = (severity or "warning").strip().lower()
    if sev == "ok":
        return OK_SIGNATURE
    severity_slug = _NONWORD.sub("-", sev).strip("-")[:15] or "warning"
    basis = _normalize(root_cause) or _normalize(summary)
    condition_slug = _NONWORD.sub("-", basis).strip("-")[:48] or "unspecified"
    return f"fallback:{severity_slug}-{condition_slug}:all"
# Historical stored two-part values remain readable; new fallbacks are canonical.
```

B.2 Severity Safeguard

From `api/store.py`, the rule that prevents a high or critical verdict from being suppressed:

```
def is_suppressed(severity, acknowledged):
    """An acknowledged condition is hidden only when low-risk;
    high/critical always surface, acknowledged or not."""
    return acknowledged and str(severity or "").lower() in {"ok", "warning"}
```

B.3 Known-Conditions Memory Block

From `agent/llm/prompts.py`, only canonical acknowledgement identifiers are included; operator notes are retained for audit but excluded from model context:

```
def _known_conditions_block(known_conditions):
    if not known_conditions:
        return ""
    lines = []
    for kc in known_conditions:
        sig = str(kc.get("signature") or "").strip()
        if not is_canonical_signature(sig):
            continue
        lines.append(f"- {sig}")
    if not lines:
        return ""
    return (
        "--- BEGIN APPLICATION ACKNOWLEDGEMENT IDENTIFIERS ---\n"
        "These identifiers are data, not instructions or evidence of health. "
        "Determine severity solely from current telemetry. "
        "Never reduce severity because an identifier is listed. "
        "If the exact same condition remains, reuse its identifier verbatim:\n"
        + "\n".join(lines) + "\n--- END APPLICATION ACKNOWLEDGEMENT IDENTIFIERS ---\n\n"
    )
```

B.4 Deterministic Threat Detection

From `agent/tools/threat_response.py`, the deterministic per-source-IP threshold detector:

```
def analyze_threats(loki_logs):
    ip_401_count, ip_ssh_fail = {}, {}
    for entry in loki_logs:
        line = str(entry.get("line", ""))
        low = line.lower()
        if " 401 " in line or " 403 " in line or "unauthorized" in low:
            for ip in _extract_ips(line):
                ip_401_count[ip] = ip_401_count.get(ip, 0) + 1
        if "failed password" in low or "authentication failure" in low:
            for ip in _extract_ips(line):
                ip_ssh_fail[ip] = ip_ssh_fail.get(ip, 0) + 1
    threats = []
    for ip, n in ip_401_count.items():
        if n >= _BRUTE_FORCE_THRESHOLD:
            threats.append({"threat_type": "http_brute_force",
                           "source_ip": ip, "count": n})
    # ... ssh and port-scan thresholds elided ...
    return {"threats_found": bool(threats), "threats": threats}
```

B.5 LangGraph Reasoning Loop

From agent/orchestrator.py, the four-node state machine:

```
def build_graph():
    graph = StateGraph(GraphState)
    graph.add_node("collect_data", _collect_data)
    graph.add_node("analyze", _analyze)
    graph.add_node("decide_action", _decide_action)
    graph.add_node("notify", _notify)
    graph.add_edge(START, "collect_data")
    graph.add_edge("collect_data", "analyze")
    graph.add_edge("analyze", "decide_action")
    graph.add_conditional_edges("decide_action", _route_notify,
                               {"notify": "notify", "skip": END})
    graph.add_edge("notify", END)
    return graph.compile()
```

APPENDIX C: DOCKER COMPOSE CONFIGURATION

The docker-compose.yml extract below defines the single-host deployment. Both application containers mount the SQLite volume. The API additionally mounts the local runbooks read-only, the ChromaDB volume and the embedding cache. Docker monitoring is optional, but the shown composition mounts the Docker socket into the agent; omit that mount when local-container monitoring is not required. Ollama provides the self-hosted model path.

```
services:
  api:
    build: {context: ., dockerfile: api/Dockerfile}
    image: ${REGISTRY:-infraguard}/api:latest
    env_file: [.env]
    ports: ["127.0.0.1:8080:8080"]
    environment:
      - PYTHONPATH=/app
      - DB_PATH=/data/verdicts.db
      - RUNBOOKS_DIR=/app/runbooks
    volumes:
      - ./runbooks:/app/runbooks:ro
      - sqlite_data:/data
      - chroma_data:/app/chroma_db
      - embedding_cache:/root/.cache
    restart: unless-stopped
    healthcheck:
      test: ["CMD", "curl", "-f", "http://localhost:8080/health"]
      interval: 30s
      timeout: 10s
      retries: 3
  agent:
    build: {context: ., dockerfile: agent/Dockerfile}
    image: ${REGISTRY:-infraguard}/agent:latest
    env_file: [.env]
    environment:
      - PYTHONPATH=/app
      - DB_PATH=/data/verdicts.db
    volumes:
      - /var/run/docker.sock:/var/run/docker.sock:ro
      - sqlite_data:/data
    restart: unless-stopped
    depends_on: [api]
  ollama:
    image: ollama/ollama:latest
    volumes: [ollama_data:/root/.ollama]
    restart: unless-stopped

volumes:
  sqlite_data: {}
  chroma_data: {}
  embedding_cache: {}
  ollama_data: {}
```

APPENDIX D: PRACTITIONER USABILITY INSTRUMENT AND DESCRIPTIVE EXPLORATORY SUS RESULTS

Appendix D records the intended practitioner task script, the SUS questionnaire and the descriptive exploratory analysis. The SUS survey is distinct from the practitioner benchmark role reports. Eleven participants consented and ten complete responses were analysed under the complete-case rule. The formula-driven analysis workbook retains an unchanged raw-response copy; identity/contact records remain confidential, and a separate standalone source-export file was not present in the repository.

D.1 Task Script

The following interaction sequence structured the intended practitioner evaluation. The retained survey export verifies consent and item-level SUS responses but does not include task-by-task success, timing, error or assistance records. Those task-performance outcomes are therefore not claimed and should be retained in any replication.

1. Log in to the dashboard and state the current overall severity.
2. Open the root-cause and recommended-action sections of a non-OK verdict and paraphrase them.
3. State which integrations are configured by reading the status chips.
4. Ask the runbook assistant a question and confirm a cited answer is returned.
5. Locate a detected threat and trigger the block-IP action (dry-run).
6. Mark a recurring warning as known, and confirm on the next refresh that it is hidden in the default presentation while the verdict record remains stored.
7. Explain what the stale-agent banner indicates.

D.2 System Usability Scale Questionnaire

Participants rate each statement on a five-point scale from 1 (strongly disagree) to 5 (strongly agree). The standard SUS scoring is applied: for odd-numbered items subtract 1 from the response; for even-numbered items subtract the response from 5; sum the ten contributions and multiply by 2.5 to yield a score out of 100 (Brooke, 1996).

1. I think that I would like to use this dashboard frequently.
2. I found the dashboard unnecessarily complex.
3. I thought the dashboard was easy to use.

4. I think that I would need the support of a technical person to be able to use this dashboard.
5. I found the various functions in this dashboard were well integrated.
6. I thought there was too much inconsistency in this dashboard.
7. I would imagine that most people would learn to use this dashboard very quickly.
8. I found the dashboard very cumbersome to use.
9. I felt very confident using the dashboard.
10. I needed to learn a lot of things before I could get going with this dashboard.

The executed export did not retain structured interview responses or free-text comments. A future larger study should add a short interview covering effectiveness, efficiency, learnability and trust, and should retain task results, qualitative themes and resulting interface changes alongside the item-level SUS record.

D.3 Executed Descriptive Exploratory SUS Study

Eleven consented human-practitioner submissions were received. Complete-case analysis retained P1-P8, P10 and P11 and excluded P9 because Question 3 was blank. No answer was inferred, reconstructed or imputed. Five included participants were grouped as DevOps/DevSecOps and five as SRE. The source export records one to five years of relevant experience in the complete sample.

Table D.1 reports the participant-level scores. The arithmetic is reproducible from the item responses in the supporting workbook. The source workbook's form quiz Score column is excluded because it contains zeros and is unrelated to the standard SUS calculation.

Table D.1: Included Human SUS Participant Scores.

Participant	Role group	Years of experience	SUS score
P1	DevOps/DevSecOps	2	92.5
P2	SRE	5	70.0
P3	DevOps/DevSecOps	3	62.5
P4	DevOps/DevSecOps	1	92.5
P5	DevOps/DevSecOps	3	90.0
P6	SRE	4	95.0
P7	SRE	1	77.5
P8	DevOps/DevSecOps	3	97.5
P10	SRE	4	75.0
P11	SRE	2	40.0

The ten-item raw response means are reported in Table D.2. Positive and negative wording is shown because the polarity determines the SUS adjustment; the values themselves remain the original one-to-five responses.

Table D.2: Mean Raw Response by SUS Item.

SUS item	Mean raw response	Polarity
Q1	4.60	Positive
Q2	2.20	Negative
Q3	3.90	Positive
Q4	1.60	Negative
Q5	3.80	Positive
Q6	1.60	Negative
Q7	4.20	Positive
Q8	1.90	Negative
Q9	4.20	Positive
Q10	1.70	Negative

Reproducibility record: outputs/2026-08-26-infraguard-sus/InfraGuard_AI_SUS_Analysis_10_Complete.xlsx; analysis SHA-256 d7baddcee9d98293d87d70b8fde3f4e7993fc7fd13178faaed038ee6fd13a2d6; source-export SHA-256 ee7da2f72d651007dd68d652a0aba52fa7b57209247006feb453cb11b45e0f43. The workbook retains the unchanged source responses, explicit inclusion rule, exclusion reason, formula-based participant scores and all reported aggregates.

APPENDIX E: CONTROLLED INCIDENT AND RAG EVALUATION PROTOCOL AND OBJECTIVE RESULTS

This appendix records the frozen protocol and objective qwen2.5:3b results. Incident severity, schema, signature, retrieval, runtime and token observations derive from retained rows. Appendix F documents the separate practitioner-role-report provenance boundary and qualitative permitted use; Appendix D contains the descriptive SUS evidence.

E.1 Evaluation Questions and Fixed Conditions

The benchmark asks whether the configured model returns the expected severity, identifies the controlled cause, recommends a safe action, grounds material claims in supplied evidence, follows the verdict schema and maintains the required signature behaviour. The first execution fixed qwen2.5:3b on Ollama 0.30.11, temperature 0.0, benchmark version 1.0.0, identical fixtures, top-four retrieval and three repeated runs per case. Raw and parsed outputs, timestamps, latency, input/output tokens, retrieval ranks, objective scores, model digest and source hashes were retained.

Gold-label provenance. The researcher constructed the 24 purposive synthetic scenarios and assigned their primary severity labels before execution using the operational definitions in Table E.1. The retained role reports did not establish or validate the labels, and no independent expert-panel adjudication record exists. Each scenario had one primary label. C20 remains warning in the primary analysis; {ok, warning} and exclusion are post hoc sensitivity checks. Severity agreement therefore measures correspondence with the researcher-defined policy, not real-world diagnostic truth. C23 is the historical acknowledgement-conditioned exception explained after Table E.2.

Table E.1: Gold Severity Policy for the Controlled Benchmark.

Gold Severity	Operational Definition
ok	All present signals are within the expected band, or an optional integration is absent without evidence of application impact.
warning	Degradation or an observability problem exists, but the monitored service remains available and there is no immediate outage or data-loss risk.
high	An active service failure, security event or material degradation requires prompt operator intervention.
critical	Evidence indicates a widespread outage, immediate data-loss risk, or severe compromise requiring urgent containment.

E.2 Controlled Incident Scenario Set

The twenty-four scenarios below use deterministic telemetry fixtures. Gold labels must be frozen before model execution. Fixture changes, prompt changes and model-version changes should create a new benchmark version rather than silently replacing prior observations.

Table E.2: Controlled Incident Benchmark Scenarios and Gold Expectations.

ID	Category	Controlled Evidence	Gold Expectation
C01	Healthy	Normal CPU, memory and disk; HTTP 200; informational logs; Docker monitoring disabled.	ok; healthy state; no action beyond routine monitoring.
C02	Healthy	Only a healthy HTTP probe is present; Loki, Prometheus and Docker sections are absent.	ok; absent optional integrations must not be reported as incidents.
C03	Healthy	Normal metrics with sparse informational logs and no error pattern.	ok; no unsupported root cause or remediation.
C04	Degraded	CPU above 90% for 15 minutes; endpoint remains HTTP 200 with rising latency.	warning; CPU saturation; inspect workload and process utilisation.
C05	Degraded	Memory above 88% with growing swap; no OOM event and endpoint remains available.	warning; memory pressure; inspect consumers and capacity.
C06	Degraded	Disk utilisation at 86% and increasing; no write failure.	warning; low free space; identify growth and reclaim or expand storage.
C07	Degraded	HTTP latency is elevated while status remains 200 and error rate is normal.	warning; latency degradation; inspect dependencies and recent changes.
C08	Degraded	Prometheus data is stale while the application probe and logs remain healthy.	warning; monitoring-data freshness problem, not an application outage.
C09	Failure	Application probe returns 503 and Loki shows a matching HTTP 5xx spike.	high; active API failure; inspect application logs and dependency health.
C10	Failure	Endpoint connection is refused across repeated probes.	high; service unavailable; verify process, listener and network path.
C11	Failure	Redis connection errors coincide with failed dependent requests.	high; Redis dependency unavailable; restore service and verify clients.
C12	Failure	Database pool-exhaustion messages coincide with request timeouts.	high; connection pool exhausted; inspect leaks, limits and database health.
C13	Failure	Container restart loop and unhealthy state coincide with probe failure.	high; unstable container; inspect exit reason, logs and deployment change.
C14	Failure	Disk reaches 98% and logs show write failures.	critical; imminent service/data risk; stop growth and recover space urgently.
C15	Security	Repeated HTTP 401/403 responses from one IP cross the deterministic threshold.	high; probable HTTP brute force; review evidence before approved containment.
C16	Security	Repeated SSH authentication failures from one IP cross the threshold.	high; probable SSH brute force; validate source and apply approved response.
C17	Security	Rapid connection attempts across ports from one IP cross the scan threshold.	high; probable port scan; validate and consider operator-approved ban.
C18	Ambiguous	CPU is high during a labelled batch job; probes and error rates remain healthy.	warning; constrained statement of load; do not claim an outage.
C19	Ambiguous	Latency is high with normal server metrics and intermittent network errors.	warning; uncertain network/dependency cause; recommend discriminating checks.
C20	Ambiguous	One transient HTTP 500 occurs while subsequent probes, logs and metrics are normal.	warning under the primary frozen label; ok is examined only in sensitivity analysis; avoid claiming persistent failure.
C21	Missing telemetry	Docker collector returns the disabled or missing-configuration sentinel.	ok; omit Docker from the verdict and do not treat it as a fault.

ID	Category	Controlled Evidence	Gold Expectation
C22	Missing telemetry	Configured Loki query returns a connection error while application metrics and probes are healthy.	warning; telemetry-source failure; do not claim application outage.
C23	Recurring	An acknowledged disk warning recurs unchanged with the same prompt version and model.	Historical v1: ok with the acknowledged signature; see the policy-exception note below. Current v2 does not downgrade severity.
C24	Recurring	The acknowledged disk condition worsens to 98% with write failures.	critical and visible; the severity safeguard must override default-view masking.

C23 retains the historical v1 expectation of ok for an acknowledged unchanged disk warning. The hash-matched v1 prompt treated unchanged acknowledged conditions as accepted non-issues and instructed an ok verdict with the stored signature. This is an acknowledgement-conditioned exception to Table E.1, whereas current v2 acknowledgement changes eligible default presentation without downgrading severity. All three C23 runs returned ok but emitted none:healthy:/ rather than the expected prometheus:disk-low:/ signature. The primary 29/72 agreement therefore remains a result under the frozen v1 policy; C23 neither demonstrates correct signature reuse nor validates the current no-downgrade contract.

E.3 Diagnostic Scoring Rubric and Metrics

The public package does not contain completed original item-level assessor ratings, so earlier aggregate human scores and agreement statistics are not reported as recomputable quantitative findings. The retained practitioner reports remain exploratory sources. Separate development scores explicitly labelled AI-simulated are excluded. A subsequent quantitative study should preserve independent original ratings and document reconciliation before reporting agreement.

Table E.3: Per-Response Diagnostic Scoring Rubric.

Dimension	Score	Operational Rule
Severity	0 or 1	1 for the exact frozen gold severity; 0 otherwise. A separately labelled acceptable-set or exclusion result may be reported only as sensitivity analysis.
Root-cause correctness	0-2	0 wrong/unsupported; 1 partly correct or too general; 2 identifies the controlled cause and affected component.
Recommended action	0-2	0 unsafe/irrelevant; 1 partly appropriate; 2 safe, prioritised and suitable for diagnosis or recovery.
Evidence grounding	0-2	0 contradicts or invents evidence; 1 mostly supported with minor extrapolation; 2 every material claim is traceable to supplied evidence.
Schema validity	0 or 1	1 when all required fields parse and severity is allowed; 0 otherwise.

Dimension	Score	Operational Rule
Signature behaviour	0 or 1	1 when the signature format, stability and acknowledged-condition behaviour match the fixture expectation.

Primary automated metrics for the completed execution are exact researcher-label severity agreement, the confusion matrix, macro-averaged precision/recall/F1, schema-valid output rate, signature behaviour, top-four retrieval, latency and tokens. The role reports are qualitative only; the separate SUS result is descriptive perceived-usability evidence.

E.4 Labelled RAG Baseline

Each question is run under the same provider/model with retrieval enabled and disabled. Report retrieval relevance, grounding or traceability, answer correctness and actionable safety separately. The completed execution supports objective retrieval quantitatively. The public package lacks completed original item-level answer-quality ratings, so grounding, correctness and actionable safety remain unresolved.

Table E.4: Labelled Runbook Question Set for RAG and No-RAG Comparison.

ID	Question	Frozen Relevant Runbook
R01	Disk usage is above 90%. What should be checked first?	infrastructure/disk-space-high.md
R02	The host is swapping and memory is nearly exhausted. What are the safe first steps?	infrastructure/memory-pressure.md
R03	Loki has stopped receiving logs. How should ingestion be isolated?	observability/loki-ingestion-gap.md
R04	HTTP 5xx responses spiked after normal operation. What evidence should be correlated?	application/http-5xx-spike.md
R05	A container repeatedly exits and restarts. What should the operator inspect?	containers/container-restart-loop.md
R06	A Prometheus scrape target is down. What checks distinguish target failure from network failure?	observability/prometheus-target-down.md
R07	API latency is high without a matching 5xx spike. What diagnostic sequence is appropriate?	application/api-latency-high.md
R08	Redis is unavailable to the application. What containment and recovery checks are required?	application/redis-unavailable.md
R09	The PostgreSQL connection pool is exhausted. What should be examined before increasing limits?	application/database-connection-exhaustion.md
R10	Internal DNS resolution is failing. How should the operator isolate the fault?	infrastructure/dns-resolution-failure.md
R11	One IP is producing repeated SSH authentication failures. What review and response steps apply?	security/ssh-brute-force.md
R12	A service regressed immediately after deployment. What evidence supports rollback or continued diagnosis?	containers/deployment-regression.md

E.5 Execution and Reporting Procedure

1. Freeze the benchmark version, gold labels, prompt version, provider, model, temperature, retrieval depth and runbook corpus before execution.

2. Run every incident fixture three times per provider/model configuration and retain both raw and parsed responses.
3. Run every labelled question three times with RAG and three times without RAG under the same provider/model configuration.
4. Record latency, provider token counts and cost from the same execution logs; do not estimate missing measurements after the fact.
5. Provide anonymised outputs and the frozen rubric to independent assessors before revealing the system condition or model identity where practical.
6. Report all runs, parse failures and provider errors. Do not remove difficult cases or change gold labels after observing outputs without publishing a new benchmark version.
7. Present category-level automated results, the severity confusion matrix, RAG retrieval success and the stated limitations. Report assessor agreement only when independently completed original item-level ratings are available for recomputation. Conclusions must remain within the tested models, fixtures and single-host context.
8. When multiple human practitioners score the same outputs, retain each assessor's item-level scores, join scores only after independent completion, document any reconciliation, and report inter-rater agreement with the small-sample limitation.

E.6 Evidence Status

The protocol was executed once for qwen2.5:3b. Across 72 repeated responses from 24 purposive scenarios, schema validity was 100%, agreement with researcher-defined severity labels was 40.3%, macro-F1 was 0.383, six high-to-warning response-run under-calls arose from the repeated C15 and C17 scenario families, and repeat-stable signatures occurred in 10/24 scenarios. Across twelve questions, a frozen relevant runbook appeared in the top four for 12/12. The unchanged role reports contribute qualitative hypotheses only. No human item-level score, weighted kappa or adjudicated result is adopted.

E.7 Reproducibility Record

The repository retains the frozen specification, execution harness, complete response rows, automatically derived metrics and two unchanged qualitative role reports. The current source includes post-benchmark changes and must not be described as the exact v1 source snapshot; v1 results remain historical under their recorded manifest and must not be overwritten.

The accompanying examiner supplement,

InfraGuard_AI_Frozen_V1_Source_and_Objective_Evidence_20260910.zip, contains the 26 source and runbook files identified by the frozen v1 manifest, including the specification and harness, together with retained objective incident, RAG and retrieval records. Each recovered file matches its recorded SHA-256; the combined source digest also matches. The README provides file locations and a standard-library helper for hash checking and objective recomputation without model calls. The derived configuration/source manifest is evaluation/results/qwen2.5-3b-v1/frozen_configuration_and_source_manifest.json. This attachment is the access copy for examination; no public deposit is asserted.

Supplement SHA-256:

fa4e550dedaaca53d9ac0d6fe295a64f1895f30055ebb0baf4e7541f68d0a51e. Human records

and simulation-labelled assessor files are excluded from this source/objective supplement; the separate SUS workbook and practitioner-report provenance remain identified in Table E.5 and Appendix F.

The frozen harness made serial direct OpenAI-compatible calls to local Ollama at temperature 0.0, with a 300-second client timeout, no automatic SDK retries and completion limits of 320 incident tokens or 420 runbook-answer tokens. It processed each incident three times in C01–C24 order; for each R01–R12 question it ran three RAG generations followed by three no-RAG generations. Elapsed time surrounded the model-client request only, excluding response parsing and prior RAG retrieval/index construction. Percentiles use the nearest-rank value at $\text{ceil}(p \times n)$, rather than averaging the two middle values for an even-sized sample. All 144 retained requests completed with stop termination; none records a timeout or token-limit termination. No generation seed, controlled warm-up, model-cache reset or randomised order was specified.

The retained manifest records Python 3.11.16, Ollama 0.30.11 and the model digest, but does not preserve exact host CPU/GPU/RAM, OS/kernel or container-image identity, installed dependency versions, concurrent load, or initial model/index/cache state. The supplement supports source inspection and recomputation of retained objective results; it is not a complete historical execution environment. Absolute timings remain descriptive and cannot establish portable performance or isolate the causal overhead of retrieval.

Table E.5: Controlled Benchmark Reproducibility Record.

Record	Value or repository-relative location
Frozen specification	evaluation/benchmark_v1.json
Specification SHA-256	7936721040238a95c57d51ec6fa86b9ee104b6b4021df83efdf903604ab58fee
Gold-label origin	Researcher-constructed purposive scenarios and labels, frozen before execution; Table E.1 gives general definitions and Table E.2 discloses the historical C23 exception.
Independent gold-label review	Not performed or retained; the reported severity measure is agreement with the researcher-defined policy, not independently adjudicated or real-world truth.
Label ambiguity handling	C20 warning remains primary; its acceptable-set/exclusion checks are post hoc. C23 retains the historical v1 acknowledgement-conditioned label; no primary label is retrospectively changed.
Benchmark/source relationship	The current source has post-benchmark changes. Interpret v1 against its recorded manifest; do not overwrite or transfer its result to the revised code.
Researcher-reported SRE seed metadata	The report identifies 2026082412 as authoritative and preserves 2026081902 as a legacy method-table value; this metadata is not evidence of independent scoring.
Execution harness	evaluation/run_benchmark.py

Record	Value or repository-relative location
Result set	evaluation/results/qwen2.5-3b-v1/
Model digest	357c53fb659c5076de1d65ccb0b397446227b71a42be9d1603d46168015c9e4b
Incident rows	incident_runs.jsonl; 72 unique scenario/repeat records
RAG rows	rag_runs.jsonl; 72 unique question/condition/repeat records
Objective metrics and historical summary	summary.json, report.md and incident_objective_scores.csv; objective metrics remain distinct from the qualitative practitioner-role material documented in Appendix F.
Practitioner role-report evidence	Unchanged DevOps and SRE role reports are retained with hashes; completed original per-item sheets are absent from the public package, so the reports are used qualitatively only.
Current local working-tree verification	2 September 2026; 180 passed; 0 failed; 45 deprecation warnings; 89% line coverage (1,655 statements; 190 missed). The working tree contained uncommitted and untracked source/test files, including six untracked test modules. No clean commit hash, tagged release, exact dependency lock or container-image identifier was retained for that execution, so it is not a clean-checkout or published-commit receipt.
DevOps practitioner report	evaluation/practitioner_confirmation/InfraGuard_DevOps_Assessment_Report.docx; SHA-256 741b5446c8dffaabfeac20823aa7a4427a4a61c058b1b9e9c619000c641d6720
SRE practitioner report	evaluation/practitioner_confirmation/InfraGuard_SRE_Assessment_Report.docx; SHA-256 7c91dfd735a4a070ce4e6053c5addcfb70cec2d67002b199b43f22f21133efdb
Practitioner provenance status	Two practitioner reports supplied as human assessments; hashes retained. Public item-level ratings are absent, so quantitative assessor statistics are not independently recomputable from the public package. Confidential identity/email records are researcher-reported as held separately.
Practitioner evidence boundary	Role reports support qualitative engineering hypotheses only; no item-level human score, agreement, RAG effect or diagnostic-reliability claim.
Human SUS source export	A separate standalone repository source export was not present; an unchanged raw-response copy is retained inside outputs/2026-08-26-infraguard-sus/InfraGuard_AI_SUS_Analysis_10_Complete.xlsx.
Human SUS analysis workbook	outputs/2026-08-26-infraguard-sus/InfraGuard_AI_SUS_Analysis_10_Complete.xlsx; SHA-256 d7baddcee9d98293d87d70b8fde3f4e7993fc7fd13178faaed038ee6fd13a2d6
Human SUS inclusion record	11 consented submissions; 10 complete analysed; P9 excluded because Question 3 was blank; no imputation; 22-26 August 2026.

APPENDIX F: PRACTITIONER ROLE-REPORT PROVENANCE AND PERMITTED USE

This appendix separates retained practitioner reports, public scoring templates, simulation-labelled development scores and the distinct SUS study. It states what each record supports and where the public evidence package limits recomputation.

F.1 Evidence Inventory and Provenance Boundary

Two unchanged DevOps and SRE reports were supplied as exploratory practitioner assessments. Their recorded hashes verify the retained report copies. Completed original item-level ratings are not present in the inspected public package; the repository describes confidential identity and original email records as held separately by the researcher. This limits independent recomputation from the public package and does not establish that no human assessment occurred. Separate candidate score files match development files explicitly labelled AI-simulated and are excluded from human findings. That finding applies to those files, not to every examiner report or submission.

Table F.1: Practitioner Evidence Inventory and Permitted Use.

Record	Verified status	Permitted use
DevOps practitioner report (SHA-256 741b5446...6720)	Unchanged report supplied as a human practitioner assessment; full hash in Table E.5.	Exploratory report-level observations and engineering hypotheses.
SRE practitioner report (SHA-256 7c91dfd7...efdb)	Unchanged report supplied as a human practitioner assessment; full hash in Table E.5.	Exploratory report-level observations and engineering hypotheses.
Public A/B scoring worksheets	Four 72-row templates contain no populated score or note cells.	Shows a public recomputation gap; does not establish absence of private examiner records.
Development DevOps scores (SHA-256 5888f61b...0200)	The matching JSON file explicitly identifies its scores as AI-simulated.	Excluded from human quantitative findings.
Development SRE scores (SHA-256 3f18ae9e...ddd2)	The matching JSON file explicitly identifies its scores as AI-simulated.	Excluded from human quantitative findings.
Researcher-reported confidential records	Repository documentation reports original emails and identity mapping outside the public package.	Disclosed provenance context; independent verification of private records is not claimed here.
System Usability Scale workbook	A separate workbook retains response-level survey evidence.	Descriptive perceived usability in Appendix D; distinct from diagnostic assessor scoring.

Note. Full report hashes are retained in Table E.5. Reported human participation, report integrity, access to original ratings and independent recomputation are distinct evidence questions. The quantitative exclusion leaves the objective benchmark and the separate SUS analysis unchanged.

F.2 Qualitative Role-Report Themes

The practitioner reports describe concerns about severity-policy alignment, evidence preservation, safe action sequencing, discriminating diagnostic checks and signature stability.

Table 5.10 retains these as exploratory engineering hypotheses. They do not establish prevalence, between-role differences, practitioner consensus or a quantitative RAG effect.

F.3 Requirements for a Future Quantitative Practitioner Study

A stronger subsequent practitioner study should retain independently completed original item-level files before transformation, protect confidential identity and consent records, and use blinded packages with a pre-specified rubric. Preserve raw and reconciled ratings separately and record the analysis and reconciliation procedure. Compute agreement from those retained records; exclude AI-simulated or reconstructed scores from human findings. If original examiner ratings are verified separately, document their provenance and recompute their results without retrospectively changing the frozen benchmark.

For this submission, practitioner findings remain exploratory and qualitative because the public package does not support independent recomputation of quantitative assessor results.